



KEBUTUHAN TEKNIS DAN DESAIN SOLUSI

Financial Crime Intelligence Platform

MVP Capstone Akademik 16 Minggu — Produk Gabungan (Group A + Group B)

ID Dokumen: FCIP-TRD | Versi 0.9 | Status: DRAFT untuk review mentor

Berada di bawah FCIP-FRD v1.0; setiap konflik ditandai di §1.5, tidak pernah diselesaikan diam-diam
Seluruh data bersifat sintetis. Platform ini memberi saran; ia tidak pernah bertindak, memutuskan, atau mengirim.

Organisasi referensi: PT Nusantara Digital Payment — sepenuhnya fiktif

Program Capstone UKDW × V-TEKI

Disiapkan untuk tim mahasiswa gabungan, Dosen Pembimbing, dan Mentor V-TEKI

Cara membaca dokumen ini

Dokumen ini mengubah FRD yang telah disetujui menjadi sesuatu yang dapat dibangun oleh tim mahasiswa dalam enam belas minggu. Lima konvensi berikut memikul sebagian besar bobotnya.

FRD yang berlaku. Jika dokumen ini dan FRD berbeda, FRD yang menang. Konflik dicatat dalam register di §1.5, bukan diselesaikan diam-diam.

Keputusan dicatat, bukan diasumsikan. Dua belas Architecture Decision Record (ADR-001 sampai ADR-012) menyatakan apa yang dipilih, mengapa, apa yang ditolak, dan berapa biayanya. Keputusan tanpa biaya bukanlah keputusan.

Guardrail bersifat struktural. Larangan bertindak atas transaksi, larangan pengiriman, larangan menyetujui pekerjaan sendiri, dan sifat tidak dapat diubahnya audit ditegakkan melalui hak akses database, check constraint, dan ketiadaan client keluar mana pun — sehingga semuanya dapat diuji, bukan sekadar dijanjikan.

Eksibit. Eksibit bernomor memuat diagram arsitektur, kontrak, dan matriks. Setiap diagram berupa teks siap-Mermaid, sehingga dapat dibangkitkan ulang dan dikelola versinya berdampingan dengan kode.

Gate Minggu 4. Bagian 17 adalah Integration Contract antara Group A dan Group B. Tidak ada yang boleh dibangun di luar kerangka dasar sebelum kedua group lead dan mentor menandatangani.

Daftar Isi

1. Kontrol Dokumen, Keputusan dan Asumsi
 - 1.1 Identifikasi
 - 1.2 Penulis dan Persetujuan
 - 1.3 Architecture Decision Records (ADRs)
 - 1.4 Ringkasan Stack yang Direkomendasikan
 - 1.5 Register Konflik FRD
 - 1.6 Asumsi (Teknis)
2. Pemetaan Ruang Lingkup FRD-ke-Komponen dan Batas MVP
 - 2.1 Pemetaan
 - 2.2 Batas Teknis MVP
3. Arsitektur (C4)
 - 3.1 Level 1 — Konteks Sistem
 - 3.2 Level 2 — Diagram Container
 - 3.3 Level 3 — Diagram Komponen (Pipeline Deteksi)
 - 3.4 Level 3 — Diagram Komponen (Investigasi dan Keputusan)
 - 3.5 Model Lapisan
4. Katalog Komponen
5. Topologi Deployment MVP
 - 5.1 Topologi
 - 5.2 Layanan, Sizing dan Justifikasi
 - 5.3 Penyimpanan Data dan Apa yang Tersimpan di Mana
 - 5.4 Lingkungan
 - 5.5 Artefak Rule dan Model
 - 5.6 Mengapa Bukan Alternatif Lain
6. Arsitektur Data
 - 6.1 Schema Sumber dan Kontrak File
 - 6.2 Pipeline Ingestion
 - 6.3 Quarantine dan Jalur Error
 - 6.4 Processing Log
 - 6.5 Idempotency, Deduplication dan Kedatangan Terlambat
 - 6.6 Reprocessing
 - 6.7 Pemisahan Schema dan Role Database
 - 6.8 Retensi dan Pengarsipan
7. Model Data dan ERD
 - 7.1 Konvensi
 - 7.2 ERD Inti
 - 7.3 Definisi Tabel Utama (diringkas sebatas yang menjadi sandaran kontrak)
 - 7.4 Rantai Ketertelusuran
 - 7.5 Catatan Index dan Performa
8. Kontrak API
 - 8.1 Konvensi
 - 8.2 Kosakata Bersama (normatif bagi kedua group)
 - 8.3 Katalog Endpoint — Group A (api-detection)
 - 8.4 Katalog Endpoint — Group B (api-investigation)
 - 8.5 Endpoint Bersama
 - 8.6 Contoh Request/Response Sintetis
 - 8.7 Domain Event
 - 8.8 Schema Audit Event (normatif)
 - 8.9 Envelope dan Kode Error
 - 8.10 Penegakan RBAC pada Lapisan API
 - 8.11 Ringkasan Kepemilikan Antarmuka A↔B
9. Desain Rekayasa Deteksi
 - 9.1 Pendekatan Rekayasa
 - 9.2 Registri Feature (C-04)
 - 9.3 Spesifikasi Rekayasa per Pattern
 - 9.4 Transaksi Pembuatan Alert
 - 9.5 Mode Simulasi
 - 9.6 Batas Penekanan Duplikat (menyelesaikan CF-01)
 - 9.7 Penanganan Pattern Bersamaan (menyelesaikan CF-07)

9.8 Desain Kinerja Deteksi

10. Desain Risk, Anomaly, Graph dan Screening yang Dapat Dijelaskan

- 10.1 Model Risk (C-05)
- 10.2 Model Anomaly (C-07)
- 10.3 Desain Graph (C-08, C-16)
- 10.4 Desain Screening (C-09)
- 10.5 Metadata Model dan Rule (seragam untuk keempatnya)
- 10.6 Evaluasi dan Pemantauan Hanya-Sintetis

11. Generator Data Sintetis

- 11.0 Prinsip
- 11.1 Target Volume
- 11.2 Komposisi Populasi
- 11.3 Skenario dan Label yang Diinjeksikan
- 11.4 Cacat Kualitas yang Disengaja
- 11.5 Populasi Uji Entity Resolution
- 11.6 Data Investigasi yang Di-seed
- 11.7 Kamus Data dan Reprodutibilitas

12. Desain Keamanan dan Privasi

- 12.1 Matriks Ancaman (proporsional untuk MVP akademik internal)
- 12.2 Autentikasi
- 12.3 Otorisasi dan Hak Akses Minimum
- 12.4 Perlindungan Data dan Masking
- 12.5 Validasi Input dan Unggahan Aman
- 12.6 Logging yang Aman
- 12.7 Manajemen Secret
- 12.8 Backup dan Pemulihan
- 12.9 Kontrol Jaringan dan Egress
- 12.10 Higiene Dependensi dan Rantai Pasok

13. Desain Narrative AI

- 13.1 Paket Input (grounded, mencakup case)
- 13.2 Konstruksi Prompt
- 13.3 Pemeriksaan Grounding (C-21)
- 13.4 Perilaku Ketika Evidence Tidak Lengkap
- 13.5 AI Usage Log
- 13.6 Template Fallback

14. Observability dan Audit

- 14.1 Logging Terstruktur
- 14.2 Desain Audit
- 14.3 Metrik
- 14.4 Alert Demonstrasi (operasional, bukan alert financial crime)
- 14.5 Health dan Readiness

15. Strategi Pengujian

- 15.1 Prinsip
- 15.2 Level Pengujian dan Target Coverage
- 15.3 Desain Pengujian Detection
- 15.4 Pengujian Contract
- 15.5 Matriks Pengujian RBAC dan Maker-Checker
- 15.6 Pengujian Performa Demo
- 15.7 Ketertelusuran

16. CI/CD, Migration, Konfigurasi dan Rollback

- 16.1 Branching dan Review
- 16.2 Pipeline
- 16.3 Job Guardrail (memblokir)
- 16.4 Migration dan Data Seed
- 16.5 Manajemen Konfigurasi
- 16.6 Versioning dan Rilis
- 16.7 Rollback

17. Kontrak Integrasi yang Harus Disetujui pada Minggu 4

- 17.1 Identifier Bersama
- 17.2 State Bersama
- 17.3 Antarmuka Bersama
- 17.4 Event Bersama

- 17.5 Autentikasi Antar Layanan
- 17.6 Error Bersama
- 17.7 Fixture Pengujian Bersama
- 17.8 Checklist Persetujuan — Minggu 4

18. Milestone, Risiko, Keterbatasan dan Lampiran

- 18.1 Milestone Teknis Enam Belas Minggu dan Definition of Done
- 18.2 Kerangka Panduan Deployment
- 18.3 Kerangka Runbook
- 18.4 Risiko, Trade-off dan Keterbatasan
- 18.5 Roadmap Produksi Masa Depan (indikatif, di luar lingkup)
- 18.6 Lampiran A — Kamus ERD (indeks)
- 18.7 Lampiran B — Katalog API (indeks)
- 18.8 Lampiran C — Inventaris Rule dan Model
- 18.9 Lampiran D — Checklist Kesiapan Build

01

1. Kontrol Dokumen, Keputusan dan Asumsi

POIN UTAMA

- Dua belas Architecture Decision Record menyatakan apa yang dipilih, mengapa, apa yang ditolak, dan berapa biayanya — termasuk biaya yang benar-benar akan dirasakan tim.
- Stack yang direkomendasikan adalah Python/FastAPI, PostgreSQL 16, React, dan Docker Compose, dengan fallback Django terdokumentasi yang dipicu pada gate Minggu 4, bukan di Minggu 10.
- Delapan konflik dengan FRD dicatat, bukan diselesaikan diam-diam. Dua di antaranya masih terbuka dan memerlukan jawaban mentor.
- Enam asumsi teknis masing-masing membawa konsekuensi yang disebutkan namanya bila ternyata keliru.

1.1 Identifikasi

Field	Nilai
Judul dokumen	Technical Requirements and Solution Design — Financial Crime Intelligence Platform MVP
ID Dokumen	FCIP-TRD
Versi	0.9 (Draft untuk Review Mentor)
Status	DRAFT
FRD sumber	FCIP-FRD, versi yang dirujuk pada saat build; lihat §1.5 untuk register konflik
Ruang lingkup tim	JOINT PRODUCT
Batasan stack yang diberikan	Tidak ada — dokumen ini merekomendasikan stack utama dan fallback (§1.4, ADR-001)
Target deployment	Docker Compose lokal untuk pengembangan; satu server universitas (atau satu VM setara) untuk demonstrasi; lihat §5
Klasifikasi data	Hanya sintetis
Disiapkan untuk	Tim mahasiswa gabungan, Faculty Supervisor, Mentor V-TEKI

1.2 Penulis dan Persetujuan

Peran	Nama	Ruang lingkup persetujuan	Tanda tangan	Tanggal
Solution Architect (penulis utama)	[Akan ditentukan]	Seluruh dokumen		

Peran	Nama	Ruang lingkup persetujuan	Tanda tangan	Tanggal
Data Architect	[Akan ditentukan]	§6, §7, §11		
Security Architect	[Akan ditentukan]	§12, §14		
ML Engineering Lead	[Akan ditentukan]	§9, §10, §13		
Group A Lead	[Akan ditentukan]	Kelayakan komponen Group A		
Group B Lead	[Akan ditentukan]	Kelayakan komponen Group B		
Mentor V-TEKI	[Akan ditentukan]	Realisme arsitektur, batas MVP, Kontrak Integrasi Minggu-4		
Faculty Supervisor	[Akan ditentukan]	Ruang lingkup dan batasan akademik		

1.3 Architecture Decision Records (ADRs)

Setiap keputusan menyatakan pilihan yang diambil, alasannya, apa yang ditolak, dan berapa biayanya.

ADR-001 — Stack teknologi utama

Keputusan: Python 3.11 + FastAPI (API dan worker), PostgreSQL 16 (satu penyimpanan relasional), React 18 + TypeScript + Vite (SPA), Redis 7 (queue dan cache), RQ atau Celery untuk background job, MinIO (kompatibel S3) untuk objek evidence, Docker Compose untuk orkestrasi.

Alasan: satu bahasa untuk ingestion, deteksi, scoring dan API mengurangi context switching bagi tim mahasiswa; PostgreSQL saja sudah memenuhi kebutuhan relasional, JSON, full-text dan graph rekursif; seluruh stack bersifat gratis, dapat dipasang secara offline dan berjalan pada satu mesin sederhana (CN-05, CN-06, NFR-18).

Ditolak: Java Spring Boot (penyiapan lebih berat dan iterasi lebih lambat untuk tim paruh waktu selama 16 minggu, meskipun merupakan alternatif yang wajar); Node/NestJS untuk backend (pustaka data dan analitik lebih lemah untuk pekerjaan deteksi); tata letak satu microservice per domain (overhead operasional tidak sebanding pada skala ini).

Biaya: performa batch Python memerlukan kehati-hatian pada 500k transaksi — dimitigasi dengan SQL berbasis himpunan untuk window agregasi (§9.1), bukan pemrosesan Python baris per baris.

ADR-002 — Stack fallback

Keputusan: Jika FastAPI/SQLAlchemy terbukti terlalu asing, beralih ke Django 5 + Django REST Framework + Django ORM + Django admin (hanya untuk layar reference data), dengan mempertahankan PostgreSQL, React, Redis dan MinIO tanpa perubahan.

Alasan: auth, migration dan admin bawaan Django mengurangi waktu pembangunan; model data dan kontrak API tidak berubah, sehingga fallback ini merupakan penggantian satu lapisan, bukan perancangan ulang.

Biaya: admin Django harus dikunci (§12.3) agar tidak menjadi pintu belakang yang melewati RBAC dan maker-checker.

ADR-003 — Graph berbasis relasional dengan proyeksi, bukan database graph

Keputusan: Modelkan graph sebagai tabel `graph_node` dan `graph_edge` di PostgreSQL, telusuri dengan CTE rekursif, dan batasi kedalaman serta jumlah node (FR-404). Pertahankan batas adapter yang terdokumentasi agar Neo4j dapat disubstitusikan di kemudian hari.

Alasan: menjawab MQ-06; satu datastore berarti satu backup, satu batas transaksi dan satu set kredensial; penelusuran terbatas (kedalaman ≤ 3 , ≤ 300 node) masih jauh di dalam kemampuan PostgreSQL pada volume data ini; jaminan audit dan imutabilitas tetap berada di satu tempat.

Ditolak: Neo4j Community (datastore kedua yang harus dipasang, diamankan, di-backup dan dijaga konsistensinya dengan kebenaran relasional, hanya untuk penelusuran yang sengaja dibatasi oleh MVP).

Biaya: analitik yang dalam atau tidak terbatas (community detection, shortest-path atas seluruh graph) akan menjadi canggung — secara eksplisit di luar lingkup (§3.2 pada FRD).

ADR-004 — Audit hanya dapat ditambah, ditegakkan pada lapisan database

Keputusan: `audit_event` bersifat hanya dapat ditambah, ditegakkan oleh trigger `BEFORE UPDATE OR DELETE` yang memunculkan exception, ditambah satu role database untuk aplikasi yang hanya memiliki `INSERT` dan `SELECT` pada tabel tersebut.

Alasan: CN-08 dan FR-1104 mensyaratkan bahwa imutabilitas merupakan properti sistem, bukan properti disiplin aplikasi; sebuah cacat atau query nakal tidak boleh mampu menulis ulang riwayat.

Biaya: koreksi terhadap isi audit tidak mungkin dilakukan secara rancangan — dan itulah maksudnya.

ADR-005 — Layanan deteksi tidak memiliki hak tulis pada data sumber

Keputusan: satu role database terpisah (`fcip_detection`) hanya memiliki `SELECT` pada tabel `transaction`, `account` dan `entity` serta `INSERT` pada tabel `alert`, `screening`, `risk` dan `audit`.

Alasan: menjadikan NG-01 dan FR-309 benar secara struktural dan dapat diuji, bukan sekadar dinyatakan.

Biaya: dua role aplikasi yang harus dikelola dalam migration dan konfigurasi.

ADR-006 — Rule engine sebagai template SQL berbasis konfigurasi, bukan DSL scripting

Keputusan: masing-masing dari dua belas pattern diimplementasikan sebagai template SQL/CTE yang terparameterisasi dan terkontrol versi ditambah wrapper Python; sebuah rule version adalah satu baris parameter bertipe yang terikat pada sebuah ID template.

Alasan: menjaga evaluasi tetap berbasis himpunan dan cepat (NFR-04); menjadikan rule version benar-benar tidak dapat diubah dan dapat direproduksi (SM-01); menghindari pembangunan dan pengamanan bahasa scripting bagi pengguna dalam 16 minggu.

Ditolak: DSL ekspresi penuh (ruang lingkup dan risiko injection); produk rule seperti Drools (terlalu berat untuk MVP dan di luar stack).

Biaya: pattern yang benar-benar baru membutuhkan developer, bukan sekadar analyst. Diterima: dua belas pattern telah ditetapkan oleh FRD.

ADR-007 — Hanya model yang dapat dijelaskan

Keputusan: risk scoring menggunakan model faktor berbobot yang transparan; anomaly scoring menggunakan deviasi terstandarisasi per feature terhadap baseline per entity (dan, jika kapasitas memungkinkan, Isolation Forest **hanya** jika kontribusi per feature dapat dilaporkan).

Alasan: NG-07 dan SM-04 mensyaratkan penjelasan pada tingkat feature; model yang kontribusinya tidak dapat ditampilkan tidak dapat digunakan.

Biaya: daya deteksi teoretis lebih rendah dibanding model yang tidak transparan. Diterima secara sengaja.

ADR-008 — Narrative AI melalui provider yang dapat dipasang dengan fallback deterministik

Keputusan: sebuah interface `NarrativeProvider` dengan dua implementasi: provider LLM (endpoint dan model dapat dikonfigurasi, API key dari secrets) dan `TemplateProvider` yang deterministik. Grounding checker bersifat independen dari provider.

Alasan: FR-906 mensyaratkan degradasi yang aman; mentor juga dapat mensyaratkan demo berjalan sepenuhnya offline.

Biaya: dua jalur rendering yang harus diuji. Dimitigasi karena keduanya bermuara pada workflow review dan persetujuan yang sama.

ADR-009 — Satu aplikasi yang dapat di-deploy, berlapis secara internal, dengan batas HTTP internal antara layanan Group A dan Group B

Keputusan: satu repository, satu Compose stack; layanan deteksi/data milik Group A dan layanan investigasi milik

Group B merupakan aplikasi FastAPI terpisah di belakang satu gateway, berbagi satu database dengan pemisahan pada tingkat schema dan grant berbasis role.

Alasan: menjawab MQ-10; batas HTTP yang eksplisit membuat kontrak Minggu-4 dapat diuji dan kepemilikan menjadi tidak ambigu, sementara database bersama menghindari kerumitan transaksi terdistribusi yang tidak mampu ditanggung MVP.

Biaya: database bersama berarti disiplin schema menjadi penting; ditegakkan melalui grant per schema (§6.7) dan contract test (§15.4).

ADR-010 — Penanganan zona waktu

Keputusan: simpan seluruh timestamp sebagai `timestampz` dalam UTC; evaluasi window bisnis dalam Asia/Jakarta menggunakan konversi yang sadar zona; jangan pernah mengasumsikan offset tetap.

Alasan: FR-307 dan AS-09.

Biaya: setiap query window harus eksplisit mengenai zonanya. Ditegakkan melalui helper bersama dan sebuah test yang menjalankan window melintasi batas tengah malam.

ADR-011 — Idempotency pada lapisan database

Keputusan: sebuah unique constraint pada `transaction.idempotency_key`; loader menggunakan `INSERT ... ON CONFLICT DO NOTHING` dan menghitung selisihnya sebagai duplikat yang ditekan; payload yang bertentangan dengan key yang sama dialihkan ke quarantine.

Alasan: FR-103 dan SM-01 mensyaratkan reproduksibilitas yang bertahan terhadap bug aplikasi.

Biaya: jalur konflik memerlukan perbandingan eksplisit antara payload masuk dengan baris yang tersimpan.

ADR-012 — Evidence disimpan sebagai objek dengan metadata di database

Keputusan: berkas di MinIO dengan key beralamat konten (`sha256`), metadata di PostgreSQL; tidak ada API delete; policy bucket menolak delete bagi pengguna aplikasi.

Alasan: imutabilitas FR-813, sekaligus menjaga biner besar tetap di luar database.

Biaya: satu layanan tambahan untuk dijalankan dan di-backup. Dimitigasi: MinIO hanya satu container dan direktori datanya termasuk dalam job backup (§12.8).

1.4 Ringkasan Stack yang Direkomendasikan

Lapisan	Pilihan utama	Versi	Fallback
Frontend	React + TypeScript + Vite, TanStack Query, pustaka komponen sesuai pilihan tim	React 18	Template Django yang dirender di server + HTMX
Visualisasi graph	Cytoscape.js	3.x	vis-network
Chart	Recharts atau Chart.js	terkini	PNG yang dirender di server untuk ekspor
API	FastAPI + Pydantic v2 + SQLAlchemy 2.0 + Alembic	Python 3.11	Django 5 + DRF
Background job	RQ (sederhana) atau Celery (jika kerumitan penjadwalan bertambah) + Redis	Redis 7	APScheduler in-process (hanya dev)
Database	PostgreSQL	16	PostgreSQL 15

Lapisan	Pilihan utama	Versi	Fallback
Object store	MinIO	terkini	Volume filesystem lokal dengan interface yang sama
Auth	OAuth2 password flow dengan JWT access token + refresh, hashing password <code>argon2</code>	—	Auth sesi Django
Observability	Log JSON <code>structlog</code> ; Prometheus + Grafana opsional	—	Log JSON ke berkas dengan layar penampil log
Provider AI	Endpoint LLM yang dapat dikonfigurasi melalui <code>NarrativeProvider</code>	—	<code>TemplateProvider</code> (deterministik)
Packaging	Docker + Docker Compose	Compose v2	Bare-metal dengan unit <code>systemd</code>
CI	GitHub Actions (atau runner milik universitas)	—	Skrip <code>make ci</code> lokal
Testing	<code>pytest</code> , <code>pytest-asyncio</code> , <code>schemathesis</code> (contract), <code>Playwright</code> (E2E)	—	<code>pytest</code> + E2E manual

1.5 Register Konflik FRD

Konflik dengan FRD **ditandai, bukan diselesaikan secara diam-diam** (sesuai brief TRD). Tidak ada satu pun berikut ini yang mengubah perilaku FRD; masing-masing mencatat di mana FRD memerlukan klarifikasi atau di mana desain ini menambahkan batasan yang tidak ditentukan FRD.

ID	Referensi FRD	Observasi	Usulan penyelesaian	Status
CF-01	FRD §5.6 / NG-12	FRD melarang penutupan otonom tetapi mengizinkan penekanan otomatis atas duplikat persis. Keduanya kompatibel, tetapi batasnya harus tidak ambigu dalam code review.	Terapkan penekanan secara ketat sebelum lifecycle (tidak ada baris alert yang dibuat); dokumentasikan di §9.6. Memerlukan konfirmasi mentor atas MQ-09.	Terbuka — MQ-09

ID	Referensi FRD	Observasi	Usulan penyelesaian	Status
CF-02	FRD §5.14	“Jika penulisan audit gagal, perubahan bisnis di-rollback” menyiratkan penulisan audit berbagi transaksi bisnis. Hal ini membatasi tabel audit pada database yang sama.	Dikonfirmasi sesuai rancangan (ADR-004); audit tidak dapat menjadi layanan eksternal pada MVP.	Selesai
CF-03	FRD FR-1104 vs FR-610	Notifikasi secara eksplisit tidak diaudit, sementara “setiap tindakan material” diaudit.	Notifikasi bersifat operasional, bukan material; dicatat ke log aplikasi, bukan ke audit trail. Dicatat di sini untuk menghindari temuan inkonsistensi di kemudian hari.	Selesai
CF-04	FRD §5.5 SLA “jam kerja”	SLA jam kerja memerlukan kalender hari libur yang oleh FRD dicantumkan sebagai konfigurasi tetapi tidak diisi.	Sertakan kalender hari libur Indonesia yang fiktif dan terdokumentasi sebagai seed reference data; tandai sebagai sintetis.	Selesai
CF-05	FRD FR-401	Sebuah anomaly score “tidak boleh membuat alert dengan sendirinya kecuali sebuah rule anomaly dikonfigurasi dan disetujui secara eksplisit”. Tidak ada rule semacam itu di	Anomaly tetap menjadi sinyal pendukung pada MVP; tidak ada rule berbasis anomaly saja yang dirilis. Mentor akan mengonfirmasi.	Terbuka — mentor

ID	Referensi FRD	Observasi	Usulan penyelesaian	Status
		antara dua belas pattern.		
CF-06	FRD FR-709 vs FR-901	Policy masking dan penyusunan paket AI sama-sama mendefinisikan apa yang “sensitif”. Dua definisi berisiko menyimpang.	Satu konfigurasi sensitive_field_policy yang dikonsumsi keduanya (§12.4).	Selesai
CF-07	FRD §8.6 severity P06	Severity P06 dinaikkan ketika P11/P09 terjadi bersamaan, tetapi §8.13 menyatakan pattern dievaluasi secara independen.	Kebersamaan dibaca dari alert yang sudah dibuat dalam run yang sama dan dicatat sebagai sebuah faktor; eskalasi severity diterapkan pada priority scoring (FR-311), bukan di dalam rule. Didokumentasikan di §9.7.	Selesai
CF-08	FRD FR-1109	Backup mencakup “database dan evidence store”; FRD tidak menyebut konfigurasi dan secrets.	Ruang lingkup backup diperluas ke konfigurasi dan seed data; secrets tidak pernah di-backup bersama data (§12.8).	Selesai

1.6 Asumsi (Teknis)

ID	Asumsi	Jika tidak benar
TA-01	Tersedia satu mesin dengan RAM ≥ 8 GB, ≥ 4 core dan disk ≥ 100 GB untuk lingkungan demonstrasi.	Kurangi volume sintetis ke batas bawah §11 dan dokumentasikan pengurangannya.

ID	Asumsi	Jika tidak benar
TA-02	Docker dan Docker Compose diizinkan pada server universitas.	Beralih ke deployment bare-metal dengan unit <code>systemd</code> dan PostgreSQL yang dipasang secara lokal.
TA-03	Internet keluar tersedia pada saat build untuk pemasangan paket, tetapi demonstrasi dapat berjalan sepenuhnya offline.	Sertakan wheel dan paket npm ke dalam repository sebelum demonstrasi; <code>TemplateProvider</code> menutupi jalur AI secara offline.
TA-04	Sebuah endpoint LLM tersedia untuk narrative AI selama pengembangan.	<code>TemplateProvider</code> menjadi jalur yang diserahkan; FR-906 terpenuhi dan keterbatasannya dinyatakan (MQ-05).
TA-05	500.000 transaksi dan window enam bulan muat dengan nyaman di PostgreSQL pada mesin target.	Kurangi menjadi 300.000 dan dokumentasikan.
TA-06	Anggota tim memiliki atau dapat memperoleh keterampilan Python, SQL dan React yang memadai pada Minggu 3.	Picu fallback ADR-002 pada gate Minggu-4, bukan setelahnya.

02

2. Pemetaan Ruang Lingkup FRD-ke-Komponen dan Batas MVP

POIN UTAMA

- Setiap domain FRD dipetakan ke komponen bernama beserta group pelaksana dan keputusan inklusi MVP yang eksplisit, sehingga tidak ada yang setengah dimiliki.
- Batas MVP dinyatakan sebagai hal-hal yang secara struktural mustahil, bukan sebagai hal-hal yang dijanjikan tim untuk tidak dilakukan.
- Ketika sebuah kebutuhan dapat dilepas, dokumen ini menyatakannya di sini, bukan menemukannya di bawah tekanan waktu pada Minggu 14.

2.1 Pemetaan

Eksibit 1 — Setiap domain FRD dipetakan ke komponen bernama, group pelaksana dan keputusan inklusi

Domain FRD	Kebutuhan FRD	Komponen (§4)	Pemilik	Inklusi MVP
D1 Ingestion dan kualitas data	FR-101...FR-110	C-01 Ingestion, C-02 Validation & Quality, C-22 Configuration, C-19 Audit	A	Penuh
D2 Entity resolution	FR-111...FR-116	C-03 Entity Resolution	A	Penuh
D3 Risk scoring	FR-201...FR-207	C-04 Feature Builder, C-05 Risk Engine	A	Override FR-207 adalah c
D4 Monitoring dan rule	FR-301...FR-312	C-06 Rules Engine, C-10 Alert Scoring & Dedupe, C-11 Alert Service	A	Override FR-312 adalah c
D5 Sinyal anomaly dan graph	FR-401...FR-406	C-07 Anomaly Engine, C-08 Graph Builder & Signals	A	Anomaly FR-401 adalah s
D6 Screening	FR-501...FR-508	C-09 Screening Engine, C-11 Alert Service, C-13 Screening Review (UI)	A + B	Penuh
D7 Manajemen alert	FR-601...FR-612	C-11 Alert Service, C-12 Triage UI	B	FR-610/611 adalah s/c
D8 Entity 360, timeline, graph	FR-701...FR-709	C-14 Entity 360 Service, C-15 Timeline	B	FR-705 adalah c

Domain FRD	Kebutuhan FRD	Komponen (§4)	Pemilik	Inklusi MVP
		Service, C-16 Graph Investigation		
D9 Manajemen case	FR-801...FR-808	C-17 Case Service	B	FR-806 adalah c
D10 Evidence dan maker-checker	FR-811...FR-818	C-18 Evidence Service, C-19 Decision & Maker-Checker	B	Penuh
D11 Narrative AI	FR-901...FR-906	C-20 Narrative Service, C-21 Grounding Checker	B	Tergantung MQ-05
D12 Pelaporan regulatori	FR-911...FR-916	C-23 Report Service	B	FR-916 adalah c
D13 Monitoring rule/model	FR-1001...FR-1006	C-24 Metrics Engine	A	FR-1003/1004/1006 adalah s
D14 Dashboard	FR-1011...FR-1016	C-25 Dashboard Service	B	FR-1015/1016 adalah s
D15 Tata kelola, RBAC, audit	FR-1101...FR-1110	C-26 IAM, C-27 Audit Service, C-28 Notification, C-29 Observability, C-30 Secrets	Gabungan	FR-1110 adalah c

2.2 Batas Teknis MVP

Batas	Pernyataan
Tidak ada jalur tulis ke data sumber	Role deteksi hanya memiliki SELECT pada tabel transaction, account dan entity (ADR-005, FR-309). Tidak ada endpoint yang mengubah sebuah transaksi.
Tidak ada integrasi keluar	Policy jaringan container tidak mengizinkan egress dari layanan aplikasi kecuali endpoint AI opsional; tidak ada transport surel, tidak ada klien API eksternal, tidak ada klien transfer berkas (NG-02, §12.9).
Tidak ada keputusan otonom	Setiap state decision, disposition dan confirmed memiliki kolom aktor manusia NOT NULL dengan foreign key ke app_user; sebuah check constraint database menolak aktor sistem (NG-03).

Batas	Pernyataan
Batch, bukan stream	Ingestion digerakkan oleh berkas/batch; demo “near-real-time” adalah micro-batch terjadwal atas sebuah berkas replay, yang secara jelas dilabeli sebagai simulasi (NG-06).
Graph terbatas	Kedalaman ≤ 3 , node ≤ 300 , pemotongan deterministik (FR-404).
Hanya model yang dapat dijelaskan	Setiap score yang tersimpan memiliki tabel anak berisi kontribusi faktor/feature; sebuah score tanpa kontribusi melanggar constraint yang didukung foreign key (NG-07).
Hanya sintetis	Loader watchlist mensyaratkan <code>synthetic_declaration = TRUE</code> ; pipeline CI menjalankan pemindaian secret dan PII pada setiap commit (NFR-15, §16.3).
Tenant tunggal, pengguna internal	Tidak ada registrasi publik, tidak ada permukaan yang menghadap customer (NG-08).

03

3. Arsitektur (C4)

POIN UTAMA

- Fitur terpenting pada diagram konteks sistem adalah sebuah kotak yang tidak terhubung: tidak ada jalur dari platform ini menuju otoritas eksternal mana pun.
- Dua layanan API, satu database, satu audit writer. Group A memiliki data dan deteksi; Group B memiliki investigasi dan keputusan; batas di antara keduanya adalah kontrak HTTP internal, sehingga kepemilikan dapat diuji.
- Enam lapisan, masing-masing dengan satu aturan yang berlaku di seluruh lapisan itu — termasuk yang paling penting: lapisan deteksi boleh membuat alert, score, signal, dan audit event, dan tidak lebih.

3.1 Level 1 — Konteks Sistem

Aktor: Administrator, Data Operations, AML/Fraud Analyst, Triage Analyst, Investigator, Senior Investigator, MLRO, Auditor, Management (FRD §4).

Sistem eksternal (seluruhnya sintetis atau internal):

- *Synthetic Source Systems* — file drop yang merepresentasikan wallet core, platform merchant dan penyimpanan KYC yang fiktif. Bukan integrasi langsung; berkas dihasilkan oleh Synthetic Data Generator.
- *Synthetic Watchlist Source* — berkas daftar berversi yang disusun oleh tim.
- *AI Narrative Provider* (opsional) — endpoint LLM yang dijangkau melalui HTTPS; satu-satunya egress yang diizinkan, dan dapat dinonaktifkan.

Tidak ada sistem eksternal yang ditulis oleh FCIP. Ketiadaan ini merupakan wujud arsitektural dari NG-01 dan NG-02.

Eksibit 2 — Konteks sistem: kotak terpenting adalah kotak yang tidak terhubung

```
graph TB
    subgraph Users["Internal Users - PT Nusantara Digital Payment (fictional)"]
        U1["Data Operations"]
        U2["AML/Fraud Analyst"]
        U3["Triage Analyst"]
        U4["Investigator / Senior Investigator"]
        U5["MLRO / Compliance"]
        U6["Auditor"]
        U7["Management"]
        U8["Administrator"]
    end

    FCIP["<b>Financial Crime Intelligence Platform</b><br>Single integrated web application<br>Detect - Triage - Investigate - Decide - Draft report - Audit<br>SYNTHETIC DATA ONLY"]

    subgraph Sources["Synthetic Inputs (files, one-way)"]
        S1["Synthetic Source Systems<br>customers, merchants, accounts,<br>devices, transactions"]
        S2["Synthetic Watchlist<br>sanctions / PEP / internal, versioned"]
    end

    AI["AI Narrative Provider (optional)<br>LLM endpoint - only permitted egress<br>disableable, template fallback"]

    U1 --> FCIP
    U2 --> FCIP
    U3 --> FCIP
    U4 --> FCIP
    U5 --> FCIP
    U6 --> FCIP
    U7 --> FCIP
    U8 --> FCIP

    S1 -->|batch files, read-only| FCIP
    S2 -->|versioned list, read-only| FCIP
    FCIP -->|case package only,<br>grounded, logged| AI
```

AI -->|draft text| FCIP

FCIP -->|"NO transmission path:
no regulator, no bank,
no transaction action"| X["X External Authorities
NOT CONNECTED"]

style FCIP fill:#1f4e79,color:#ffffff
style X fill:#7d1f1f,color:#ffffff,stroke-dasharray: 5 5

3.2 Level 2 — Diagram Container

Eksibit 3 — Arsitektur container: dua batas layanan, satu database, satu penulis audit

```
graph TB
    Browser["Web Browser<br/>React 18 + TypeScript SPA"]

    GW["API Gateway / Reverse Proxy<br/>Nginx - TLS termination, routing,<br/>security headers, rate limiting"]

    subgraph GroupA ["Group A – Data & Detection Services (FastAPI)"]
        API_A["Detection API<br/>ingestion, quality, ER, risk,<br/>rules, anomaly, graph, screening,<br/>alerts (create/read), metrics"]
        WORKER["Worker Pool (RQ)<br/>ingestion jobs, detection runs,<br/>ER scoring, risk recompute,<br/>graph refresh, screening runs"]
        SCHED["Scheduler<br/>batch windows, nightly graph refresh,<br/>metric computation, SLA evaluation"]
    end

    subgraph GroupB ["Group B – Investigation Services (FastAPI)"]
        API_B["Investigation API<br/>alert lifecycle, Entity 360, timeline,<br/>graph investigation, cases, evidence,<br/>maker-checker, narrative, reports, dashboards"]
    end

    subgraph Shared ["Shared Cross-Cutting Services"]
        IAM["IAM Service<br/>authn, RBAC, session,<br/>maker-checker evaluation"]
        AUD["Audit Service<br/>append-only writer + search"]
    end

    DB["PostgreSQL 16<br/>schemas: raw, core, detect,<br/>invest, gov, meta"]
    OBJ["MinIO<br/>evidence objects,<br/>report exports"]
    Q["Redis 7<br/>job queue, cache,<br/>rate-limit counters"]
    AIP["AI Narrative Provider<br/>(optional, external)"]

    Browser --> GW
    GW --> API_A
    GW --> API_B
    GW --> IAM

    API_A --> DB
    API_B --> DB
    WORKER --> DB
    SCHED --> Q
    Q --> WORKER
    API_A --> Q
    API_B --> OBJ
    API_B --> |grounded case package| AIP

    API_A --> IAM
    API_B --> IAM
    API_A --> AUD
    API_B --> AUD
    IAM --> AUD
    AUD --> DB
    IAM --> DB

    API_B --> |internal HTTP,<br/>versioned contract §13| API_A

    style GroupA fill:#e8f0f8
    style GroupB fill:#f8f0e8
    style Shared fill:#f0f0f0
```

Tanggung jawab dan kepemilikan container

Container	Pemilik	Tanggung jawab	Data yang boleh ditulis
React SPA	B (shell), keduanya (layar fitur)	Seluruh interaksi pengguna; tidak ada logika bisnis; tidak ada keputusan otorisasi	—
Gateway Nginx	Gabungan	TLS, routing, security header, batas ukuran request, rate limiting dasar	—
Detection API	A	Kontrol ingestion, kualitas, ER, risk, rule, anomaly, graph, screening, pembuatan dan pembacaan alert, metrik	raw, core, detect, meta
Worker pool	A	Seluruh job yang berjalan lama	Sama dengan Detection API
Scheduler	A	Hanya trigger berbasis waktu; tidak memuat logika bisnis	Hanya melakukan enqueue
Investigation API	B	Lifecycle alert, permukaan investigasi, case, evidence, keputusan, narrative, laporan, dashboard	invest, ditambah kolom lifecycle alert di detect
Layanan IAM	Gabungan	Autentikasi, penerbitan token, resolusi role, evaluasi maker-checker per item	gov.app_user, gov.session
Layanan audit	Gabungan	Satu-satunya penulis ke gov.audit_event; pencarian dan ekspor	gov.audit_event (hanya INSERT)
PostgreSQL	Gabungan	Seluruh data terstruktur, termasuk proyeksi graph	—

Container	Pemilik	Tanggung jawab	Data yang boleh ditulis
MinIO	B	Objek evidence dan hasil ekspor laporan	—
Redis	A	Job queue, cache berumur pendek, penghitung rate-limit. Tidak ada state bisnis.	—

3.3 Level 3 — Diagram Komponen (Pipeline Deteksi)

Eksibit 4 — Pipeline deteksi: data menjadi alert yang dijelaskan, dan tidak lebih dari itu

```
graph LR
    F["Batch files<br/>(synthetic)"] --> C01["C-01<br/>Ingestion<br/>Controller"]
    C01 --> C02["C-02<br/>Validation &<br/>Quality"]
    C02 -->|pass| STG["core.transaction<br/>core.party<br/>core.account"]
    C02 -->|fail| QRT["raw.quarantine_item"]
    C02 --> LOG["meta.processing_log"]

    STG --> C03["C-03<br/>Entity<br/>Resolution"]
    C03 --> ENT["core.entity"]

    ENT --> C04["C-04<br/>Feature<br/>Builder"]
    STG --> C04
    C04 --> FEAT["detect.entity_feature"]

    FEAT --> C05["C-05<br/>Risk Engine"]
    FEAT --> C07["C-07<br/>Anomaly Engine"]
    STG --> C06["C-06<br/>Rules Engine<br/>(12 pattern templates)"]
    ENT --> C08["C-08<br/>Graph Builder<br/>& Signals"]
    ENT --> C09["C-09<br/>Screening Engine"]

    C05 --> RISK["detect.risk_assessment<br/>+ risk_factor"]
    C07 --> ANOM["detect.anomaly_score<br/>+ anomaly_feature"]
    C08 --> GRAPH["detect.graph_node<br/>detect.graph_edge<br/>detect.graph_signal"]
    C09 --> SCRIN["detect.screening_result"]

    C06 --> C10["C-10<br/>Alert Scoring<br/>& Dedupe"]
    RISK --> C10
    ANOM --> C10
    GRAPH --> C10
    C10 --> C11["C-11<br/>Alert Service"]
    C11 --> ALERT["detect.alert<br/>+ alert_factor<br/>+ alert_transaction"]

    ALERT --> C12["C-12<br/>Triage UI<br/>(Group B)"]
    SCRIN --> C13["C-13<br/>Screening Review<br/>(Group B)"]

    C11 --> AUD["C-27 Audit Service"]
    C10 --> AUD
    C09 --> AUD

    style C06 fill:#d5e8d4
    style C10 fill:#d5e8d4
    style C11 fill:#d5e8d4
    style AUD fill:#f8cecc
```

3.4 Level 3 — Diagram Komponen (Investigasi dan Keputusan)

Eksibit 5 — Investigasi dan keputusan: setiap langkah yang berkonsekuensi membawa nama manusia

```
graph TB
    ALERT["detect.alert"] --> C11["C-11 Alert Service<br/>lifecycle, assignment,<br/>disposition, SLA"]
    C11 --> C12["C-12 Triage UI"]

    C12 -->|escalate| C17["C-17 Case Service<br/>lifecycle, links, notes,<br/>completeness check"]
```

```

C14["C-14 Entity 360 Service"] --> C17
C15["C-15 Timeline Service"] --> C17
C16["C-16 Graph Investigation"] --> C17

C17 --> C18["C-18 Evidence Service<br/>capture, upload, hash,<br/>immutability, supersession"]
C18 --> OBJ[("MinIO<br/>content-addressed")]
C18 --> EVD[("invest.evidence")]

C17 --> C20["C-20 Narrative Service<br/>package assembly,<br/>provider call, storage"]
C20 --> C21["C-21 Grounding Checker<br/>extract & compare,<br/>flag unsupported"]
C21 --> NARR[("invest.narrative<br/>invest.narrative_flag<br/>gov.ai_usage_log")]

C17 --> C19["C-19 Decision &<br/>Maker-Checker Service"]
C19 --> IAM["C-26 IAM<br/>maker ≠ checker<br/>evaluated per item"]
C19 --> DEC[("invest.decision")]

DEC --> C23["C-23 Report Service<br/>draft, validate, version,<br/>MLRO approval, export"]
C23 --> RPT[("invest.regulatory_report")]
C23 --> OBJ

C11 --> C24["C-24 Metrics Engine<br/>(Group A)"]
C19 --> C24
C24 --> C25["C-25 Dashboard Service"]

C11 --> AUD["C-27 Audit Service"]
C17 --> AUD
C18 --> AUD
C19 --> AUD
C20 --> AUD
C23 --> AUD
AUD --> AE[("gov.audit_event<br/>append-only")]

style C19 fill:#ffe6cc
style IAM fill:#ffe6cc
style AUD fill:#f8cecc
style AE fill:#f8cecc

```

3.5 Model Lapisan

Lapisan	Isi	Aturan yang berlaku pada lapisan ini
Sumber	File drop sintetis, versi watchlist sintetis	Hanya-baca bagi platform; tidak ada yang pernah ditulis balik
Data / Pemrosesan	Ingestion, validasi, quarantine, idempotency, entity resolution, pembangunan feature, processing log	Setiap record dimuat, di-quarantine atau dihitung sebagai ditekan — tidak pernah dibuang
Deteksi / Intelijen	Rules engine, risk engine, anomaly engine, graph builder dan sinyal, screening engine, alert scoring dan dedupe	Boleh membuat alert, score, sinyal dan potential match screening — dan tidak lebih dari itu
Investigasi / Case	Lifecycle alert, Entity 360, timeline, graph investigation, case, evidence, narrative, keputusan, laporan	Setiap perubahan state yang berkonsekuensi membawa aktor manusia bernama
Pengalaman	React SPA, dashboard, ekspor	Menyajikan; tidak pernah mengotorisasi

Lapisan	Isi	Aturan yang berlaku pada lapisan ini
Lintas fungsi	IAM, audit, konfigurasi, notifikasi, observability, secrets	Audit ditulis dalam transaksi yang sama dengan perubahannya; tidak ada role yang boleh mengubah atau menghapus audit event

04

4. Katalog Komponen

POIN UTAMA

- Tiga puluh komponen, masing-masing dengan input, output, logika utama, dan — bagian yang biasanya tertinggal — perilaku kegagalan yang terdefinisi.
- Beberapa komponen sengaja gagal ke arah keterlihatan: bila dedupe key tidak dapat dihitung, alert tetap dibuat dan ditandai, tidak pernah dibuang diam-diam.
- Ketidadaan sinyal tidak pernah digambarkan sebagai keberhasilan. Komponen yang belum pernah berjalan ditampilkan sebagai 'belum pernah berjalan', bukan sebagai sehat.

Setiap komponen menyatakan: tujuan, pemilik, input, output, logika utama, perilaku saat gagal, dan kebutuhan FRD yang dipenuhinya.

C-01 Ingestion Controller — Pemilik: A — FR-101, FR-105, FR-107, FR-110

Input: permintaan registrasi batch (kode sumber, tanggal bisnis, referensi berkas), versi kontrak sumber.

Output: baris `meta.ingestion_batch`, job ingestion yang di-enqueue, entri `meta.processing_log`.

Logika utama: menerbitkan ID batch; menghitung checksum berkas; menolak ID batch duplikat dan checksum duplikat untuk sumber dan tanggal bisnis yang sama; menggerakkan state machine §5.1; memiliki pratinjau dampak pemrosesan ulang.

Perilaku saat gagal: kegagalan struktural menetapkan `FAILED` dengan nol baris dimuat. Worker yang crash melanjutkan dari checkpoint idempotency; processing log mencatat crash dan restart tersebut sehingga celahnya menjadi eksplisit.

C-02 Validation and Quality Engine — Pemilik: A — FR-102, FR-103, FR-104, FR-108, FR-109

Input: record yang di-stage, versi kontrak sumber, registri rule validasi.

Output: baris `core.*`, baris `raw.quarantine_item`, baris `meta.dq_metric`, penghitung penekanan.

Logika utama: tiga tahap — struktural, format per record, bisnis per record — masing-masing menghasilkan kode validasi terdaftar dan nama field yang gagal; penegakan threshold pembatalan; idempotency melalui `ON CONFLICT DO NOTHING` dengan perbandingan payload saat konflik (ADR-011); rekonsiliasi akhir batch (`loaded + quarantined + suppressed = input`).

Perilaku saat gagal: ketidakcocokan rekonsiliasi memunculkan `RECONCILIATION_MISMATCH` dan menandai batch untuk ditindaklanjuti alih-alih selesai secara diam-diam.

C-03 Entity Resolution Service — Pemilik: A — FR-111...FR-116

Input: record party (customer, business customer, beneficial owner), versi konfigurasi ER.

Output: `core.er_candidate` (dengan baris anak berisi score per field), `core.entity`, `core.entity_source_record`, record merge/unmerge.

Logika utama: blocking pada lima key; kemiripan berbobot (Jaro-Winkler pada nama dengan normaliser aksara Latin untuk partikel dan gelar kehormatan Indonesia, persis/fuzzy pada tanggal lahir, telepon dan surel yang dinormalisasi, token-set pada alamat, persis pada identifier yang di-hash); auto-merge mensyaratkan `score ≥ ER_AUTO_MIN` dan kesesuaian `≥ 1` identifier kuat; identifier kuat yang bertentangan memaksa review; merge yang melibatkan case terbuka diblokir sampai ada pengakuan dari Senior Investigator.

Perilaku saat gagal: pemotongan akibat batas blocking dicatat sebagai `ER_BLOCK_TRUNCATED` alih-alih membatasi recall secara diam-diam.

C-04 Feature Builder — Pemilik: A — mendukung FR-201, FR-202, FR-401, dan seluruh pattern deteksi

Input: transaksi, account, device, entity, edge graph.

Output: `detect.entity_feature` (entity, feature_code, window, value, computed_at, feature_set_version).

Logika utama: SQL berbasis himpunan yang menghasilkan agregat rolling dan kalender per entity (count, sum, persentil, distinct, profil jam/hari, rasio konsentrasi, rasio masuk/keluar) untuk window yang digunakan oleh risk, anomaly dan dua belas pattern. Dihitung sekali per run dan digunakan kembali, sehingga sebuah rule tidak pernah

menghitung ulang agregat bersama.

Perilaku saat gagal: feature yang tidak dapat dihitung ditulis dengan `data_availability_status = DATA_UNAVAILABLE`, tidak pernah sebagai nol.

C-05 Risk Engine — Pemilik: A — FR-201...FR-207

Input: feature, profil entity, state screening, riwayat alert, versi model risk.

Output: `detect.risk_assessment + detect.risk_factor` (hanya dapat ditambah).

Logika utama: evaluasi faktor berbobot (ADR-007); normalisasi ke 0–100; batas potong band; perhitungan coverage dengan `INSUFFICIENT_DATA` di bawah nilai minimum; debouncing trigger; penanganan override dengan masa berlaku wajib.

Perilaku saat gagal: himpunan faktor yang parsial menghasilkan assessment ber-score yang ditandai dengan coverage, atau `INSUFFICIENT_DATA` — tidak pernah berupa score rendah yang diam-diam.

C-06 Rules Engine — Pemilik: A — FR-301...FR-307

Input: rule version aktif, feature, transaksi, entity, sinyal graph.

Output: kecocokan rule (dalam memori), `meta.detection_run` dan penghitung per rule, `meta.simulation_result`.

Logika utama: setiap pattern adalah template SQL/CTE berversi (ADR-006) yang terikat pada satu himpunan parameter bertipe; sebuah rule version tidak dapat diubah setelah `ACTIVE`; simulasi menjalankan template identik terhadap periode historis dengan penulisan alert dinonaktifkan; evaluasi window bersifat sadar zona (ADR-010) dan mencatat batas serta ID transaksi yang tercakup.

Perilaku saat gagal: rule yang error atau melampaui batas runtime-nya ditandai gagal untuk run tersebut; rule lain berlanjut; run berakhir `COMPLETED_WITH_ERRORS`. Run yang dibatalkan akan di-rollback sepenuhnya — tidak ada himpunan alert parsial yang dipublikasikan.

C-07 Anomaly Engine — Pemilik: A — FR-401, FR-405, FR-406

Input: feature sepanjang periode baseline dan periode berjalan.

Output: `detect.anomaly_score + detect.anomaly_feature`.

Logika utama: baseline per entity (rata-rata, simpangan baku, p95) selama 90 hari; deviasi terstandarisasi per feature pada window berjalan; score komposit sebagai kombinasi berbobot yang terdokumentasi; `NO_BASELINE` di bawah aktivitas minimum; `LOW_CONFIDENCE_BASELINE` di atas batas varians. Jika kapasitas memungkinkan, varian Isolation Forest dapat ditambahkan **hanya** dengan pelaporan kontribusi per feature (ADR-007).

Perilaku saat gagal: tidak ada score lebih baik daripada score yang menyesatkan.

C-08 Graph Builder and Signal Engine — Pemilik: A — FR-402...FR-404

Input: entity, account, device, telepon, surel, alamat, transaksi.

Output: `detect.graph_node`, `detect.graph_edge`, `detect.graph_signal`, `meta.graph_version`.

Logika utama: pembangunan ulang penuh setiap refresh ke dalam versi graph baru, lalu pertukaran pointer atomik sehingga pembaca tidak pernah melihat graph yang setengah jadi; tujuh tipe edge dengan first/last seen, jumlah kemunculan, bobot dan `specificity_flag`; sinyal dihitung dengan parameter yang tercatat; ukuran connected component dilaporkan sebagai “lebih besar dari N” di luar batas.

Perilaku saat gagal: refresh yang gagal membiarkan versi graph sebelumnya tetap aktif dengan indikator keusangan yang terparap ke setiap konsumen.

C-09 Screening Engine — Pemilik: A — FR-501, FR-502, FR-505...FR-507

Input: record party, versi watchlist aktif, versi konfigurasi screening.

Output: `detect.screening_result` hanya dalam state `POTENTIAL_MATCH`, ditambah record `screened`, `zero potential matches`.

Logika utama: normalisasi (huruf besar-kecil, diakritik, tanda baca, gelar kehormatan seperti *Bapak/Ibu/Haji/Drs*, partikel, urutan token); score gabungan dari kemiripan tingkat token, komponen fonetik dan kesesuaian atribut sekunder; threshold dari konfigurasi aktif; penanda nama berfrekuensi tinggi dari persentil populasi; rescreen terpicu oleh perubahan daftar atau party.

Perilaku saat gagal: party tanpa nama yang dapat digunakan dicatat sebagai `NOT_SCREENABLE`, tidak pernah dilewati secara diam-diam — coverage harus terekonsiliasi secara persis (FR-507 AC1).

Jaminan struktural: penulis hanya menerima `POTENTIAL_MATCH` pada saat pembuatan; sebuah check constraint database ditambah fungsi transisi state mencegah state pembuatan lainnya (SM-06).

C-10 Alert Scoring and Deduplication — Pemilik: A — FR-310, FR-311, §5.6

Input: kecocokan rule, risk band entity, band nominal, jumlah alert terbuka, kode pattern yang bersamaan.

Output: keputusan dedupe, `priority_score`, `priority_band`, kontribusi input prioritas.

Logika utama: key dedupe = entity_id + rule_id + window_bucket + hash(sorted triggering transaction IDs); sebuah alert terbuka dengan key yang sama menyerap kemunculan tersebut (menaikkan suppression_count, menambahkan referensi transaksi) dan tidak ada baris alert yang dibuat; near-duplicate ditautkan sebagai RELATED_PRIOR; formula prioritas berversi dan inputnya disimpan.

Perilaku saat gagal: jika key dedupe tidak dapat dihitung, alert tetap dibuat dan ditandai DEDUPE_UNAVAILABLE — gagal ke arah keterlihatan, tidak pernah ke arah kesenyapan.

C-11 Alert Service — Pemilik: A (create/read), B (lifecycle) — FR-308, FR-601...FR-612

Input: kecocokan ber-score (dari A), tindakan lifecycle (dari B).

Output: detect.alert, detect.alert_factor, detect.alert_transaction, kolom lifecycle dan disposition, audit event ALERT_*, domain event ALERT_*.

Logika utama: pembuatan menegakkan reason code, ≥ 1 faktor dan ≥ 1 referensi transaksi melalui constraint NOT NULL dan yang didukung foreign key; transisi lifecycle divalidasi di sisi server terhadap \$5.5; panjang minimum rationale dan kategori reason terdaftar ditegakkan; perhitungan SLA atas jam kerja dan kalender hari libur; bulk disposition divalidasi homogenitasnya dan dibatasi 50, dengan menulis satu audit event per alert.

Perilaku saat gagal: transisi yang tidak valid mengembalikan INVALID_TRANSITION yang menyebut state saat ini dan state yang diminta; kegagalan guard mengembalikan GUARD_NOT_MET yang menyebut guard spesifiknya.

C-12 Triage UI — Pemilik: B — FR-601, FR-602, FR-604...FR-606, FR-612

Logika utama: queue dengan paginasi di sisi server pada key pengurutan komposit yang stabil; detail alert yang merangkai payload penjelasan lengkap dalam satu request; formulir disposition yang menegakkan kategori dan rationale di sisi klien **dan** di sisi server; empty state yang menyebutkan filter aktif.

C-13 Screening Review UI — Pemilik: B — FR-503, FR-504, FR-508

Logika utama: perbandingan berdampingan antara party dan record daftar dengan penyorotan atribut yang sesuai dan yang berbeda; pemilihan atribut pembeda diwajibkan saat dismissal; jalur konfirmasi dibatasi untuk Senior Investigator/MLRO dengan lampiran evidence yang diwajibkan; hanya kosakata state yang disetujui, ditegakkan melalui enumerasi bersama yang dipakai UI, API dan ekspor.

C-14 Entity 360 Service — Pemilik: B, data dari A — FR-701, FR-706, FR-707, FR-709

Logika utama: satu endpoint agregasi yang mengembalikan setiap blok dengan empty state eksplisit; masking berbasis role diterapkan di sisi server; isi banner kualitas data dihitung dari meta.dq_metric yang dibatasi pada entity tersebut; audit event akses subjek pada setiap tampilan.

C-15 Timeline Service — Pemilik: B — FR-702

Logika utama: paginasi keyset atas (value_datetime_utc, transaction_id); agregat dihitung persis atas himpunan terfilter dalam query yang sama; penanda event digabung dari alert, perubahan risk band, perubahan state screening dan device yang pertama terlihat; definisi filter dikembalikan bersama payload sehingga penangkapan evidence dapat menyimpannya secara verbatim.

C-16 Graph Investigation Service — Pemilik: B, data dari A — FR-703, FR-704, FR-705

Logika utama: penelusuran CTE rekursif dengan depth $\leq$ cap dan LIMIT node_cap, diurutkan secara deterministik berdasarkan (edge_weight DESC, node_id ASC) sehingga pemotongan dapat direproduksi; permintaan kedalaman di atas batas ditolak dengan menyebut nilai batasnya alih-alih dikurangi secara diam-diam; keterangan lead yang berlaku merupakan bagian dari kontrak payload, bukan hanya bagian dari UI.

C-17 Case Service — Pemilik: B — FR-801...FR-808

Logika utama: pembuatan case mensyaratkan aktor manusia (check constraint database pada created_by); state machine ditegakkan di sisi server; catatan hanya dapat ditambah; pemeriksaan kelengkapan mengembalikan **seluruh** kondisi yang belum terpenuhi dalam satu respons; merge menyalin evidence secara referensi dan mempertahankan atribusi aslinya.

C-18 Evidence Service — Pemilik: B — FR-708, FR-811...FR-813

Logika utama: unggahan divalidasi berdasarkan tipe MIME yang masuk daftar izin **dan** tanda tangan konten (magic bytes), batas ukuran, serta deskripsi wajib; penyimpanan beralamat konten dengan key SHA-256; penangkapan menyimpan tipe tampilan, parameter, ID objek sumber, status banner kualitas data dan versi aplikasi; tidak ada endpoint update atau delete, dan policy MinIO serta grant database menolak keduanya.

C-19 Decision and Maker-Checker Service — Pemilik: B, IAM bersama — FR-814...FR-818, §10.3

Logika utama: pengajuan menjalankan pemeriksaan kelengkapan dan mengunci identitas maker; endpoint persetujuan membaca ulang maker yang tersimpan dan membandingkannya dengan principal yang terautentikasi — penolakan di sini adalah `SEGREGATION_OF_DUTIES_VIOLATION` dan menulis audit event tindakan yang ditolak; resolusi role checker spesifik per tipe keputusan (`DRAFT_REPORT_RECOMMENDED` → hanya MLRO); keputusan yang disetujui menjadi tidak dapat diubah melalui jalur update yang dijaga state dan sebuah trigger.

C-20 Narrative Service — Pemilik: B — FR-901, FR-902, FR-904...FR-906

Logika utama: perakitan paket secara deterministik dengan referensi sumber untuk setiap elemen; abstraksi provider dengan implementasi LLM dan template (ADR-008); menyimpan prompt, respons, identifier dan versi model, parameter serta latensi; menolak generasi ketika input yang diwajibkan tidak ada, dengan mengembalikan daftar celah terstruktur.

C-21 Grounding Checker — Pemilik: B — FR-903

Logika utama: mengekstraksi entity, nominal (dengan normalisasi mata uang dan besaran), tanggal, referensi account dan nama counterparty dari narrative; membandingkan masing-masing terhadap indeks yang dibangun dari paket input; item yang tidak cocok menjadi baris `narrative_flag`; endpoint persetujuan menolak selama masih ada flag yang belum diselesaikan.

C-22 Configuration Service — Pemilik: Gabungan — FR-110, FR-1106, FR-1107

Logika utama: konfigurasi bertipe dan berversi dengan tiga kelas — reference, operasional dan relevan terhadap risiko; perubahan yang relevan terhadap risiko dialihkan ke maker-checker dan tidak dapat diterapkan langsung oleh Administrator; setiap objek bisnis mencatat versi konfigurasi saat objek tersebut dibuat, sehingga objek historis tidak pernah ditafsirkan ulang.

C-23 Report Service — Pemilik: B — FR-911...FR-916

Logika utama: pra-pengisian secara ketat berdasarkan referensi ke data case; versi himpunan field menggerakkan validator kelengkapan; satu versi per siklus submit/return; persetujuan hanya oleh MLRO; rendering PDF/DOCX dengan watermark yang diterapkan pada saat render dari sebuah konstanta, bukan dari konfigurasi (BR-914.2).

C-24 Metrics Engine — Pemilik: A — FR-1001...FR-1006

Logika utama: materialisasi terjadwal atas snapshot metrik per rule version dengan pembilang dan penyebut yang eksplisit; coverage hasil dihitung dan ditampilkan; “volume tidak mencukupi” di bawah penyebut 20; perbandingan versi diberi label ketika periodenya berbeda; tidak ada pemeringkatan, tidak ada rekomendasi, tidak ada penyetulan otomatis.

C-25 Dashboard Service — Pemilik: B — FR-1011...FR-1016

Logika utama: setiap widget mengembalikan nilai, pembilang, penyebut, periode dan deep link ke daftar terfilter yang mereproduksinya; peringatan data sintetis merupakan bagian dari payload sehingga tidak dapat hilang dalam ekspor.

C-26 IAM Service — Pemilik: Gabungan — FR-1101...FR-1103, §10

Logika utama: OAuth2 password flow, hashing argon2id, JWT access token berumur pendek dengan refresh token, timeout sesi idle dan absolut, penguncian setelah lima kegagalan; resolusi role per request; sebuah fungsi terpusat `authorize(principal, action, object)` dan fungsi terpisah `assert_maker_is_not_checker(item, principal)` yang digunakan oleh setiap endpoint persetujuan; deny-by-default untuk setiap endpoint tanpa rule eksplisit.

C-27 Audit Service — Pemilik: Gabungan — FR-1104, FR-1105

Logika utama: satu-satunya penulis ke `gov.audit_event`; dipanggil di dalam transaksi bisnis sehingga penulisan audit yang gagal me-rollback perubahannya; correlation ID dipropagasikan dari gateway melalui setiap panggilan dan job; pencarian berdasarkan aktor, aksi, objek, correlation ID dan rentang tanggal; ekspor dengan filter yang tercatat.

C-28 Notification Service — Pemilik: B — FR-610

Logika utama: hanya notifikasi di dalam aplikasi; tidak ada transport surel dalam deployment ini (NG-02); kegagalan pengiriman tidak pernah me-rollback tindakan bisnis; payload tidak memuat identifier yang tidak disamakan.

C-29 Observability — Pemilik: Gabungan — §14

Logika utama: log JSON terstruktur dengan correlation ID pada setiap baris; metrik job dan run; endpoint health

dan readiness; sebuah layar operasi yang menampilkan run sukses terakhir per komponen, dengan “belum pernah dijalankan” dibedakan dari “sehat”.

C-30 Secrets Management — *Pemilik: Gabungan* — §12.7

Logika utama: secrets berasal dari environment variable yang bersumber dari berkas yang dikecualikan dari version control (`.env`, `chmod 600`) dengan `.env.example` yang di-commit; tidak ada secret di dalam kode, log, pesan error atau database; CI menjalankan pemindai secret pada setiap commit.

05

5. Topologi Deployment MVP

POIN UTAMA

- Satu host, tiga jaringan internal, dan tepat satu port yang dipublikasikan. Jaringan data sama sekali tidak memiliki egress.
- Satu-satunya koneksi keluar yang diizinkan di seluruh deployment adalah penyedia AI opsional, dari satu layanan saja, dan dapat dimatikan.
- Setiap alternatif yang dipertimbangkan — Kubernetes, broker, graph database, layanan cloud terkelola — dicatat beserta alasan penolakannya untuk MVP ini.

5.1 Topologi

Eksibit 6 — Deployment: satu host, satu port yang dipublikasikan, dan tanpa egress kecuali AI provider opsional

graph TB

```
subgraph Host["Single Host – university server or laptop (Docker Compose)"]
  NG["nginx<br/>:443 / :80<br/>TLS, routing, headers,<br/>body size limit, rate limit"]
```

```
subgraph AppNet["Internal network: fcip-app (no egress except AI)"]
  WEB["web<br/>React build served as static assets"]
  APIA["api-detection<br/>FastAPI (uvicorn, 2 workers)"]
  APIB["api-investigation<br/>FastAPI (uvicorn, 2 workers)"]
  IAM["api-iam<br/>FastAPI"]
  WRK["worker<br/>RQ, 2 processes"]
  SCH["scheduler<br/>RQ-scheduler"]
end
```

```
subgraph DataNet["Internal network: fcip-data (no egress at all)"]
  PG["postgres:16<br/>volume: pgdata"]
  RD["redis:7<br/>volume: redisdata"]
  MO["minio<br/>volume: miniodata"]
end
```

```
BK["backup job<br/>nightly pg_dump + mc mirror"]
end
```

```
EXT["AI Narrative Provider<br/>(optional, HTTPS, egress-allowlisted)"]
```

```
NG --> WEB
NG --> APIA
NG --> APIB
NG --> IAM
APIA --> PG
APIB --> PG
IAM --> PG
WRK --> PG
APIA --> RD
WRK --> RD
SCH --> RD
APIB --> MO
APIB -. -> |only permitted egress| EXT
BK --> PG
BK --> MO
```

```
style DataNet fill:#eeeeee
style EXT fill:#fff2cc
```

5.2 Layanan, Sizing dan Justifikasi

Layanan	Image / build	Replika	Sumber daya (demo)	Justifikasi
nginx	nginx:alpine	1	128 MB	Satu titik terminasi TLS

Layanan	Image / build	Replika	Sumber daya (demo)	Justifikasi
				dan routing; satu-satunya container dengan port yang dipublikasikan; menerapkan batas ukuran body dan security header secara terpusat
web	Build Node multi-stage → static asset yang disajikan oleh nginx	—	—	Tidak adanya runtime Node di produksi mengurangi permukaan serangan
api-detection	Python 3.11 slim	1 (2 uvicorn worker)	1 GB	Batas kepemilikan Group A; dapat dipisahkan dan diuji secara independen
api-investigation	Python 3.11 slim	1 (2 uvicorn worker)	1 GB	Batas kepemilikan Group B; menjadikan kontrak §13 nyata
api-iam	Python 3.11 slim	1	512 MB	Otorisasi terpusat dan evaluasi maker-checker; dipisahkan agar tidak dapat dilewati oleh layanan fitur
worker	Python 3.11 slim	2 proses	2 GB	Ingestion dan deteksi membutuhkan banyak memori; dua proses memberikan paralelisme tanpa berebut database
scheduler	Python 3.11 slim	1	256 MB	Hanya pemicu waktu; sengaja

Layanan	Image / build	Replika	Sumber daya (demo)	Justifikasi
				tidak memuat logika bisnis sehingga dapat direstart dengan bebas
postgres	postgres:16-alpine	1	2 GB, shared_buffers=512MB, work_mem=32MB	Sumber kebenaran tunggal termasuk proyeksi graph (ADR-003)
redis	redis:7-alpine	1	256 MB	Hanya queue dan cache; tidak menyimpan state bisnis, sehingga flush tidak menghilangkan apa pun
minio	minio/minio	1	512 MB	Objek evidence dan ekspor, content-addressed, penghapusan ditolak (ADR-012)
backup	postgres:16-alpine + mc	cron	128 MB	Dump dan mirror objek setiap malam; restore diuji sebelum Week 15 (NFR-09)

Total footprint demo: $\approx$ 8 GB RAM, 4 core, 100 GB disk (TA-01).

5.3 Penyimpanan Data dan Apa yang Tersimpan di Mana

Penyimpanan	Isi	Backup	Alasan ditempatkan di sini
PostgreSQL — schema raw	Payload yang didaratkan, item quarantine	Dump setiap malam	Menyimpan payload asli untuk koreksi dan pembuktian (FR-104)
PostgreSQL — schema core	Party, entity, account, merchant, device, kontak, transaksi, counterparty	Dump setiap malam	Kebenaran observasional; read-only bagi detection (ADR-005)

Penyimpanan	Isi	Backup	Alasan ditempatkan di sini
PostgreSQL — schema detect	Feature, risk assessment, anomaly score, graph node/edge/signal, hasil screening, alert	Dump setiap malam	Ditempatkan bersama core sehingga query window tetap berbasis himpunan dan cepat
PostgreSQL — schema invest	Case, metadata evidence, keputusan, narrative, laporan	Dump setiap malam	Batas transaksi yang sama dengan audit (ADR-004)
PostgreSQL — schema gov	User, role, sesi, audit event, log penggunaan AI, versi konfigurasi	Dump setiap malam	Audit harus berbagi transaksi bisnis
PostgreSQL — schema meta	Batch, processing log, detection run, simulasi, metric snapshot, versi graph	Dump setiap malam	Riwayat operasional
MinIO bucket evidence	Objek evidence yang diunggah dan ditangkap	Mirror setiap malam	Konten biner berada di luar database; penghapusan ditolak
MinIO bucket exports	Ekspor laporan dan case yang telah dirender	Mirror setiap malam	Dapat dibuat ulang, tetapi disimpan untuk audit atas apa yang diekspor
Redis	Job queue, cache, penghitung rate-limit	Tidak di-backup	Secara desain tidak menyimpan state bisnis

5.4 Lingkungan

Lingkungan	Tujuan	Data	Catatan
Developer lokal	Pembangunan harian	Profil “small” generator ($\approx$ 5% volume, seed tetap)	docker compose up; migration dan seed berjalan saat start
CI	Pengujian otomatis	Set fixture + profil “tiny” generator	Container bersifat ephemeral; database dibuat dan dihapus per run
Integrasi / staging	Pengujian kontrak lintas tim mulai Week 8	Profil “full” generator	Digunakan bersama; direset sesuai permintaan dari seed

Lingkungan	Tujuan	Data	Catatan
Demonstrasi	UAT dan demo akhir	Profil “full” generator, seed dibekukan	Dibekukan pada gate Week-14; hanya perbaikan defect yang di-deploy setelahnya

5.5 Artefak Rule dan Model

Artefak	Penyimpanan	Versioning	Alasan
Template SQL pattern	Repository sumber, <code>detection/templates/<pattern>_v<N>.sql</code>	Git tag + kolom <code>template_version</code>	Sebuah rule version mereferensikan sebuah versi template; pasangan inilah yang membuat alert dapat direproduksi (SM-01)
Parameter rule	<code>detect.rule_version</code> (JSONB bertipe dengan schema per pattern)	Tidak dapat diubah pada tingkat baris setelah <code>ACTIVE</code>	Analyst mengubah parameter tanpa deployment; perubahan logika membutuhkan developer (ADR-006)
Definisi model risk	<code>detect.risk_model_version</code> (faktor, bobot, cut-off)	Tidak dapat diubah setelah disetujui	Keterangan dan dapat direproduksi
Definisi baseline anomaly	<code>detect.anomaly_model_version</code>	Tidak dapat diubah setelah disetujui	Sama seperti di atas
Konfigurasi screening	<code>detect.screening_config_version</code> (threshold, parameter algoritma)	Tidak dapat diubah setelah digunakan	Hasil historis mempertahankan konteksnya
Artefak hasil pelatihan (jika ada)	MinIO bucket <code>models</code> , direferensikan melalui hash dari baris versi model	Content-addressed	Hanya diizinkan apabila kontribusi per-feature dapat dilaporkan (ADR-007)

5.6 Mengapa Bukan Alternatif Lain

Alternatif yang dipertimbangkan	Alasan ditolak untuk MVP ini
Kubernetes	Berat secara operasional untuk satu host dan satu tim; tidak ada kebutuhan yang memerlukan elastic scaling
Microservice per domain (10+ layanan)	Transaksi terdistribusi akan membuat ADR-004 (audit dalam transaksi yang sama) menjadi mustahil atau sangat mahal

Alternatif yang dipertimbangkan	Alasan ditolak untuk MVP ini
Kafka atau broker lain	Redis + RQ sudah mencakup kebutuhan queueing MVP; broker menambah satu komponen yang harus diamankan, dipantau dan di-backup tanpa keuntungan fungsional pada volume ini
Neo4j berdampingan dengan PostgreSQL	Dua sumber kebenaran, dua backup, dua set kredensial, untuk penelusuran terbatas yang sudah ditangani PostgreSQL (ADR-003)
Layanan cloud terkelola	CN-05 (gratis/open-source) dan kebutuhan untuk mendemonstrasikan secara offline pada mesin universitas
Database audit terpisah	Akan merusak jaminan transaksi-yang-sama pada FRD §5.14 (CF-02)

06

6. Arsitektur Data

POIN UTAMA

- Setiap record dimuat, di-quarantine, atau dihitung sebagai duplikat yang ditekan. Tidak ada yang dibuang diam-diam, dan batch harus rekonsiliasi atau ia ditandai.
- Idempotency adalah constraint database, bukan disiplin aplikasi, sehingga reproduksibilitas tetap bertahan meski ada bug.
- Enam schema dengan hak akses tingkat tabel dan tingkat kolom. Kontrak lintas tim ditegakkan oleh database, bukan oleh kebiasaan.

6.1 Schema Sumber dan Kontrak File

Seluruh sumber merupakan file drop sintetis yang dihasilkan oleh generator (§11). File berformat CSV (UTF-8, dipisahkan koma, diberi tanda kutip, baris header, akhir baris `\n`) dengan manifest pendamping.

Manifest (<batch>.manifest.json)

Field	Tipe	Aturan
source_system_code	string	Harus cocok dengan sumber yang terdaftar
business_date	date YYYY-MM-DD	Business date Asia/Jakarta
contract_version	string	Harus cocok dengan versi kontrak yang aktif
files	array berisi {name, sha256, record_count}	Checksum diverifikasi sebelum parsing
generated_at	timestamp	Bersifat informatif
synthetic_declaration	boolean	Harus true — jika tidak, ingestion menolak

Kontrak file (kolom, tipe, flag wajib, validasi)

customers.csv — source_customer_id*, full_name*, aliases, date_of_birth*, place_of_birth, gender, nationality*, national_id_reference*, occupation, income_band, address_line, city, province, postcode, country*, phone, email, onboarding_date*, kyc_status*, customer_status*.

Validasi: date_of_birth ≤ hari ini – 17 tahun; nationality dan country mengikuti ISO-3166-1 alpha-2; kyc_status ∈ {COMPLETE, PARTIAL, PENDING}; phone dapat dinormalisasi ke E.164; national_id_reference cocok dengan pola sintetis dan di-hash saat load.

business_customers.csv — source_business_id*, legal_name*, trading_names, registration_number*, registration_country*, incorporation_date*, industry_code*, declared_turnover_band, address_line, city, province, postcode, country*, contact_phone, contact_email, status*.

beneficial_owners.csv — source_bo_id*, source_business_id*, full_name*, date_of_birth, nationality, ownership_percentage*, control_type*, declared_date.

Validasi: source_business_id harus dapat diresolusi di dalam batch atau sudah ada sebelumnya; ownership_percentage ∈ (0,100].

accounts.csv — source_account_id*, owner_source_id*, owner_type*, account_type*, currency*, opened_date*, closed_date, status*, balance_snapshot, balance_snapshot_at.

Validasi: currency ada dalam daftar referensi; $closed_date \geq opened_date$; $status \in \{ACTIVE, DORMANT, CLOSED, RESTRICTED\}$ dan tidak pernah ditulis oleh platform.

merchants.csv — source_merchant_id*, source_business_id*, merchant_name*, mcc*, declared_expected_volume_band, declared_expected_ticket_band, onboarded_date*, status*, settlement_source_account_id, operating_hours_declared, outlet_count.

devices.csv — source_device_id*, device_type*, os_family, app_version, is_emulator, is_rooted, first_seen*, last_seen.

transactions.csv — source_transaction_reference*, source_account_id*, direction*, amount_original*, currency_original*, value_datetime*, business_date*, channel*, transaction_type*, counterparty_reference, counterparty_name, counterparty_country, source_merchant_id, source_device_id, ip_address, status_from_source*.

Validasi: amount_original > 0 dan berada dalam pita kewajaran; value_datetime dapat di-parse dengan offset eksplisit; business_date berada dalam $\pm$ toleransi terkonfigurasi terhadap value_datetime pada zona Asia/Jakarta; direction $\in \{IN, OUT\}$; konversi FX ke IDR menggunakan tabel kurs sintetis untuk business_date dan baik kurs maupun referensinya disimpan.

watchlist.csv — list_record_id*, list_type*, primary_name*, aliases, date_of_birth, nationality, country, position_or_role, note, ditambah field manifest synthetic_declaration = true (FR-501).

6.2 Pipeline Ingestion

Eksibit 7 — Ingestion: setiap record di-load, di-quarantine atau dihitung, dan batch direkonsiliasi

```
graph LR
    A["Manifest check<br/>source registered, contract version,<br/>checksums, synthetic_declaration"] --> B["Structural validation<br/>readable, columns, header"]
    B -->|fail| F1["batch = FAILED<br/>0 rows loaded"]
    B --> C["Land to raw.*<br/>full payload + row number"]
    C --> D["Format validation<br/>types, enums, patterns"]
    D --> E["Business validation<br/>referential, plausibility, FX"]
    E -->|fail| Q["raw.quarantine_item<br/>code + failing field + payload"]
    E --> G["Idempotency<br/>INSERT ... ON CONFLICT DO NOTHING"]
    G -->|conflict, same payload| S["suppressed_count++"]
    G -->|conflict, different payload| Q
    G --> H["core.* upsert"]
    H --> I["Reconciliation<br/>loaded + quarantined + suppressed = input"]
    I -->|mismatch| M["RECONCILIATION_MISMATCH"]
    I --> J["batch = LOADED / PARTIALLY_LOADED"]
    J --> K["Queue: ER → features → detection → screening"]
```

Jaminan per tahap

Tahap	Jaminan
Landing	Payload asli secara utuh disimpan di <i>raw</i> terlepas dari hasil tahap berikutnya
Quarantine	Setiap kegagalan membawa kode terdaftar, nama field yang gagal dan payload-nya
Idempotency	Ditegakkan oleh unique constraint, bukan oleh logika aplikasi (ADR-011)
Threshold pembatalan	Rasio quarantine $\geq 20\%$ membatalkan batch secara atomik
Rekonsiliasi	input = loaded + quarantined + suppressed dipastikan saat batch ditutup
Urutan	Party → account → merchant → device → transaksi, dengan referensi maju intra-batch ditahan dan divalidasi ulang pada akhir batch

6.3 Quarantine dan Jalur Error

Aspek	Desain
Penyimpanan	<code>raw.quarantine_item(quarantine_id, batch_id, entity_kind, row_number, raw_payload JSONB, validation_code, failing_field, attempt_count, state, resolution, corrected_payload JSONB, rationale, resolved_by, resolved_at)</code>
Resolusi	<code>CORRECT_AND_RELOAD</code> membuat salinan terkoreksi yang tertaut ke aslinya dan masuk kembali ke validasi di dalam batch reprocessing; <code>REJECT</code> menutup item dengan alasan yang wajib diisi
Batas percobaan	Setelah 3 koreksi yang gagal, item dikunci hanya untuk <code>REJECT</code>
Jaminan	Record yang ditolak tidak akan pernah muncul di <code>core.*</code> , ditegaskan dengan hanya memuat dari jalur salinan terkoreksi

6.4 Processing Log

`meta.processing_log(log_id, batch_id, stage, started_at, ended_at, duration_ms, input_count, output_count, quarantined_count, suppressed_count, state, message)` — hanya dapat ditambah, satu baris per tahap per batch, dapat diekspor sebagai CSV, direkonsiliasi saat batch ditutup.

6.5 Idempotency, Deduplication dan Kedatangan Terlambat

Perhatian	Mekanisme
Idempotency transaksi	<code>UNIQUE (source_system_code, source_transaction_reference, business_date) → idempotency_key</code> ; payload yang berkonflik dengan key yang sama diarahkan ke quarantine sebagai <code>IDEMPOTENCY_CONFLICT</code>
Idempotency batch	<code>UNIQUE (source_system_code, business_date, file_sha256)</code> pada tabel file batch
Deduplication alert	Dedupe key pada tingkat aplikasi (C-10) ditambah <code>UNIQUE (dedupe_key) WHERE state IN ('NEW', 'ASSIGNED', 'IN_REVIEW')</code> sebagai partial index, sehingga jaminan tersebut bertahan terhadap race
Kedatangan terlambat	<code>late_arrival_flag</code> dan <code>lag_days</code> dihitung saat load terhadap <code>MAX(business_date)</code> per entity; job evaluasi ulang tertarget hanya di-enqueue untuk pasangan (<code>entity_id</code> , <code>rule_id</code>) yang terdampak
Batas keterlambatan	<code>lag_days > 90 → LATE_BEYOND_WINDOW</code> , di-load dan ditandai, tanpa evaluasi ulang
Penandaan evaluasi ulang	Alert dari run tersebut membawa <code>late_data_reevaluation = true</code> beserta nilai <code>lag-nya</code>

6.6 Reprocessing

Langkah	Perilaku
Permintaan	Data Ops menyediakan sumber, business date dan alasan yang wajib diisi
Pratinjau dampak	Sebuah query mengembalikan ID transaksi, alert dan case yang terdampak secara persis; disimpan sebagai snapshot bersama permintaan
Eksekusi	ID batch baru; load yang idempoten; detection dijalankan ulang terbatas pada entity yang terdampak
Perlindungan	Batch, alert dan case sebelumnya tidak tersentuh; case yang terdampak ditandai SOURCE_DATA_REPROCESSED
Dapat direproduksi	Menjalankan ulang dengan input dan rule version yang sama menghasilkan set alert yang sama (SM-01)

6.7 Pemisahan Schema dan Role Database

Schema	Pemilik	fcip_app_a (detection)	fcip_app_b (investigation)	fcip_audit
raw	A	SELECT, INSERT, UPDATE	—	—
core	A	SELECT, INSERT, UPDATE	SELECT	—
detect	A	SELECT, INSERT, UPDATE	SELECT + UPDATE hanya pada kolom lifecycle alert (grant tingkat kolom)	—
invest	B	SELECT (hanya metrik)	SELECT, INSERT, UPDATE	—
gov	Bersama	SELECT pada config/users	SELECT pada config/users	INSERT, SELECT pada audit_event
meta	A	SELECT, INSERT, UPDATE	SELECT	—

Properti yang ditegakkan:

- Role detection **tidak memiliki** UPDATE maupun DELETE pada core.transaction, core.account atau core.entity (ADR-005, FR-309).
- **Tidak ada role yang memiliki DELETE pada** gov.audit_event, invest.evidence, detect.alert, detect.rule_version,

invest.decision, invest.case_note.

- gov.audit_event juga memiliki trigger BEFORE UPDATE OR DELETE yang memunculkan AUDIT_IMMUTABLE (ADR-004).
- Akses tulis Group B ke detect.alert dibatasi pada kolom lifecycle dan outcome yang tercantum dalam FRD §13.3 melalui grant tingkat kolom — kontrak ditegakkan oleh database, bukan hanya oleh konvensi.

6.8 Retensi dan Pengarsipan

Data	Kebijakan MVP	Sikap produksi terdokumentasi (pekerjaan mendatang)
Audit event	Tidak pernah dihapus selama proyek berlangsung	Disimpan ≥ 5 tahun, lalu diarsipkan ke cold storage dengan verifikasi integritas
Objek evidence	Tidak pernah dihapus	Disimpan sesuai penutupan case + periode retensi; penghapusan hanya melalui purge yang terkendali dan teraudit dengan persetujuan ganda
Transaksi	Tidak pernah dihapus	Dipartisi berdasarkan bulan bisnis; diarsipkan di luar window deteksi
Alert dan case	Tidak pernah dihapus	Disimpan bersama record case
Log penggunaan AI	Tidak pernah dihapus	Disimpan bersama record case
Payload quarantine	Tidak pernah dihapus	Disimpan selama window koreksi, lalu dihapus disertai catatan atas apa yang dihapus
Backup	Setiap malam, 7 harian + 4 mingguan disimpan	Offsite, terenkripsi, restore diuji setiap kuartal

07

7. Model Data dan ERD

POIN UTAMA

- Tidak ada soft delete di mana pun. Record digantikan, ditutup, atau dibalik — tidak pernah ditandai sebagai terhapus.
- Empat guardrail hidup di dalam schema sebagai constraint dan trigger: audit tidak dapat diubah, checker $\neq$ maker, tidak ada alert tanpa faktor, dan tidak ada confirmed match tanpa manusia kedua.
- Properti terpenting dari model ini adalah bahwa satu correlation ID mengambil keseluruhan rantai dari batch ingestion sampai draft report yang disetujui.

7.1 Konvensi

Konvensi	Aturan
Primary key	ID bisnis berprefiks (ALR-...) sebagai identifier eksternal; surrogate bigint untuk join apabila volumenya menuntut
Timestamp	timestampz, disimpan dalam UTC; window bisnis dievaluasi dalam Asia/Jakarta (ADR-010)
Uang	numeric(20,2) untuk amount_idr; jumlah dan mata uang asli tetap disimpan bersamanya
Field audit yang tidak dapat diubah	Setiap tabel memuat created_at, created_by; tabel yang dapat diubah juga memuat updated_at, updated_by, row_version (untuk optimistic locking)
Soft delete	Tidak digunakan di mana pun. Record digantikan, ditutup atau dibalik — tidak pernah ditandai terhapus
Enumerasi	ENUM PostgreSQL atau tabel referensi dengan foreign key; tidak pernah berupa teks bebas
JSONB	Hanya untuk kumpulan parameter bertipe (parameter rule, parameter penangkapan evidence, paket AI) dengan schema validasi di kode aplikasi

7.2 ERD Inti

Eksibit 8 — Model data inti: entity yang menjadi sandaran kontrak dan guardrail

```

erDiagram
    PARTY_SOURCE_RECORD }o--|| ENTITY : "resolves to"
    ENTITY ||--o{ ACCOUNT : owns
    ENTITY ||--o{ BENEFICIAL_OWNER : "declared for"
    ENTITY ||--o{ MERCHANT : operates
    ACCOUNT ||--o{ TRANSACTION : "records"
    TRANSACTION }o--o| COUNTERPARTY : "with"
    TRANSACTION }o--o| DEVICE : "via"
    TRANSACTION }o--o| MERCHANT : "at"
    ENTITY ||--o{ RISK_ASSESSMENT : "scored by"
    RISK_ASSESSMENT ||--|| RISK_FACTOR : "explained by"
    ENTITY ||--o{ ANOMALY_SCORE : "profiled by"
  
```

```

ANOMALY_SCORE ||--|{ ANOMALY_FEATURE : "explained by"
ENTITY ||--o{ SCREENING_RESULT : "screened in"
WATCHLIST_RECORD ||--o{ SCREENING_RESULT : "matched against"
RULE ||--|{ RULE_VERSION : "versioned as"
RULE_VERSION ||--o{ ALERT : produces
ALERT ||--|{ ALERT_FACTOR : "explained by"
ALERT ||--|{ ALERT_TRANSACTION : cites
TRANSACTION ||--o{ ALERT_TRANSACTION : "cited in"
ENTITY ||--o{ ALERT : "subject of"
ALERT }o--o{ CASE : "linked to"
CASE ||--|{ CASE_SUBJECT : concerns
ENTITY ||--o{ CASE_SUBJECT : "subject in"
CASE ||--o{ CASE_NOTE : "annotated by"
CASE ||--|{ EVIDENCE : "supported by"
CASE ||--o{ NARRATIVE : "drafted for"
NARRATIVE ||--o{ NARRATIVE_FLAG : "checked by"
CASE ||--o{ DECISION : "closed by"
DECISION ||--o{ DECISION_EVIDENCE : references
EVIDENCE ||--o{ DECISION_EVIDENCE : "referenced by"
CASE ||--o{ REGULATORY_REPORT : "reported in draft"
APP_USER ||--o{ AUDIT_EVENT : performs
APP_USER ||--o{ DECISION : "makes / checks"
ENTITY ||--o{ GRAPH_NODE : "projected as"
GRAPH_NODE ||--o{ GRAPH_EDGE : "from"
GRAPH_NODE ||--o{ GRAPH_SIGNAL : "measured by"
INGESTION_BATCH ||--o{ TRANSACTION : loads
INGESTION_BATCH ||--o{ QUARANTINE_ITEM : rejects
DETECTION_RUN ||--o{ ALERT : "produced in"

```

7.3 Definisi Tabel Utama (diringkas sebatas yang menjadi sandaran kontrak)

core.entity — PK entity_id; entity_type (INDIVIDUAL,BUSINESS); display_name; primary_source_record_id; resolution_confidence numeric(4,3); resolution_mode (SINGLE_SOURCE,AUTO,MANUAL); resolved_by, resolved_at; source_record_count; created_at, created_by.

Index: (display_name_normalised), (entity_type, created_at).

Lifecycle: tidak pernah dihapus; unmerge membuat entity baru dan mencatat lineage di core.entity_lineage.

core.transaction — PK transaction_id; idempotency_key UNIQUE; FK account_id, entity_id, counterparty_id, merchant_id, device_id; direction; amount_original, currency_original, amount_idr, fx_rate_reference; value_datetime_utc, business_date; channel, transaction_type; counterparty_country; ip_address; status_from_source; batch_id; late_arrival_flag, lag_days; created_at.

Index: (entity_id, value_datetime_utc DESC) — tulang punggung untuk window dan timeline; (account_id, value_datetime_utc DESC); (business_date); (counterparty_id); (device_id) parsial jika tidak null; BRIN pada value_datetime_utc untuk range scan.

Lifecycle: **hanya insert**. Tidak ada grant UPDATE atau DELETE untuk role aplikasi mana pun.

detect.rule_version — PK (rule_id, version); pattern_code; template_version; parameters JSONB; window_type, window_length; entity_scope; severity; reason_code; description; state; created_by, submitted_by, approved_by, approved_at, retired_at; simulation_id.

Constraint: sebuah trigger memblokir UPDATE ketika state = 'ACTIVE' kecuali untuk satu-satunya transisi ke SUSPENDED/RETIRED (hanya kolom state).

detect.alert — PK alert_id; FK rule_id, rule_version, subject_entity_id, detection_run_id, case_id (nullable); pattern_code, reason_code, severity; window_start, window_end, window_type, partial_window_flag; priority_score, priority_band, priority_formula_version, priority_inputs JSONB; priority_override_band, priority_override_rationale, overridden_by; dedupe_key, suppression_count; data_quality_flag, late_data_reevaluation, concurrent_patterns[]; state, assignee_id, sla_target_at, first_review_at; disposition, disposition_reason_category, disposition_rationale, disposed_by, disposed_at; created_at; row_version. Constraint: CHECK (disposition IS NULL OR (disposition_reason_category IS NOT NULL AND length(disposition_rationale) >= 20 AND disposed_by IS NOT NULL)) — SM-07 ditegakkan di dalam database; partial unique index pada dedupe_key untuk state yang masih terbuka.

Index: (state, priority_band, created_at); (assignee_id, state); (subject_entity_id, created_at DESC); (rule_id, rule_version, created_at).

detect.alert_factor — PK alert_factor_id; FK alert_id; factor_code, observed_value, threshold_value, comparison, display_order.

Constraint: pembuatan alert dilakukan oleh sebuah function yang menyisipkan alert + ≥ 1 factor + ≥ 1 referensi transaksi dalam satu transaksi; sebuah deferred constraint trigger menolak alert tanpa factor pada saat commit (BR-308.1, SM-04).

detect.alert_transaction — PK (alert_id, transaction_id); role (TRIGGERING,CONTEXT,SUPPRESSED_OCCURRENCE).

detect.screening_result — PK screening_result_id; FK party_entity_id, watchlist_record_id; list_version, algorithm_version, threshold_applied; combined_score, name_score, secondary_score; matched_attributes JSONB, differing_attributes JSONB; high_frequency_name_flag; state; reviewed_by, review_rationale, discriminating_attribute, escalated_by, confirmed_by, evidence_id; created_at.

Constraint: CHECK (state <> 'CONFIRMED_MATCH' OR (confirmed_by IS NOT NULL AND evidence_id IS NOT NULL AND confirmed_by <> escalated_by)) — SM-06 dan aturan dua orang ditegakkan di dalam database. Jalur pembuatan hanya mengizinkan POTENTIAL_MATCH.

invest.case — PK case_id; title, case_type, priority, state, owner_id, created_by, created_at, segment_number, rework_count, findings_text, closed_at, row_version.

Constraint: CHECK (created_by IS NOT NULL) dengan FK ke gov.app_user, dan system principal dikecualikan melalui pemeriksaan terhadap ID yang dicadangkan — NG-12 ditegakkan di dalam database.

invest.evidence — PK evidence_id; FK case_id; evidence_type, view_type, parameters JSONB, source_object_ids JSONB, object_key, sha256, mime_type, size_bytes, description, dq_banner_state, app_version, captured_by, captured_at, state, supersedes_id, corrects_id.

Constraint: tidak ada grant UPDATE kecuali satu-satunya transisi state ATTACHED → SUPERSEDED; tidak ada grant DELETE untuk role mana pun; sha256 UNIQUE per case **tidak** ditegakkan (tampilan yang sama dapat secara sah ditangkap dua kali pada waktu yang berbeda).

invest.decision — PK decision_id; FK case_id; decision_type, rationale, maker_id, submitted_at, checker_id, outcome, checker_rationale, deficiency_category, decided_at, state.

Constraint: CHECK (checker_id IS NULL OR checker_id <> maker_id) — SM-08 ditegakkan di dalam database, bukan hanya di layanan (§10.3 pada FRD).

gov.audit_event — PK event_id; correlation_id, actor_id, actor_role, action, object_type, object_id, before_value JSONB, after_value JSONB, rationale, occurred_at_utc, session_id, source_ip, outcome.

Constraint: trigger BEFORE UPDATE OR DELETE memunculkan AUDIT_IMMUTABLE; role hanya memiliki INSERT + SELECT.

Index: (correlation_id), (object_type, object_id, occurred_at_utc), (actor_id, occurred_at_utc), (action, occurred_at_utc).

detect.graph_edge — PK edge_id; graph_version; from_node_id, to_node_id, edge_type, first_seen, last_seen, occurrence_count, weight, specificity_flag.

Index: (graph_version, from_node_id, edge_type), (graph_version, to_node_id, edge_type) — keduanya diperlukan untuk penelusuran rekursif dua arah.

7.4 Rantai Ketertelusuran

Properti struktural yang paling penting dari model ini: **satu correlation ID mengambil seluruh rantai** (SM-09, SM-12, FR-1104).

Eksibit 9 — Satu correlation ID mengambil seluruh rantai, dari batch ingestion hingga draft report yang disetujui

```
graph LR
    B["ingestion_batch<br/>batch_id"] --> T["transaction<br/>transaction_id"]
    T --> AT["alert_transaction"]
    RV["rule_version<br/>rule_id + version"] --> A["alert<br/>alert_id"]
    AT --> A
    DR["detection_run<br/>run_id"] --> A
    A --> C["case<br/>case_id"]
    C --> E["evidence<br/>evidence_id"]
    C --> N["narrative<br/>narrative_id"]
    E --> DE["decision_evidence"]
    DE --> D["decision<br/>decision_id<br/>maker_id ≠ checker_id"]
    D --> R["regulatory_report<br/>report_id (draft only)"]
    B -.→ AE["audit_event<br/>correlation_id"]
    T -.→ AE
    A -.→ AE
    C -.→ AE
    E -.→ AE
    N -.→ AE
    D -.→ AE
    R -.→ AE

    style AE fill:#f8cecc
    style R fill:#fff2cc
```

Jaminan query yang akan didemonstrasikan pada UAT-12:

1. Diberikan sebuah `report_id`, kembalikan keputusannya, maker dan checker-nya, setiap item evidence yang direferensikan, case-nya, setiap alert yang tertaut, rule version dan factor dari masing-masing alert, setiap transaksi yang dikutip, dan batch yang memuatnya.
2. Diberikan sebuah `transaction_id`, kembalikan setiap alert yang mengutipnya, setiap case yang dicapai alert tersebut, dan setiap keputusan yang dibuat.
3. Diberikan sebuah `correlation_id`, kembalikan setiap audit event dalam rantai tersebut secara kronologis.
4. Diberikan sebuah `entity_id`, kembalikan setiap risk assessment, hasil screening, alert, case dan keputusan, beserta versi model, rule, algoritma dan konfigurasi yang berlaku pada setiap titik.

7.5 Catatan Index dan Performa

Perhatian	Desain
Agregasi window atas 500k transaksi	Composite index (<code>entity_id</code> , <code>value_datetime_utc</code> DESC) ditambah baris <code>detect.entity_feature</code> yang telah dihitung sebelumnya; rule membaca feature, bukan transaksi mentah, di mana pun agregatnya digunakan bersama
Paging antrean alert	Keyset pagination pada (<code>priority_band</code> , <code>created_at</code> , <code>alert_id</code>) alih-alih OFFSET, sehingga halaman 40 berbiaya sama dengan halaman 1
Paging timeline	Keyset pada (<code>value_datetime_utc</code> , <code>transaction_id</code>)
Penelusuran graph	Recursive CTE dengan penghitung <code>depth</code> , <code>LIMIT</code> pada batas jumlah node, dan <code>visited-set</code> untuk mencegah siklus; kedua index berarah tersedia
Pencarian audit	Index pada <code>correlation</code> , objek dan aktor; tabel audit hanya dapat ditambah sehingga index bloat sangat kecil
Komputasi metrik	Snapshot termaterialisasi di <code>meta.metric_snapshot</code> , disegarkan sesuai jadwal, sehingga dashboard tidak pernah mengagregasi seluruh tabel alert saat permintaan datang
Partisi	Tidak digunakan pada MVP dengan 500k baris; didokumentasikan sebagai langkah penskalaan pertama (§18.4)

08

8. Kontrak API

POIN UTAMA

- Sekitar delapan puluh endpoint, masing-masing dengan aturan otorisasi yang dideklarasikan. Route tanpa deklarasi menggagalkan assertion saat startup, sehingga ‘lupa mengamankannya’ menjadi kegagalan build, bukan lubang keamanan.
- Objek yang tidak boleh dilihat pemanggil mengembalikan error otorisasi, tidak pernah not-found. API bersikap jujur tentang apa yang ada.
- Pengajuan yang diblokir mengembalikan seluruh kondisi yang belum terpenuhi sekaligus, bukan yang pertama saja — karena maker yang memperbaiki satu penghambat setiap kali adalah cara demo Minggu 14 kehabisan waktu.
- Maker-checker dievaluasi terhadap maker tersimpan yang dibaca dari database, tidak pernah terhadap nilai yang dikirim dalam request.

8.1 Konvensi

Aspek	Aturan
Base path	/api/v1/detection/** (Group A, api-detection), /api/v1/investigation/** (Group B, api-investigation), /api/v1/iam/**, /api/v1/audit/**
Transport	Hanya HTTPS; HTTP dialihkan ke HTTPS pada gateway
Media type	application/json; charset=utf-8; ekspor menggunakan application/pdf, text/csv atau tipe MIME Office
Auth	Authorization: Bearer <JWT> pada setiap endpoint kecuali /api/v1/iam/token
Correlation	Header permintaan X-Correlation-Id; dibuat pada gateway bila tidak ada; dikembalikan pada setiap respons dan ditulis ke setiap audit event dan baris log
Idempotency	Header Idempotency-Key wajib pada endpoint POST yang membuat objek bisnis (registrasi batch, pembuatan case, pelampiran evidence)
Konkurensi	If-Match: <row_version> pada PATCH/POST yang mengubah state; ketidaksesuaian mengembalikan 409 CONFLICT
Waktu	Seluruh timestamp ISO-8601 dengan offset z; seluruh tanggal YYYY-MM-DD
Uang	Objek: {"amount": "48000000.00", "currency": "IDR"} — berupa string untuk menghindari kehilangan presisi float

Aspek	Aturan
Pagination	Keyset: ?limit=50&cursor=<opaque>; respons membawa page.next_cursor, page.has_more, page.limit. OFFSET tidak disediakan
Filtering	Hanya parameter query bernama yang eksplisit; tidak ada parameter bahasa query bebas yang diterima
Sorting	Sekumpulan tertutup pengurutan bernama per endpoint (?sort=priority_then_age)
Versioning	Versi path v1; hanya perubahan bersifat aditif di dalam satu versi; kontrak Week-4 mengatur perubahan yang merusak kompatibilitas
Error	Envelope pada §8.9 untuk setiap respons non-2xx
Masking	Diterapkan di sisi server per role sebelum serialisasi (§12.4); field yang tidak berhak diakses dihilangkan dan dicantumkan di _masked_fields

8.2 Kosakata Bersama (normatif bagi kedua group)

Prefiks identifier: ENT-, ACC-, TXN-, MER-, DEV-, RUL-, ALR-, SCR-, CAS-, EVD-, DEC-, RPT-, BAT-, RUN-, NAR-. Identifier bersifat opak bagi konsumen.

State lifecycle alert: NEW, ASSIGNED, IN_REVIEW, ESCALATED, LINKED_TO_CASE, CLOSED_FALSE_POSITIVE, CLOSED_NO_ACTION, MERGED_DUPLICATE, CLOSED_WITH_CASE, REOPENED.

State lifecycle case: OPEN, IN_INVESTIGATION, PENDING_DECISION, PENDING_APPROVAL, RETURNED_FOR_REWORK, APPROVED_CLOSED, REOPENED.

State screening: POTENTIAL_MATCH, UNDER_REVIEW, POSSIBLE_MATCH, CONFIRMED_MATCH, DISMISSED_NO_MATCH, RESCREEN_REQUIRED.

Tipe keputusan: NO_FURTHER_ACTION, MONITOR, INTERNAL_ESCALATION, DRAFT_REPORT_RECOMMENDED, MERGED_INTO_CASE.

State laporan: DRAFT_STARTED, DRAFT_COMPLETE, PENDING_MLRO_APPROVAL, APPROVED_INTERNAL, RETURNED. *(Tidak ada state transmisi.)*

State rule: DRAFT, IN_SIMULATION, PENDING_APPROVAL, ACTIVE, SUSPENDED, RETIRED, REJECTED.

Role: ROLE_ADMIN, ROLE_DATA_OPS, ROLE_ANALYST, ROLE_TRIAGE, ROLE_INVESTIGATOR, ROLE_SENIOR_INVESTIGATOR, ROLE_MLRO, ROLE_AUDITOR, ROLE_MANAGEMENT.

Kode pattern: P01_LARGE_TXN, P02_STRUCTURING, P03_RAPID_MOVEMENT, P04_HIGH_VELOCITY, P05_DORMANT_REACTIVATION, P06_ROUND_AMOUNTS, P07_SUDDEN_SPIKE, P08_HIGH_RISK_GEO, P09_SHARED_DEVICE, P10_UNUSUAL_MERCHANT, P11_FUNNEL_FLOW, P12_POTENTIAL_WATCHLIST_MATCH.

Kategori alasan disposition: EXPECTED_BUSINESS_PATTERN, KNOWN_SALARY_CYCLE, KNOWN_SETTLEMENT_PATTERN, THRESHOLD_TOO_LOW, DATA_QUALITY_ARTEFACT, LEGITIMATE_MERCHANT_SETTLEMENT, HOUSEHOLD_OR_FAMILY_SHARING, SEASONAL_ACTIVITY, EXPLAINED_BY_CUSTOMER_PROFILE, OTHER_UNSPECIFIED.

8.3 Katalog Endpoint — Group A (api-detection)

#	Method & path	Tujuan	Role	Pemilik
A1	POST /detection/batches	Mendaftarkan sebuah batch ingestion	DATA_OPS, ADMIN	A
A2	GET /detection/batches	Menampilkan daftar batch beserta state dan jumlahnya	DATA_OPS, ANALYST, MLRO, AUDITOR, ADMIN	A
A3	GET /detection/batches/{batch_id}	Detail batch + processing log	sama seperti A2	A
A4	POST /detection/batches/{batch_id}/reprocess	Meminta reprocessing disertai alasan	DATA_OPS	A
A5	GET /detection/quarantine	Menampilkan daftar item quarantine	DATA_OPS, ANALYST	A
A6	POST /detection/quarantine/{id}/resolve	Correct-and-reload atau reject	DATA_OPS	A
A7	GET /detection/data-quality/metrics	Metrik DQ per sumber dan tanggal	DATA_OPS, ANALYST, MLRO, AUDITOR	A
A8	GET /detection/er/candidates	Antrean review ER	DATA_OPS, ANALYST	A
A9	POST /detection/er/candidates/{id}/resolve	Merge atau reject disertai alasan	DATA_OPS	A
A10	POST /detection/er/entities/{id}/unmerge	Membalik sebuah merge	DATA_OPS	A
A11	GET /detection/entities/{entity_id}/risk	Assessment terkini + historis beserta factor-nya	seluruh role operasional	A→B
A12	POST /detection/risk/models	Membuat versi draft risk model	ANALYST	A
A13	POST /detection/risk/models/{v}/simulate	Menyimulasikan distribusi band	ANALYST	A
A14	POST /detection/risk/models/{v}/submit	Mengajukan untuk persetujuan (maker)	ANALYST	A

#	Method & path	Tujuan	Role	Pemilik
A15	POST /detection/risk/models/{v}/decision	Menyetujui atau menolak (checker)	MLRO	A
A16	GET/POST /detection/rules	Menampilkan daftar rule / membuat draft	ANALYST, pembacaan lebih luas	A
A17	GET /detection/rules/{id}/versions/{v}	Detail rule version (tidak dapat diubah)	seluruh role operasional	A→B
A18	POST /detection/rules/{id}/versions/{v}/simulate	Menyimulasikan terhadap data historis	ANALYST	A
A19	POST /detection/rules/{id}/versions/{v}/submit	Mengajukan untuk aktivasi (maker)	ANALYST	A
A20	POST /detection/rules/{id}/versions/{v}/decision	Mengaktifkan / menolak (checker)	MLRO	A
A21	POST /detection/rules/{id}/state	Menangguhkan / mengaktifkan kembali / memensiunkan	MLRO	A
A22	POST /detection/runs	Memicu sebuah detection run	DATA_OPS,ADMIN	A
A23	GET /detection/runs/{run_id}	Status run dan jumlah per rule	DATA_OPS,ANALYST,MLRO	A
A24	GET /detection/alerts	Daftar alert (sumber kebenaran)	seluruh role operasional	A→B
A25	GET /detection/alerts/{alert_id}	Detail lengkap alert beserta penjelasannya	seluruh role operasional	A→B
A26	GET /detection/entities/{id}/graph	Penelusuran terbatas	ANALYST,TRIAGE,INVESTIGATOR+	A→B
A27	GET /detection/entities/{id}/signals	Sinyal graph + anomaly	sama seperti A26	A→B
A28	GET /detection/entities/{id}/timeline	Transaksi + penanda event	sama seperti A26	A→B
A29	GET /detection/entities/{id}/profile	Blok data Entity 360	sama seperti A26	A→B
A30	GET /detection/screening/results	Hasil screening (potential match)	sama seperti A26	A→B

#	Method & path	Tujuan	Role	Pemilik
A31	GET /detection/screening/coverage	Laporan coverage per versi list	MLRO,AUDITOR,ANALYST	A
A32	POST /detection/screening/watchlist/versions	Memuat sebuah versi list sintetis	ADMIN	A
A33	POST /detection/screening/config	Mengusulkan perubahan threshold/algoritma	ANALYST (maker), MLRO (checker)	A
A34	GET /detection/metrics/rules	Snapshot performa rule	ANALYST,MLRO,AUDITOR,MANAGEMENT	A
A35	GET /detection/metrics/patterns	Coverage dua belas pattern	sama seperti A34	A
A36	POST /detection/outcomes	Ingest B→A atas outcome alert/case	service principal untuk Group B	B→A

8.4 Katalog Endpoint — Group B (api-investigation)

#	Metode & path	Tujuan	Peran	Pemilik
B1	GET /investigation/alerts	Tampilan queue (mem-proxy A24, menambah filter lifecycle)	TRIAGE+	B
B2	POST /investigation/alerts/{id}/assign	Penugasan / self-claim	TRIAGE+, penugasan ulang SENIOR_INVESTIGATOR+	B→A (menulis kolom lifecycle)
B3	POST /investigation/alerts/{id}/review	Pindahkan ke IN_REVIEW	penerima tugas	B→A
B4	POST /investigation/alerts/{id}/disposition	Disposition dengan kategori + alasan	TRIAGE+	B→A
B5	POST /investigation/alerts/{id}/escalate	Escalate dengan alasan	TRIAGE+	B→A
B6	POST /investigation/alerts/bulk-disposition	Penutupan massal terbatas	TRIAGE,SENIOR_INVESTIGATOR	B→A
B7	POST /investigation/alerts/{id}/reopen	Buka kembali dengan alasan	SENIOR_INVESTIGATOR,MLRO	B→A

#	Metode & path	Tujuan	Peran	Pemilik
B8	POST /investigation/alerts/{id}/priority-override	Override band prioritas	SENIOR_INVESTIGATOR, MLRO	B→A
B9	GET /investigation/entities/{id}/overview	Entity 360 (menyusun A29, A11, A27, A30)	TRIAGE+	B
B10	GET /investigation/entities/{id}/timeline	Timeline (menyusun A28)	TRIAGE+	B
B11	GET /investigation/entities/{id}/graph	Tampilan graph (menyusun A26)	ANALYST, TRIAGE+	B
B12	GET /investigation/entities/search	Pencarian entity	TRIAGE+	B
B13	POST /investigation/cases	Membuat sebuah case	INVESTIGATOR+	B
B14	GET /investigation/cases/{id}	Queue / detail case	INVESTIGATOR+, AUDITOR baca	B
B15	PATCH /investigation/cases/{id}	Memperbarui prioritas, tautan, subjek	pemilik case, SENIOR_INVESTIGATOR+	B
B16	POST /investigation/cases/{id}/notes	Menambahkan sebuah catatan	peserta case	B
B17	POST /investigation/cases/{id}/state	Transisi lifecycle	sesuai §5.9	B
B18	POST /investigation/cases/{id}/evidence	Melampirkan evidence yang diunggah	INVESTIGATOR+	B
B19	POST /investigation/cases/{id}/evidence/capture	Menangkap sebuah tampilan sistem	INVESTIGATOR+	B
B20	GET /investigation/cases/{id}/evidence	Inventaris evidence	peserta case, AUDITOR	B
B21	POST /investigation/cases/{id}/decision	Mengirim keputusan (maker)	pemilik case	B
B22	POST /investigation/decisions/{id}/approval	Menyetujui atau menolak (checker)	SENIOR_INVESTIGATOR, MLRO	B

#	Metode & path	Tujuan	Peran	Pemilik
B23	POST /investigation/cases/{id}/narrative	Meminta sebuah narrative AI	INVESTIGATOR+	B
B24	GET /investigation/narratives/{id}	Narrative beserta flag	INVESTIGATOR+	B
B25	POST /investigation/narratives/{id}/flags/{fid}/resolve	Menyelesaikan sebuah grounding flag	INVESTIGATOR+	B
B26	POST /investigation/narratives/{id}/approval	Setujui / edit-dan-setujui / tolak	SENIOR_INVESTIGATOR, MLRO	B
B27	POST /investigation/screeing/{id}/review	Dismiss atau escalate sebuah potential match	TRIAGE+	B→A
B28	POST /investigation/screeing/{id}/confirmation	Konfirmasi atau dismiss	SENIOR_INVESTIGATOR, MLRO	B→A
B29	POST /investigation/cases/{id}/report	Memulai sebuah draft report	INVESTIGATOR+	B
B30	POST /investigation/reports/{id}/validate	Validasi kelengkapan	maker	B
B31	POST /investigation/reports/{id}/submit	Mengirim untuk persetujuan MLRO	maker	B
B32	POST /investigation/reports/{id}/approval	Setujui / kembalikan	hanya MLRO	B
B33	GET /investigation/reports/{id}/export	Mengekspor draft yang disetujui (PDF/DOCX)	MLRO, maker	B
B34	GET /investigation/dashboards/{name}	Payload dashboard	sesuai §12 FRD	B
B35	GET /investigation/approvals	Queue persetujuan terpadu	SENIOR_INVESTIGATOR, MLRO	B

8.5 Endpoint Bersama

#	Metode & path	Tujuan	Peran
S1	POST /iam/token	Autentikasi, menerbitkan access + refresh token	anonim

#	Metode & path	Tujuan	Peran
S2	POST /iam/token/refresh	Refresh	terautentikasi
S3	GET /iam/me	Principal, peran, kapabilitas	terautentikasi
S4	GET/POST /iam/users	Administrasi pengguna	ADMIN
S5	PATCH /iam/users/{id}/roles	Penetapan peran dengan justifikasi konflik	ADMIN
S6	GET /audit/events	Mencari audit trail	AUDITOR,MLRO
S7	GET /audit/events/export	Mengekspor ekstrak	AUDITOR,MLRO
S8	GET/PATCH /config/{scope}	Membaca / mengubah konfigurasi	ADMIN; yang relevan terhadap risiko melalui maker-checker
S9	GET /ops/health, /ops/ready	Liveness dan readiness	internal

8.6 Contoh Request/Response Sintetis

A25 — Detail alert (kontrak penjelasan A→B, FRD §13.3)

GET /api/v1/detection/alerts/ALR-20260412-0001A7

```
{
  "alert_id": "ALR-20260412-0001A7",
  "detection_run_id": "RUN-20260412-0003",
  "created_at": "2026-04-12T02:15:44Z",
  "rule": {
    "rule_id": "RUL-0007",
    "rule_version": 3,
    "pattern_code": "P02_STRUCTURING",
    "reason_code": "RC-STRUCT-01",
    "severity": "HIGH",
    "description": "Observes multiple transactions clustered below the reporting threshold within a rolling 7-day window whose aggregate exceeds that threshold.",
    "template_version": "p02_structuring_v2"
  },
  "window": {
    "type": "ROLLING",
    "start": "2026-04-05T17:00:00Z",
    "end": "2026-04-12T17:00:00Z",
    "timezone_evaluated": "Asia/Jakarta",
    "partial_window": false
  },
  "subject": {
    "entity_id": "ENT-7K2M9QX4B1CD",
    "entity_type": "INDIVIDUAL",
    "display_name": "Sari W*****",
    "risk_band": "MEDIUM",
    "risk_score": 61,
    "risk_as_at": "2026-04-01T00:00:00Z",
    "risk_model_version": "risk_individual_v2",
    "entity_resolution_confidence": 0.93,
    "entity_resolution_mode": "MANUAL",
    "source_record_count": 2
  },
  "factors": [
    { "factor_code": "TXN_COUNT_IN_BAND", "observed_value": "5", "threshold_value": "3", "comparison": "GTE", "display_order": 1 },
    { "factor_code": "AGGREGATE_AMOUNT", "observed_value": "2245000000.00", "threshold_value": "500000000.00", "comparison": "GTE", "display_order": 2 },
  ]
}
```

```
{
  "factor_code": "BAND_LOWER_APPLIED", "observed_value": "35000000.00", "threshold_value": "35000000.00", "comparison":
  "Eq", "display_order": 3},
  {"factor_code": "AMOUNT_DISPERSION_CV", "observed_value": "0.061", "threshold_value": null, "comparison": "INFO",
  "display_order": 4},
  {"factor_code": "DISTINCT_ACCOUNTS", "observed_value": "2", "threshold_value": null, "comparison": "INFO", "display_order":
  5},
  {"factor_code": "DISTINCT_COUNTERPARTIES", "observed_value": "1", "threshold_value": null, "comparison": "INFO",
  "display_order": 6}
],
"triggering_transactions": [
  {"transaction_id": "TXN-20260406-000913F2", "value_datetime": "2026-04-06T03:11:02Z", "amount": {"amount": "46200000.00",
  "currency": "IDR"}, "direction": "OUT", "channel": "TRANSFER_INTERNAL", "counterparty_id": "CPT-004512"},
  {"transaction_id": "TXN-20260407-0011C4A0", "value_datetime": "2026-04-07T07:44:19Z", "amount": {"amount": "45500000.00",
  "currency": "IDR"}, "direction": "OUT", "channel": "TRANSFER_INTERNAL", "counterparty_id": "CPT-004512"},
  {"transaction_id": "TXN-20260408-0014BB71", "value_datetime": "2026-04-08T02:52:40Z", "amount": {"amount": "47800000.00",
  "currency": "IDR"}, "direction": "OUT", "channel": "TRANSFER_INTERNAL", "counterparty_id": "CPT-004512"},
  {"transaction_id": "TXN-20260409-00160D3E", "value_datetime": "2026-04-09T09:03:55Z", "amount": {"amount": "43000000.00",
  "currency": "IDR"}, "direction": "OUT", "channel": "TRANSFER_INTERNAL", "counterparty_id": "CPT-004512"},
  {"transaction_id": "TXN-20260411-0019A2C8", "value_datetime": "2026-04-11T04:20:11Z", "amount": {"amount": "42000000.00",
  "currency": "IDR"}, "direction": "OUT", "channel": "TRANSFER_INTERNAL", "counterparty_id": "CPT-004512"}
],
"signals": {
  "anomaly_score": 0.71,
  "anomaly_model_version": "anomaly_v1",
  "graph_signals": [
    {"signal_code": "SHARED_DEVICE_ENTITY_COUNT", "value": 3, "parameters": {"window_days": 30}},
    {"signal_code": "COMPONENT_SIZE", "value": 24, "parameters": {"depth_cap": 3}}
  ],
  "interpretation_caption": "Relationships are investigation leads, not proof of wrongdoing."
},
"screening_state": "DISMISSED_NO_MATCH",
"priority": {
  "score": 78,
  "band": "P1",
  "formula_version": "priority_v1",
  "inputs": [
    {"input": "RULE_SEVERITY", "value": "HIGH", "contribution": 35},
    {"input": "SUBJECT_RISK_BAND", "value": "MEDIUM", "contribution": 18},
    {"input": "AMOUNT_MAGNITUDE_BAND", "value": "B4", "contribution": 20},
    {"input": "OPEN_ALERTS_ON_SUBJECT", "value": "2", "contribution": 5}
  ],
  "override_band": null
},
"context": {
  "dedupe_key": "ENT-7K2M9QX4B1CD|RUL-0007|2026-W15|3f9a1c...",
  "suppression_count": 0,
  "related_alert_ids": ["ALR-20260329-00014C"],
  "concurrent_patterns": ["P06_ROUND_AMOUNTS"],
  "data_quality_flag": null,
  "late_data_reevaluation": false
},
"lifecycle": {
  "state": "ASSIGNED",
  "assignee_id": "USR-0142",
  "sla_target_at": "2026-04-12T09:00:00Z",
  "first_review_at": null,
  "disposition": null,
  "case_id": null
},
"_masked_fields": ["subject.display_name"],
"_synthetic_data_notice": "All data is synthetic and relates to a fictional organisation.",
"correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11"
}
```

B4 — Melakukan disposition atas sebuah alert (penulisan lifecycle B→A)

POST /api/v1/investigation/alerts/ALR-20260412-0001A7/disposition

Header: If-Match: 4, X-Correlation-Id: 3f1c9a52-...

```
{
  "disposition": "CLOSED_FALSE_POSITIVE",
  "reason_category": "KNOWN_SETTLEMENT_PATTERN",
  "rationale": "All five transfers are the customer's documented monthly instalment payments to the same registered vendor;
  amounts are set by the vendor's invoice schedule and match the prior six months."
}
```

200 OK

```
{
  "alert_id": "ALR-20260412-0001A7",
```

```
"state": "CLOSED_FALSE_POSITIVE",
"disposition": "CLOSED_FALSE_POSITIVE",
"reason_category": "KNOWN_SETTLEMENT_PATTERN",
"disposed_by": "USR-0142",
"disposed_at": "2026-04-12T04:11:07Z",
"time_in_state_seconds": 6923,
"row_version": 5,
"audit_event_id": "AUD-0000481233",
"correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11"
}
```

B22 — Upaya persetujuan checker yang melanggar pemisahan tugas (segregation of duties)

POST /api/v1/investigation/decisions/DEC-000481/approval

```
{ "outcome": "APPROVED", "rationale": "Reviewed evidence; agree with the maker's conclusion." }
```

403 Forbidden

```
{
  "error": {
    "code": "SEGREGATION_OF_DUTIES_VIOLATION",
    "message": "The approving user is the maker of this decision. A different user with approval rights must act.",
    "field": null,
    "details": {
      "decision_id": "DEC-000481",
      "maker_id": "USR-0207",
      "attempted_checker_id": "USR-0207",
      "eligible_checker_roles": ["ROLE_SENIOR_INVESTIGATOR", "ROLE_MLRO"]
    },
    "audit_event_id": "AUD-0000481240",
    "correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11"
  }
}
```

B21 — Pengiriman case diblokir oleh pemeriksaan kelengkapan (semua kegagalan dalam satu response)

409 Conflict

```
{
  "error": {
    "code": "GUARD_NOT_MET",
    "message": "The case cannot be submitted until all conditions are met.",
    "details": {
      "unmet_conditions": [
        {
          "condition": "EVIDENCE_REQUIRED", "message": "At least one evidence item must be attached.", "observed": 0, "required": 1,
          "unresolved": ["SCR-20260405-000117"]},
        {
          "condition": "SCREENING_RESOLVED", "message": "All screening potential matches on case subjects must be resolved.",
          "unresolved": ["SCR-20260405-000117"]},
        {
          "condition": "ALERTS_DISPOSITIONED", "message": "Linked alerts must not be in NEW or ASSIGNED.", "offending": ["ALR-20260410-0002C1"]}
      ],
      "correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11"
    }
  }
}
```

A30 — Hasil screening (disiplin bahasa adalah bagian dari kontrak)

```
{
  "screening_result_id": "SCR-20260405-000117",
  "state": "POTENTIAL_MATCH",
  "party": { "entity_id": "ENT-7K2M9QX4B1CD", "name_normalised": "sari wulandari" },
  "list_record": {
    "watchlist_record_id": "WLR-000318",
    "list_type": "PEP_SYNTHETIC",
    "list_version": "v4",
    "primary_name": "Sari Wulandary",
    "synthetic": true
  },
  "scores": { "combined_score": 0.887, "name_score": 0.94, "secondary_score": 0.62, "threshold_applied": 0.85 },
  "matched_attributes": ["name_tokens", "nationality"],
  "differing_attributes": ["date_of_birth"],
  "high_frequency_name_flag": true,
  "algorithm_version": "screen_v1",
  "notice": "This is a name-similarity observation against a synthetic list. It is not a finding and is not a match until an authorised reviewer records a confirmation.",
  "correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11"
}
```

A36 — Feed hasil B→A (batch)

```
{
  "outcomes": [
    {
      "alert_id": "ALR-20260412-0001A7",
      "disposition": "CLOSED_FALSE_POSITIVE",
      "reason_category": "KNOWN_SETTLEMENT_PATTERN",
      "disposed_at": "2026-04-12T04:11:07Z",
      "disposed_by_role": "ROLE_TRIAGE",
      "case_id": null,
      "outcome_coverage_flag": true
    },
    {
      "alert_id": "ALR-20260410-0002C1",
      "disposition": "ESCALATED",
      "reason_category": null,
      "case_id": "CAS-000318",
      "case_state": "APPROVED_CLOSED",
      "case_decision_type": "DRAFT_REPORT_RECOMMENDED",
      "case_decided_at": "2026-04-20T08:31:00Z",
      "outcome_coverage_flag": true
    }
  ]
}
```

8.7 Domain Event

Dipublikasikan sebagai baris di `meta.domain_event` dan dikirimkan melalui Redis; kedua group mengonsumsi dari schema yang sama. Envelope:

```
{
  "event_id": "EVT-000019284",
  "event_type": "ALERT_CREATED",
  "occurred_at": "2026-04-12T02:15:44Z",
  "producer": "api-detection",
  "correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11",
  "schema_version": 1,
  "payload": { "alert_id": "ALR-20260412-0001A7", "subject_entity_id": "ENT-7K2M9QX4B1CD", "pattern_code": "P02_STRUCTURING",
  "reason_code": "RC-STRUCT-01", "priority_band": "P1" }
}
```

Tipe event persis sama dengan yang tercantum pada FRD §13.6. Consumer harus idempoten terhadap `event_id`, dan harus mentoleransi field yang tidak dikenal (evolusi bersifat aditif).

8.8 Schema Audit Event (normatif)

```
{
  "event_id": "AUD-0000481233",
  "correlation_id": "3f1c9a52-8d44-4c0e-9f7b-2a1e6b0d5c11",
  "occurred_at_utc": "2026-04-12T04:11:07.312Z",
  "actor": { "actor_id": "USR-0142", "actor_role": "ROLE_TRIAGE", "session_id": "SES-00093311", "source_ip": "10.20.0.44" },
  "action": "ALERT_DISPOSED",
  "object": { "object_type": "ALERT", "object_id": "ALR-20260412-0001A7" },
  "before_value": { "state": "IN_REVIEW", "disposition": null },
  "after_value": { "state": "CLOSED_FALSE_POSITIVE", "disposition": "CLOSED_FALSE_POSITIVE", "reason_category": "KNOWN_SETTLEMENT_PATTERN" },
  "rationale": "All five transfers are the customer's documented monthly instalment payments...",
  "outcome": "SUCCESS"
}
```

Aturan: `actor_id` tidak pernah null dan tidak pernah berupa system principal untuk tindakan apa pun yang memerlukan manusia. `outcome` bernilai `SUCCESS` atau `DENIED`; setiap kegagalan otorisasi dan setiap pelanggaran pemisahan tugas ditulis dengan `DENIED`. `before_value`/`after_value` di-mask sesuai §12.4 tetapi *fakta* terjadinya perubahan tidak pernah di-mask. Hanya dapat di-insert (ADR-004).

8.9 Envelope dan Kode Error

```
{ "error": { "code": "VALIDATION_FAILED", "message": "...", "field": "rationale", "details": {}, "audit_event_id": null,
"correlation_id": "..." } }
```

HTTP	Kode	Kapan
400	VALIDATION_FAILED	Kegagalan validasi pada level field; <code>field</code> menyebutkan field yang bermasalah
401	UNAUTHENTICATED	Token hilang, kedaluwarsa atau tidak valid
403	AUTHORIZATION_DENIED	Peran tidak memiliki hak; juga dikembalikan untuk objek yang tidak boleh dilihat pemanggil (tidak pernah 404)
403	SEGREGATION_OF_DUTIES_VIOLATION	Maker mencoba bertindak sebagai checker
404	NOT_FOUND	Objek benar-benar tidak ada
409	CONFLICT	Ketidakcocokan <code>If-Match</code> / modifikasi bersamaan
409	INVALID_TRANSITION	Pelanggaran state machine; menyebutkan state saat ini dan state yang diminta
409	GUARD_NOT_MET	Transisi valid tetapi sebuah prasyarat gagal; mencantumkan seluruh kondisi yang belum terpenuhi
409	IMMUTABLE_OBJECT	Upaya mengubah record yang tidak dapat diubah
413	RATE_OR_SIZE_LIMIT	Batas body, baris ekspor, aksi massal atau kedalaman graph terlampaui
422	BUSINESS_RULE_VIOLATION	mis. reason code duplikat, bobot tidak berjumlah sesuai
429	TOO_MANY_REQUESTS	Batas laju
503	DEPENDENCY_UNAVAILABLE	Menyebutkan komponen yang tidak tersedia (mis. graph belum di-refresh, penyedia AI mati)

8.10 Penegakan RBAC pada Lapisan API

Mekanisme	Desain
Deklarasi	Setiap route mendeklarasikan <code>@requires(action=..., object_type=...)</code> ; sebuah route tanpa deklarasi menggagalkan

Mekanisme	Desain
	assertion saat startup, sehingga “lupa mengamankannya” menjadi kegagalan build, bukan lubang runtime
Evaluasi	IAM.authorize(principal, action, object) menyelesaikan matriks peran (FRD §4.2) ditambah state objek; menolak secara default
Level objek	Akses case dan evidence juga memeriksa keikutsertaan atau peran yang lebih tinggi
Maker-checker	Setiap route persetujuan memanggil assert_maker_is_not_checker(item, principal) setelah memuat maker yang tersimpan dari database — tidak pernah dari body request
Masking	Sebuah middleware serialisasi menerapkan sensitive_field_policy untuk peran principal dan mengisi _masked_fields
Penolakan	Setiap penolakan menulis audit event dengan outcome = DENIED sebelum memberikan respons
Pengujian	Sebuah uji matriks peran × endpoint yang digenerasi memastikan allow/deny untuk kesembilan peran terhadap setiap route (§15.5)

8.11 Ringkasan Kepemilikan Antarmuka A↔B

Antarmuka	Arah	Pemilik kontrak	Consumer	Kontrol perubahan
Read model alert (A24, A25)	A → B	A	B	Kontrak Minggu-4; perubahan yang merusak memerlukan persetujuan bersama
Penulisan lifecycle alert (B2–B8)	B → A (grant DB tingkat kolom + service)	Bersama	Data milik A	Sama seperti di atas
Entity 360 / timeline / graph / sinyal (A26–A29)	A → B	A	B	Sama seperti di atas
Pembacaan screening (A30) dan penulisan	A → B, B → A	Bersama	Keduanya	Sama seperti di atas

Antarmuka	Arah	Pemilik kontrak	Consumer	Kontrol perubahan
review (B27, B28)				
Pembacaan risk (A11)	A → B	A	B	Sama seperti di atas
Feed hasil (A36)	B → A	B	A	Sama seperti di atas
Domain event (§8.7)	Keduanya	Bersama	Keduanya	Hanya aditif dalam schema_version
Schema audit event (§8.8)	Keduanya	Bersama	Auditor	Hanya aditif
Envelope error (§8.9)	Keduanya	Bersama	Keduanya	Hanya aditif

09

9. Desain Rekayasa Deteksi

POIN UTAMA

- Deteksi berupa SQL berbasis himpunan di atas feature yang telah dihitung sebelumnya, bukan Python baris demi baris. Itulah yang membuat satu run penuh atas 420.000 transaksi selesai dalam target tiga puluh menit.
- Sebuah rule version mengikat baik versi template maupun himpunan parameter bertipe. Keduanya, ditambah datanya, adalah yang membuat sebuah alert dapat direproduksi.
- Setiap pola memiliki lima test: positif, negatif serupa, tepat-di-threshold, kelengkapan penjelasan, dan kecukupan data.
- Template dan schema parameter menjelaskan apa yang diamati. Tidak ada apa pun dalam basis kode maupun dokumentasinya yang menjelaskan bagaimana deteksi dapat dihindari.

9.1 Pendekatan Rekayasa

Aspek	Desain
Model eksekusi	SQL berbasis himpunan. Setiap pattern adalah template CTE terparameterisasi (<code>detection/templates/<pattern>_v<N>.sql</code>) yang mengembalikan baris kandidat (<code>entity_id</code> , <code>window_start</code> , <code>window_end</code> , <code>factor_json</code> , <code>triggering_transaction_ids[]</code>). Python mengikat parameter bertipe dan mengorkestrasi; Python tidak pernah mengiterasi transaksi baris demi baris (NFR-04).
Agregat bersama	<code>detect.entity_feature</code> dihitung sekali per run oleh C-04 dan dibaca oleh beberapa pattern, sehingga P04 dan P07 tidak masing-masing memindai ulang tabel transaksi.
Pengikatan parameter	Parameter diikat hanya melalui placeholder <code>psycopg</code> . Template tidak mengandung interpolasi string dari input pengguna (§12.5).
Determinisme	Setiap template mengurutkan outputnya berdasarkan (<code>entity_id</code> , <code>window_start</code> , <code>transaction_id</code>) dan setiap input hash diurutkan, sehingga data yang sama ditambah versi yang sama menghasilkan dedupe key yang identik byte demi byte (SM-01).
Zona waktu	Window dinyatakan sebagai <code>value_datetime_utc AT TIME ZONE 'Asia/Jakarta'</code> untuk window kalender; rolling window menggunakan aritmetika interval UTC biasa (ADR-010).
Versioning	Sebuah rule version mengunci <code>template_version</code> dan satu set parameter

Aspek	Desain
	bertipe. Keduanya disalin ke setiap alert. Mengubah salah satunya menghasilkan rule version baru (FR-302).
Schema parameter	Setiap pattern mendeklarasikan sebuah JSON Schema untuk parameteranya; sebuah rule version yang gagal validasi schema tidak dapat meninggalkan DRAFT.
Uji reproduktibilitas	T-DET-REPRO: jalankan deteksi dua kali atas dataset yang dibekukan dengan rule version yang dibekukan; pastikan alert ID identik terlepas dari urutan ID, dedupe key identik, nilai factor identik, dan himpunan transaksi pemicu identik.
Dokumentasi defensif	Template dan schema parameter menjelaskan apa yang diamati. Tidak ada artefak yang mencatat panduan penghindaran (CN-09, NG-11).

9.2 Registri Feature (C-04)

Feature adalah kosakata bersama antara rule, risk dan anomaly. Masing-masing berupa (entity_id, feature_code, window_code, value, computed_at, feature_set_version, data_availability_status).

Feature code	Definisi	Window	Digunakan oleh
TXN_COUNT	Jumlah transaksi	R24H,R7D,R30D,R90D,C1D,C1W	P02, P04, P06, P10
TXN_VALUE_SUM	Total amount_idr	sama	P01, P02, P07, P08
TXN_VALUE_P95	Persentil ke-95 dari amount_idr	R90D	P01
TXN_VALUE_MEAN,_SD	Rata-rata dan simpangan baku	R90D, W12	P04, P07, anomaly
INBOUND_SUM,OUTBOUND_SUM	Total per arah	R24H,R30D	P03
PASSTHROUGH_RATIO	Outbound dalam N jam ÷ inbound yang memenuhi syarat	per-event	P03
DISTINCT_COUNTERPARTIES	counterparty_id yang berbeda	R7D,R30D	P02, P06, P11
DISTINCT_ACCOUNTS	Akun berbeda milik entity yang digunakan	R7D	P02
ROUND_TXN_COUNT,ROUND_PROPORTION	Nominal yang habis dibagi unit pembulatan dan ≥ nominal minimum	R30D	P06

Feature code	Definisi	Window	Digunakan oleh
DAYS_SINCE_LAST_TXN	Dari riwayat transaksi, bukan dari status akun	titik	P05
GEO_EXPOSURE_COUNT,_SUM,_SHARE	Terhadap versi daftar geografi yang dikelola	R30D	P08
DEVICE_ENTITY_COUNT,DEVICE_ACCOUNT_COUNT	Entity/akun berbeda per device	R30D	P09
AVG_TICKET,REFUND_RATE,PAYER_CONCENTRATION,OFF_HOURS_SHARE	Perilaku merchant	R30D	P10
FUNNEL_IN_DEGREE,FUNNEL_OUT_DEGREE,TIME_COMPRESSION_RATIO,AMOUNT_UNIFORMITY_CV	Struktur aliran berarah	sub-window R7D + R48H	P11
CHANNEL_MIX,HOUR_PROFILE,DOW_PROFILE	Vektor distribusi	R90D	anomaly, P10
BASELINE_DAYS_AVAILABLE,BASELINE_WEEKS_AVAILABLE	Kecukupan data	titik	setiap rule relatif

Aturan kecukupan: sebuah rule dengan kondisi relatif harus membaca feature `BASELINE_*` yang sesuai dan menolak mengevaluasi cabang relatif di bawah nilai minimumnya, dengan mencatat `PARTIAL_WINDOW`.

9.3 Spesifikasi Rekayasa per Pattern

Definisi bisnis setiap pattern ada pada FRD §8. Tabel ini memberikan permukaan rekayasanya: apa yang dibaca template, schema parameternya, dan ID pengujiannya. Severity, reason code dan false positive yang diperkirakan sudah ditetapkan pada FRD dan tidak diulang di sini.

Eksibit 10 — Permukaan rekayasa untuk kedua belas pattern deteksi, dengan schema parameter bertipe

Pattern	Field sumber utama	Feature yang dibaca	Schema parameter (bertipe)	Window	Uji unit	Uji FP
P01 LARGE_TXN	amount_idr, direction, channel, value_datetime_utc, entity_type	TXN_VALUE_P95(R90D), TXN_COUNT(R90D)	abs_threshold_individual:money, abs_threshold_merchant:money, relative_multiple:number≥1, min_history_txns:int≥1	titik + baseline R90D	T-DET-P01-01...04	TD-P01-NEG-01/02
P02 STRUCTURING	amount_idr, direction, account_id, counterparty_id, value_datetime_utc	TXN_COUNT(R7D), TXN_VALUE_SUM(R7D), DISTINCT_ACCOUNTS, DISTINCT_COUNTS	reporting_threshold:money, band_lower_pct:number(0,1), min_count:int≥2,	R7D	T-DET-P02-01...05	TD-P02-NEG-01/02, batas EDGE-01

Pattern	Field sumber utama	Feature yang dibaca	Schema parameter (bertipe)	Window	Uji unit	Uji FP
		UNTERPARTIES	aggregate_multiple: number>0			
P03 RAPID_MOVEMENT	pasangan kredit/debit per akun, value_datetime_utc, amount_idr	PASSTHROUGH_RATIO, INBOUND_SUM, OUTBOUND_SUM	max_elapsed_hours:int, passthrough_ratio: number(0,1), min_inbound_amount: money, min_outbound_count:int ≥1	rolling berbasis event ≤ 24 jam	T-DET-P03-01...05	TD-P03-NEG-01/02, tengah malam EDGE-01
P04 HIGH_VELOCITY	value_datetime_utc, amount_idr	TXN_COUNT(R24H), TXN_VALUE_MEAN/SD(R90D), BASELINE_DAYS_AVAILABILITY	baseline_days:int, current_window_hours:int, min_count_floor:int, deviation_sigma:number, alt_multiple:number, min_baseline_days:int	R24H VS R90D	T-DET-P04-01...05	TD-P04-NEG-01/02, riwayat tipis EDGE-01
P05 DORMANT_REACTIVATION	riwayat transaksi, account.opened_date	DAYS_SINCE_LAST_TXN, TXN_COUNT(R7D), TXN_VALUE_SUM(R7D)	dormancy_days:int, reactivation_window_days:int, min_reactivation_amount: money, min_reactivation_count:int	dormansi R90D + aktivitas R7D	T-DET-P05-01...05	TD-P05-NEG-01/02, tepat-90 EDGE-01
P06 ROUND_AMOUNTS	amount_idr, counterparty_id	ROUND_TXN_COUNT, ROUND_PROPORTION, TXN_COUNT(R30D)	rounding_unit: money, min_amount: money, min_count:int, min_proportion: number(0,1)	R30D	T-DET-P06-01...04	TD-P06-NEG-01/02, selisih-satu EDGE-01
P07 SUDDEN_SPIKE	amount_idr, business_date	TXN_VALUE_SUM(C1W), TXN_VALUE_MEAN(W12), BASELINE_WEEKS_AVAILABLE	baseline_weeks:int, min_absolute_increase: money, spike_multiple:number, min_baseline_weeks:int	C1W VS baseline 12 minggu	T-DET-P07-01...04	TD-P07-NEG-01/02, baseline miring EDGE-01
P08 HIGH_RISK GEO	counterparty_country, ip_address → ip_country	GEO_EXPOSURE_COUNT/SUM/SHARE(R30D)	min_count:int, min_aggregate: money,	R30D	T-DET-P08-01...04	TD-P08-NEG-01/02, IP-vs-country

Pattern	Field sumber utama	Feature yang dibaca	Schema parameter (bertipe)	Window	Uji unit	Uji FP
	y, versi daftar geografi		min_exposure_share: number(0,1), geography_list_version: string			terparty EDGE-01
P09 SHARED_DEVICE	device_id, entity_id, account_id, edge graph	DEVICE_ENTITY_COUNT, DEVICE_ACCOUNT_COUNT, specificity_flag	min_distinct_entities: int, min_distinct_accounts: int, exclude_low_specificity: boolean, count_household: boolean	R30D	T-DET-P09-01...05	TD-P09-NEG-01/02, tepat-4 EDGE-01
P10 UNUSUAL_MERCHANT	mcc, nominal ticket, refund, himpunan payer, profil jam	AVG_TICKET, REFUND_RATE, PAYER_CONCENTRATION, OFF_HOURS_SHARE, TXN_COUNT(R30D)	ticket_deviation_multiple: number, refund_rate: number(0,1), payer_concentration: number(0,1), off_hours_share: number(0,1), min_txn_count: int	R30D	T-DET-P10-01...06	TD-P10-NEG-01/02, merchant baru EDGE-01
P11 FUNNEL_FLOW	aliran berarah antar-entiti, tumpang tindih device/kontak	FUNNEL_IN_DEGREE, FUNNEL_OUT_DEGREE, TIME_COMPRESSION_RATIO, AMOUNT_UNIFORMITY_CV	min_distinct_counterparties: int, min_aggregate: money, compression_window_hours: int, compression_ratio: number(0,1)	R7D + R48H	T-DET-P11-01...05	TD-P11-NEG-01/02 (biaya sekolah, payroll), batas EDGE-01
P12 POTENTIAL_WATCHLIST_MATCH	nama/alias/tanggal lahir/kewarganegaraan pihak; field record daftar	n/a (engine screening, §10.4)	screening_threshold: number(0,1), secondary_weight: number(0,1), high_frequency_percentile: int	titik + rescreen	T-SCR-01...10	TD-P12-NEG-01/02, nama tunggal EDGE-01

9.4 Transaksi Pembuatan Alert

Pembuatan alert adalah satu transaksi database tunggal yang dijalankan oleh sebuah stored function sehingga alert parsial tidak mungkin ada:

1. Hitung dedupe key dari entity_id, rule_id, window_bucket dan hash ID transaksi pemicu yang telah diurutkan.
2. Coba INSERT ... ON CONFLICT (dedupe_key) WHERE state IN ('NEW', 'ASSIGNED', 'IN_REVIEW') DO NOTHING.

3. Jika terjadi konflik: UPDATE `suppression_count` pada alert yang bertahan, tambahkan baris `alert_transaction` dengan `role = 'SUPPRESSED_OCCURRENCE'`, tulis audit event `ALERT_SUPPRESSED_AS_DUPLICATE`, lalu kembali.
4. Jika tidak: sisipkan `alert`, lalu seluruh baris `alert_factor`, lalu seluruh baris `alert_transaction`.
5. Hitung prioritas (versi formula dikunci) dan simpan inputnya.
6. Tulis audit event `ALERT_CREATED` **di dalam transaksi yang sama** (ADR-004).
7. Commit. Sebuah deferred constraint trigger menolak commit jika alert tersebut memiliki nol factor atau nol transaksi pemicu.

9.5 Mode Simulasi

Template yang sama dijalankan dengan `write_alerts = false`. Output masuk ke `meta.simulation_result` berisi: jumlah alert yang akan terbentuk, entity unik, distribusi harian, tumpang tindih per rule (entity yang juga di-alert oleh rule aktif lain pada window yang sama), dan 20 alert hipotetis teratas dengan detail factor lengkap. Simulasi dibatasi oleh waktu eksekusi; pemotongan diberi label dengan periode yang benar-benar tercakup. Simulasi yang lebih tua dari 7 hari tidak dapat mendukung pengajuan aktivasi (FR-303).

9.6 Batas Penekanan Duplikat (menyelesaikan CF-01)

Diizinkan	Tidak diizinkan
Menolak membuat baris alert kedua untuk hipotesis yang identik selama alert pertama masih terbuka	Menutup, menyembunyikan, menurunkan atau melakukan disposition otomatis atas alert mana pun
Mencatat kemunculan yang ditekan pada alert yang bertahan dan pada metrik rule	Menekan lintas window bucket yang berbeda (kemunculan tersebut menjadi <code>alert RELATED_PRIOR</code>)
Menekan selama alert yang bertahan berstatus <code>NEW/ASSIGNED/IN_REVIEW</code>	Menekan terhadap alert yang sudah ditutup (sebagai gantinya dibuat alert baru)

Sebuah butir checklist code review dan pengujian T-DET-DEDUPE-05 memastikan bahwa tidak ada jalur kode yang mengubah state alert tanpa aktor manusia.

9.7 Penanganan Pattern Bersamaan (menyelesaikan CF-07)

Pattern dievaluasi secara independen (FRD §8.13). Setelah seluruh rule dalam satu run menghasilkan match-nya, C-10 menghitung, per subjek dan window bucket, himpunan pattern code yang terpicu dan menuliskannya ke `concurrent_patterns` pada setiap alert. Eskalasi severity yang dijelaskan pada FRD §8.6 dan §8.9 diterapkan pada tahap **priority scoring**, bukan di dalam template rule — sehingga logika dan severity milik sebuah rule version tetap tidak dapat diubah dan dapat direproduksi.

9.8 Desain Kinerja Deteksi

Teknik	Tujuan
Prakomputasi feature	Satu kali lintasan atas transaksi per run, bukan satu kali per rule
Indeks komposit (<code>entity_id</code> , <code>value_datetime_utc</code> DESC)	Pemindaian window mengenai indeks, bukan pemindaian sekuensial
Indeks BRIN pada <code>value_datetime_utc</code>	Pemangkasan rentang yang murah pada tabel enam bulan
Statement timeout per rule	Sebuah rule yang patologis tidak dapat menghabiskan seluruh window run

Teknik	Tujuan
Batch entity terpotong	Rule dievaluasi atas partisi entity berukuran ~5,000 sehingga memori tetap terbatas dan progres terlihat
Dua proses worker	Paralelisme tanpa berebut lock tabel yang sama
Snapshot metrik termaterialisasi	Dashboard tidak pernah mengagregasi tabel alert secara langsung

Target (NFR-04): run penuh atas 500,000 transaksi dan seluruh dua belas pattern dalam waktu kurang dari 30 menit pada host referensi. Diukur oleh T-PERF-DET-01 dan dicatat per run di `meta.detection_run`.

10

10. Desain Risk, Anomaly, Graph dan Screening yang Dapat Dijelaskan

POIN UTAMA

- Keterjelasan adalah batasan arsitektural. Score tanpa kontribusi per faktor melanggar constraint database, sehingga model yang tidak dapat dijelaskan tidak dapat dideploy bahkan secara tidak sengaja.
- Data yang tidak memadai menghasilkan `INSUFFICIENT_DATA`, bukan score rendah. Data yang tipis tidak boleh terbaca sebagai risiko rendah.
- Jaminan state screening ditegakkan di dalam schema: tidak ada confirmed match tanpa manusia yang mengonfirmasi, tanpa referensi evidence, dan tanpa konfirmator yang berbeda dari yang melakukan eskalasi.
- Keterangan 'petunjuk, bukan bukti' pada graph ikut di dalam payload API, sehingga bertahan pada ekspor dan penangkapan evidence, bukan hanya hidup di UI.

10.1 Model Risk (C-05)

Bentuk: $\text{score} = \text{clamp}(0, 100, \sum (\text{weight}_f \times \text{normalised_value}_f))$, dievaluasi per tipe entity.

Aspek	Desain
Definisi factor	Setiap factor mendeklarasikan: kode, feature atau atribut input, sebuah fungsi normalisasi (pencarian band, min-max dengan batas terkonfigurasi, atau boolean), sebuah bobot, dan deskripsi berbahasa sederhana yang ditampilkan pada UI
Set factor individu	Tipe customer, band pekerjaan/industri, geografi registrasi, geografi transaksi, bauran produk/kanal, masa kepemilikan akun, kelengkapan KYC, band volume, band velocity, eksposur risiko counterparty, berbagi device, riwayat alert terbuka, state screening
Set factor merchant	Band MCC, usia usaha, state screening beneficial owner, pola settlement, tingkat refund/pembalikan, tingkat analog chargeback, ticket rata-rata dan maksimum, konsentrasi customer, porsi lintas negara, keragaman device/IP payer
Bobot	Berjumlah total yang dikonfigurasi (divalidasi saat penyimpanan versi model); dinyatakan sebagai bilangan bulat untuk menghindari float drift
Band	LOW 0–39, MEDIUM 40–69, HIGH 70–100 (dapat dikonfigurasi per versi model)
Coverage	$\text{coverage_pct} = \text{available_weight} \div \text{total_weight}$; di bawah <code>MIN_COVERAGE</code> (default 60%) entity berstatus <code>INSUFFICIENT_DATA</code> dan tidak ada band yang ditetapkan

Aspek	Desain
Penyimpanan	Baris <code>risk_assessment + risk_factor</code> ditulis secara atomik; sebuah deferred constraint menolak assessment dengan nol factor
Jaminan penjelasan	Total kontribusi sama dengan score dalam toleransi pembulatan; hal ini dipastikan oleh T-RISK-03 pada setiap assessment tersimpan di dataset demo (SM-04)
Versioning	Versi model tidak dapat diubah setelah disetujui; assessment historis mempertahankan versinya; perbandingan antarversi diberi label tidak dapat dibandingkan
Tata kelola	Perubahan → simulasi atas populasi yang sama → maker-checker (FR-204); porsi HIGH hasil simulasi di atas 15% memblokir pengajuan sampai ada justifikasi eksplisit
Dilarang	Model apa pun yang kontribusi per factor-nya tidak dapat ditampilkan (ADR-007, NG-07)

10.2 Model Anomaly (C-07)

Aspek	Desain
Baseline	Per entity, statistik 90 hari ke belakang untuk vektor feature tetap: <code>TXN_COUNT</code> , <code>TXN_VALUE_SUM</code> , <code>TXN_VALUE_MEAN</code> , <code>DISTINCT_COUNTERPARTIES</code> , <code>CHANNEL_MIX</code> , <code>HOURLY_PROFILE</code> , <code>GEO_EXPOSURE_SHARE</code>
Score	Untuk feature skalar, deviasi terstandarisasi $z = (\text{current} - \text{mean}) \div \max(\text{sd}, \text{floor})$; untuk feature distribusi, divergensi terbatas antara vektor saat ini dan vektor baseline. Score komposit = kombinasi berbobot terdokumentasi dari kontribusi per feature yang dipotong
Kecukupan	<code>NO_BASELINE</code> di bawah 30 transaksi atau 30 hari; <code>LOW_CONFIDENCE_BASELINE</code> di atas batas koefisien variasi yang dikonfigurasi
Penyimpanan	<code>anomaly_score + anomaly_feature</code> (nilai baseline, nilai saat ini, deviasi, kontribusi)
Model opsional	Isolation Forest dapat ditambahkan hanya jika kontribusi per feature dilaporkan bersama score-nya; jika tidak, model tersebut tidak digunakan (ADR-007)
Peran dalam sistem	Hanya sinyal pendukung: menyumbang sebuah factor dan menaikkan prioritas; tidak membuat alert pada MVP (CF-05)

Aspek	Desain
Tata kelola	Versi model melalui maker-checker (FR-405); score mempertahankan versinya
Pemantauan	Distribusi score dan coverage per versi model, hanya pada data sintetis, dengan peringatan tetap (FR-1004)

10.3 Desain Graph (C-08, C-16)

Aspek	Desain
Proyeksi	Pembangunan ulang penuh ke <code>graph_version</code> baru; pertukaran pointer secara atomik saat selesai sehingga pembaca tidak pernah melihat graph parsial
Node	Entity, akun, merchant, device, telepon, email, alamat
Edge	<code>OWNS_ACCOUNT</code> , <code>USED_DEVICE</code> , <code>SHARES_PHONE</code> , <code>SHARES_EMAIL</code> , <code>SHARES_ADDRESS</code> , <code>TRANSACTIONED_WITH</code> , <code>BENEFICIAL_OWNER_OF</code> — masing-masing dengan <code>first_seen</code> , <code>last_seen</code> , <code>occurrence_count</code> , <code>weight</code> , <code>specificity_flag</code>
Bobot	Fungsi ternormalisasi dari jumlah kemunculan dan kebaruan, diturunkan bobotnya untuk <code>LOW_SPECIFICITY</code> (alamat placeholder, email generik dari penyedia gratis, konteks perangkat berbagi yang diketahui)
Penelusuran	CTE rekursif dengan himpunan node yang telah dikunjungi, <code>depth ≤ cap</code> , <code>LIMIT node_cap</code> , diurutkan (<code>weight DESC</code> , <code>node_id ASC</code>) sehingga pemotongan bersifat deterministik dan dapat direproduksi
Batas	Kedalaman 3, node 300 secara default; permintaan di atas batas ditolak dengan menyertakan nilai batasnya, tidak pernah dikurangi secara diam-diam
Sinyal	<code>SHARED_DEVICE_ENTITY_COUNT</code> , <code>COMPONENT_SIZE</code> (dilaporkan sebagai “> N” di luar batas), <code>FUNNEL_IN_DEGREE</code> , <code>FUNNEL_OUT_DEGREE</code> — masing-masing disimpan bersama parameternya
Interpretasi	Keterangan “Relationships are investigation leads, not proof of wrongdoing” adalah bagian dari payload API , bukan hanya UI, sehingga tetap ada pada ekspor dan penangkapan evidence (FR-406)

Aspek	Desain
Kebiasaan	<code>graph_refreshed_at</code> dikembalikan bersama setiap response graph; consumer harus menampilkannya
Evidence	Tampilan graph yang ditangkap menyimpan seed, kedalaman, batas, flag pemotongan, himpunan ID node/edge dan versi graph, sehingga menjalankan ulang akan mereproduksinya (FR-708)

10.4 Desain Screening (C-09)

Tahap	Desain
Normalisasi	Unicode NFKD → hilangkan diakritik → huruf kecil → hapus tanda baca → hapus honorifik dan gelar (bapak, ibu, bpk, hj, haji, drs, ir, st, md) → rapatkan spasi → urutkan token untuk perbandingan token-set sambil mempertahankan urutan asli untuk perbandingan berurutan
Skor nama	Kombinasi dari kemiripan token-set, Jaro-Winkler berurutan, dan komponen fonetik yang disesuaikan untuk varian ortografi Indonesia (mis. y/i, dj/j, tj/c, oe/u)
Skor sekunder	Kesesuaian pada tanggal lahir (persis, hanya tahun, atau dalam toleransi), kewarganegaraan dan negara; berkontribusi hingga <code>secondary_weight</code> (default 0.30) dari skor gabungan
Threshold	<code>combined_score</code> $\geq$ <code>screening_threshold</code> (default 0.85) membentuk sebuah <code>POTENTIAL_MATCH</code>
Nama berfrekuensi tinggi	Nama di atas persentil populasi yang dikonfigurasi menetapkan <code>high_frequency_name_flag</code> , sehingga reviewer memberi bobot yang sesuai
Tidak dapat di-screening	Pihak tanpa nama yang dapat digunakan dicatat sebagai <code>NOT_SCREENABLE</code> beserta alasannya; coverage harus terekonsiliasi persis (<code>in_scope = screened + not_screenable</code>)
Evidence hasil nol	Pihak yang di-screening tanpa potential match memperoleh baris eksplisit “screened, zero potential matches” beserta versi list — “kami men-screening semua orang” harus dapat dibuktikan (FR-507)
Jaminan state	Jalur pembuatan hanya menerima <code>POTENTIAL_MATCH</code> ; sebuah <code>CHECK</code> database mencegah <code>CONFIRMED_MATCH</code> tanpa confirmer

Tahap	Desain
	manusia, referensi evidence, dan confirmed_by <> escalated_by (SM-06, §10.3 FRD)
Rescreen	Dipicu oleh versi list baru atau perubahan pada nama, DOB atau kewarganegaraan suatu pihak; keputusan manusia sebelumnya ditampilkan sebagai riwayat dan tidak pernah ditimpa
Pembuatan versi	list_version, algorithm_version dan threshold_applied disimpan pada setiap hasil dan tidak pernah diisi ulang secara mundur
Bahasa	Keempat kata state merupakan enumerasi bersama yang digunakan oleh database, API, UI, ekspor dan template narrative (FR-508)

10.5 Metadata Model dan Rule (seragam untuk keempatnya)

Setiap artefak scoring atau matching menyimpan envelope metadata yang sama, dan inilah yang membuat platform dapat diaudit:

Field	Makna
artefact_type	RULE, RISK_MODEL, ANOMALY_MODEL, SCREENING_CONFIG, PRIORITY_FORMULA, GRAPH_VERSION, FEATURE_SET
version	Bilangan bulat monotonik atau string semantik
definition_hash	SHA-256 dari definisi kanonik, sehingga perubahan diam-diam dapat terdeteksi
state	State lifecycle
created_by, submitted_by, approved_by, approved_at	Provenance maker-checker
simulation_reference	Evidence yang mendukung persetujuan
effective_from	Penerapan maju saja; tidak pernah retroaktif
superseded_by	Rantai versi

10.6 Evaluasi dan Pemantauan Hanya-Sintetis

Kebutuhan	Desain
Ground truth	Generator menghasilkan tabel label meta.scenario_label(entity_id, pattern_code, scenario_id, window_start, window_end, label_type) dengan label_type ∈ {INJECTED_POSITIVE, CONTROL_CLEAN, EDGE_CASE}
Recall	Untuk setiap pattern yang diimplementasikan, recall = alerts matching

Kebutuhan	Desain
	an INJECTED_POSITIVE label ÷ INJECTED_POSITIVE labels; target ≥ 90% (SM-05)
Control cohort	Tidak boleh ada alert yang muncul pada entity CONTROL_CLEAN mana pun pada parameter default yang disetujui; satu alert saja menggagalkan T-DET-CONTROL-01 (SM-03)
Presisi	Dilaporkan sebagaimana teramati pada data sintetis dengan catatan eksplisit bahwa prevalensi injected-positive merupakan artefak generator, bukan estimasi prevalensi nyata
Drift	Tidak berlaku pada MVP; populasinya statis. Didokumentasikan sebagai pekerjaan lanjutan
Peringatan	Setiap permukaan metrik dan ekspor membawa peringatan data sintetis (\$12.0 FRD) sebagai field payload, sehingga tidak dapat hilang
Klaim terlarang	Tidak ada dokumen, layar atau slide presentasi yang boleh menyatakan angka-angka ini sebagai kinerja deteksi produksi (L-01)

11

11. Generator Data Sintetis

POIN UTAMA

- Deterministik berdasarkan seed. Seed yang sama mereproduksi dataset persis byte demi byte, termasuk labelnya — tanpa itu tidak ada metrik deteksi yang dapat direproduksi.
- Edge cohort dibangun agar berdekatan secara perilaku dengan positif yang disuntikkan. Jika akun iuran sekolah mudah dipisahkan dari sebuah funnel, diskusi false positive menjadi tidak bermakna.
- Cacat kualitas disuntikkan dengan sengaja pada laju terkendali, sehingga pipeline kualitas punya pekerjaan nyata dan demo punya sesuatu untuk ditunjukkan.
- Case dan keputusan yang di-seed ditulis melalui jalur layanan normal, bukan melalui penyisipan langsung ke database, sehingga audit trail yang dihasilkannya autentik.

11.0 Prinsip

1. **Deterministik.** Seed yang tetap mereproduksi dataset secara byte-for-byte, termasuk labelnya. Tanpa ini, tidak ada metrik deteksi yang dapat direproduksi (SM-01).
2. **Jelas sintetis.** Nama, identifier, alamat dan record list diambil dari pool yang dibangkitkan; setiap file output membawa `synthetic_declaration = true` di dalam manifest-nya.
3. **Berbentuk realistis, bukan bersumber realistis.** Generator meniru *bentuk* aktivitas digital wallet Indonesia (pengelompokan gaji, musim Idul Fitri, pengumpulan arisan, kios agen, koridor remitansi) tanpa menyalin data nyata mana pun.
4. **Berlabel.** Setiap skenario yang diinjeksikan menghasilkan baris label, sehingga uji recall dan control cohort bersifat mekanis (§10.6).
5. **Sengaja tidak sempurna.** Cacat kualitas diinjeksikan secara sengaja agar pipeline kualitas memiliki sesuatu untuk ditangkap.

11.1 Target Volume

Objek	Target	Catatan
Customer (individu)	10,000	Termasuk ~600 source record duplikat yang dirancang untuk entity resolution
Customer bisnis	1,200	Masing-masing dengan 1–4 beneficial owner
Beneficial owner	~2,400	~40 digunakan bersama oleh dua bisnis untuk membentuk edge graph
Merchant	1,000–2,000 (target 1,500)	Tersebar pada ~25 band MCC
Account / wallet	12,000–15,000 (target 13,500)	1–3 per entity individu, 1–2 per bisnis
Transaksi	300,000–500,000 (target 420,000)	Enam bulan, kalender kerja Asia/Jakarta
Device	8,000–12,000 (target 10,000)	Termasuk ~120 device yang sengaja digunakan bersama

Objek	Target	Catatan
Alert (diperkirakan pada parameter default)	500–1,500	Muncul secara emergent, tidak dibangkitkan langsung
Case (di-seed untuk demo)	100–300 (target 180)	Tersebar pada seluruh state lifecycle
Periode	6 bulan berakhir pada tanggal referensi demo	Window rule terpanjang adalah 90 hari (AS-06)
Record watchlist	2,500	60% PEP_SYNTHETIC, 30% SANCTIONS_SYNTHETIC, 10% INTERNAL_WATCH

Profil: *tiny* (1% — CI), *small* (5% — pengembangan lokal), *full* (100% — integrasi dan demonstrasi). Ketiganya berbagi skema seed yang sama sehingga skenario yang ada pada *full* juga ada pada *small* dengan proporsi yang sebanding.

11.2 Komposisi Populasi

Kohort	Porsi entity	Perilaku
Ritel biasa	~62%	Pembayaran bernilai kecil yang sering, top-up, transfer ke sekumpulan counterparty kecil yang stabil, pengelompokan pada hari gaji dan akhir bulan
Bisnis/merchant biasa	~18%	Pola settlement, refund pada tingkat normal, basis pembayar yang luas, nilai tiket yang konsisten dengan kategori
Kohort control-clean (§8.14 FRD)	~8% (subset berlabel dari dua kohort di atas)	Dibangkitkan secara eksplisit untuk menghasilkan nol alert pada parameter default yang disetujui
Edge/ambigu	~8%	Perilaku sah yang menyerupai suatu pattern: pengumpul arisan, rekening uang sekolah, penyalur payroll, kios agen, pedagang musiman, pelajar lintas negara, keluarga yang berbagi satu handset
Skenario mencurigakan yang diinjeksikan	~4%	Satu atau lebih dari dua belas pattern, diberi label dengan kode pattern dan window

Tumpang tindih yang disengaja: kohort edge dan kohort injeksi dibangun agar *berdekatan secara perilaku* — rekening uang sekolah dan skenario funnel terutama berbeda pada kompresi waktu, tumpang tindih device dan

keseragaman nominal. Jika kedua kohort tersebut mudah dipisahkan, rule akan dapat di-tuning secara trivial dan diskusi false positive menjadi tidak bermakna.

11.3 Skenario dan Label yang Diinjeksikan

Skenario	Pattern	Jumlah (profil full)	Label
Transfer tunggal bernilai sangat besar	P01	60	INJECTED_POSITIVE
Pengelompokan di bawah threshold	P02	45	INJECTED_POSITIVE
Pass-through pada hari yang sama	P03	50	INJECTED_POSITIVE
Lonjakan jumlah terhadap baseline	P04	55	INJECTED_POSITIVE
Dorman lalu aktivitas material	P05	40	INJECTED_POSITIVE
Nominal bulat yang seragam	P06	35	INJECTED_POSITIVE
Perubahan bertingkat nilai mingguan	P07	40	INJECTED_POSITIVE
Eksposur terkonsentrasi pada geografi terdaftar	P08	45	INJECTED_POSITIVE
Device digunakan bersama oleh entity yang tidak berhubungan	P09	30	INJECTED_POSITIVE
Merchant tidak konsisten dengan kategorinya	P10	45	INJECTED_POSITIVE
Konvergensi banyak-ke-satu dengan tumpang tindih device	P11	35	INJECTED_POSITIVE
Nama mirip dengan record list sintetis	P12	70	INJECTED_POSITIVE
Perilaku sah yang mirip (per pattern)	seluruh 12	25 masing-masing (300)	EDGE_CASE
Kohort bersih	—	~800 entity	CONTROL_CLEAN
Kasus batas (tepat pada threshold)	seluruh 12	5 masing-masing (60)	EDGE_CASE

Setiap baris label mencatat `entity_id`, `pattern_code`, `scenario_id`, `window_start`, `window_end`, `label_type` dan `expected_reason_code`, sehingga uji T-DET-P* menegaskan baik bahwa alert muncul maupun bahwa alert tersebut muncul karena alasan yang benar.

11.4 Cacat Kualitas yang Disengaja

Diinjeksikan pada tingkat terkendali agar pipeline kualitas (C-02) memiliki pekerjaan nyata:

Cacat	Tingkat	Penanganan yang diharapkan
Identifier counterparty hilang	3% dari transaksi	Dimuat; menurunkan metrik integritas referensial; memicu banner Entity 360
Device ID hilang	5% dari transaksi	Dimuat; feature ditandai <code>DATA_UNAVAILABLE</code>
Format tanggal salah bentuk	0.4% dari baris	Di-quarantine dengan <code>INVALID_DATE_FORMAT</code>
Kode mata uang tidak valid	0.2%	Di-quarantine dengan <code>INVALID_CURRENCY</code>
Nominal negatif atau nol	0.2%	Di-quarantine dengan <code>INVALID_AMOUNT</code>
Referensi account tidak dikenal	0.5%	Ditahan hingga akhir batch, lalu di-quarantine <code>UNRESOLVED_ACCOUNT</code>
Baris duplikat persis	1%	Ditekan oleh idempotency, tetap dihitung
Key sama, nominal berbeda	0.05%	Di-quarantine <code>IDEMPOTENCY_CONFLICT</code>
Transaksi datang terlambat	1.5%	Ditandai <code>LATE_ARRIVAL</code> , memicu evaluasi ulang tertarget
Beneficial owner hilang	4% dari bisnis	Dimuat; ditandai <code>BO_MISSING</code> ; menjadi masukan sebuah faktor risiko
Alamat placeholder	2% dari pihak	Dimuat; menghasilkan edge graph <code>LOW_SPECIFICITY</code>
Nama terpotong atau hanya satu token	3% dari pihak	Dimuat; sebagian menjadi <code>NOT_SCREENABLE</code> , sebagian lain menetapkan <code>HIGH_FREQUENCY_NAME</code>
Satu batch di atas threshold abort	1 batch dalam set demo	Mendemonstrasikan <code>QUALITY_ABORT_THRESHOLD</code> (UAT-01)

11.5 Populasi Uji Entity Resolution

Konstruksi	Jumlah	Tujuan
Orang yang sama, national ID sama, varian ejaan nama	200	Harus auto-merge
Orang yang sama, phone + DOB cocok, alamat berbeda	150	Harus auto-merge
Nama sama, tanpa atribut sekunder yang sama	180	Tidak boleh auto-merge (US-111)
Phone sama, national ID bertentangan	40	Harus memaksa PENDING_REVIEW dengan IDENTIFIER_CONFLICT
Pasangan ambigu pada band 0.75–0.95	250	Mengisi antrean review manual
Kandidat merge yang menyentuh case terbuka	5	Mendemonstrasikan jalur block-and-acknowledge

11.6 Data Investigasi yang Di-seed

Untuk mendemonstrasikan lifecycle dan dashboard tanpa mengklik setiap state secara manual:

Objek	Jumlah	Distribusi
Alert yang telah di-disposition	~600	55% false positive pada seluruh kategori reason, 25% tanpa tindakan, 8% duplikat, 12% di-escalate
Case	180	30 OPEN, 45 IN_INVESTIGATION, 20 PENDING_DECISION, 15 PENDING_APPROVAL, 10 RETURNED_FOR_REWORK, 55 APPROVED_CLOSED, 5 REOPENED
Item evidence	~700	Campuran capture dan unggahan, termasuk item yang digantikan dan item koreksi
Keputusan	70	Mencakup keempat jenis keputusan, termasuk dua rantai ditolak-lalu-disetujui
Draft report	22	12 APPROVED_INTERNAL, 6 PENDING_MLRO_APPROVAL, 4 RETURNED
Narrative	40	Termasuk 6 dengan flag grounding yang belum terselesaikan dan 3 fallback template

Objek	Jumlah	Distribusi
Upaya SoD yang ditolak	8	Sehingga dashboard tata kelola sudah terisi sejak hari pertama

Seluruh record yang di-seed diatribusikan kepada pengguna demo yang di-seed dengan timestamp yang realistis, dan setiap perubahan state yang di-seed menulis audit event yang asli melalui jalur service normal — **bukan** melalui penyisipan langsung ke database — sehingga audit trail bersifat autentik.

11.7 Kamus Data dan Reprodutibilitas

Deliverable	Isi
data_dictionary.md	Setiap field yang dibangkitkan: nama, tipe, nilai yang diizinkan, aturan pembangkitan, nullability, tingkat cacat
scenario_catalogue.md	Setiap skenario: pattern, konstruksi, parameter, reason code yang diharapkan, jumlah alert yang diharapkan
seeds.json	Seed utama beserta seed turunan per kohort
generation_report.json	Dihasilkan per eksekusi: jumlah per objek, jumlah cacat per jenis, jumlah label per pattern, versi generator, seed, waktu jam dinding
Verifikasi	T-GEN-01 menjalankan generator dua kali dengan seed yang sama dan menegaskan checksum yang identik untuk setiap file output
Penguncian versi	Versi generator dicatat dalam manifest batch dan karenanya melekat pada setiap objek hilir

12

12. Desain Keamanan dan Privasi

POIN UTAMA

- Delapan belas ancaman, masing-masing dengan kontrol dan test yang memverifikasinya. Kontrol tanpa test bukanlah kontrol.
- Satu sensitive-field policy dikonsumsi oleh serialisasi API, ekspor, redaksi log, dan penyusunan paket AI — sehingga keempatnya tidak dapat menyimpang satu sama lain.
- Ketidadaan mail client, transfer client, dan HTTP client eksternal apa pun selain adapter AI adalah yang membuat aturan larangan pengiriman bersifat struktural.
- Secret tidak pernah ikut dicadangkan bersama data, dan pemindai secret memblokir build.

12.1 Matriks Ancaman (proporsional untuk MVP akademik internal)

Eksibit 11 — Delapan belas ancaman, masing-masing dengan kontrol dan uji yang memverifikasinya

#	Ancaman	Kemungkinan	Dampak	Kontrol	Verifikasi
T-01	Pengguna bertindak melampaui perannya melalui API	Sedang	Tinggi	Otorisasi deny-by-default; aturan yang dideklarasikan per route; asersi saat startup untuk route yang tidak dideklarasikan	Uji matriks role × endpoint (\$15.5)
T-02	Seorang maker menyetujui submission-nya sendiri	Sedang	Tinggi	Pemeriksaan per item terhadap maker yang tersimpan; constraint CHECK database sebagai lapisan kedua	T-MC-01...10; SM-08
T-03	Record audit diubah untuk menyembunyikan suatu tindakan	Rendah	Sangat tinggi	Trigger append-only + role INSERT/SELECT-saja	T-AUD-05 mencoba UPDATE dan DELETE dan mengharapkan kegagalan

#	Ancaman	Kemungkinan	Dampak	Kontrol	Verifikasi
T-04	Evidence dihapus atau ditukar	Rendah	Tinggi	Tidak ada endpoint delete; grant DB menolak DELETE; kebijakan MinIO menolak delete; key content-addressed	T-EVD-04; uji verifikasi ulang hash
T-05	Deteksi atau suatu cacat memutasi data transaksi	Rendah	Sangat tinggi	Role <code>fcip_detection</code> hanya memiliki SELECT; tidak ada endpoint yang memutasi	T-SEC-PRIV-01 mencoba sebuah UPDATE dan mengharapkan error hak akses
T-06	Unggahan file berbahaya (skrip, ukuran berlebih, zip bomb)	Sedang	Sedang	Allow-list MIME + pemeriksaan tanda tangan magic-byte + batas ukuran + tanpa eksekusi di sisi server + Content-Disposition: attachment + object storage terpisah	T-SEC-UP-01...04
T-07	SQL injection melalui filter atau parameter rule	Sedang	Tinggi	Hanya query terparametrisasi; binding parameter bertipe; tanpa interpolasi string; tanpa SQL dari pengguna di mana pun	Analisis statis di CI; fuzz T-SEC-SQLI atas seluruh filter
T-08	XSS melalui catatan case,	Sedang	Sedang	Escaping React secara	T-SEC-XSS-01...03

#	Ancaman	Kemungkinan	Dampak	Kontrol	Verifikasi
	justifikasi atau teks narrative			default; tanpa dangerouslySetInnerHTML; sanitasi di sisi server pada rich text yang tersimpan; CSP ketat	
T-09	Secret ter-commit ke repository	Sedang	Tinggi	.env dikecualikan; .env.example di-commit; pemindai secret di CI memblokir build	Job CI secret-scan
T-10	Data pribadi nyata dimasukkan "demi realisme"	Rendah	Sangat tinggi	Deklarasi sintetis diwajibkan saat pemuatan list; konfirmasi unggahan; pemindaian PII di CI; review gate (NFR-15)	Job CI pii-scan; checklist gate
T-11	Pencurian token atau session fixation	Rendah	Sedang	Access token berumur pendek, refresh token yang dirotasi, timeout idle + absolut, cookie HttpOnly/Secure/SameSite=Strict untuk refresh	T-SEC-AUTH-01...05
T-12	Login brute-force	Sedang	Sedang	Penguncian setelah 5 kegagalan, pembatasan laju di gateway,	T-SEC-AUTH-06

#	Ancaman	Kemungkinan	Dampak	Kontrol	Verifikasi
				hashing argon2id	
T-13	Paparan data sensitif di dalam log	Sedang	Sedang	Redaksi log terpusat atas field sensitive_field_policy; body request tidak pernah di-log untuk route autentikasi	T-SEC-LOG-01 menelusuri log untuk identifier sintetis yang diketahui
T-14	Enumerasi entity melalui pencarian atau ID	Rendah	Rendah	ID yang opak; pencocokan hanya pada 4 digit terakhir nomor account; pencarian yang diaudit; pembatasan laju	T-SEC-ENUM-01
T-15	Dependensi yang rentan	Sedang	Sedang	pip-audit dan npm audit di CI; lockfile yang dikunci; jalur upgrade yang terdokumentasi	Job CI dependency-scan
T-16	Kehilangan data (kegagalan disk, migration yang buruk)	Rendah	Tinggi	Backup setiap malam, restore yang teruji, migration maju-saja dengan skrip rollback untuk setiap migration	Uji restore NFR-09
T-17	Egress tanpa izin (report	Rendah	Sangat tinggi	Tanpa transport surel, tanpa	Uji jaringan §12.9

#	Ancaman	Kemungkinan	Dampak	Kontrol	Verifikasi
	keluar dari platform)			klien eksternal, kebijakan jaringan menolak egress kecuali host AI opsional	
T-18	Penyedia AI menerima lebih dari paket case	Sedang	Tinggi	Paket dirakit hanya dari query mencakupan case; disimpan verbatim; pemeriksaan referensi sumber secara otomatis	T-AI-02

12.2 Autentikasi

Kontrol	Desain
Penyimpanan password	argon2id, salt per pengguna, parameter dicatat agar dapat ditingkatkan di kemudian hari
Kebijakan	Minimum 12 karakter, diperiksa terhadap daftar password umum; tanpa rotasi paksa
Token	Access JWT, masa berlaku 15 menit, sub, roles, sid, iat, exp; refresh token dirotasi saat digunakan, disimpan HttpOnly+Secure+SameSite=Strict
Sesi	Timeout idle 30 menit; timeout absolut 8 jam; record sesi di sisi server memungkinkan pencabutan
Penguncian	5 kegagalan berturut-turut → kunci 15 menit, diaudit
MFA	Di luar lingkup MVP; didokumentasikan sebagai langkah penguatan produksi yang pertama

12.3 Otorisasi dan Hak Akses Minimum

Lapisan	Kontrol
Aplikasi	authorize(principal, action, object); deny-by-default; asersi saat startup bahwa

Lapisan	Kontrol
	setiap route mendeklarasikan sebuah aturan
Tingkat objek	Akses ke case dan evidence memerlukan keterlibatan atau role yang lebih tinggi
Database	Dua role aplikasi ditambah satu role audit, dengan grant pada tingkat tabel dan kolom (§6.7)
Object store	Kredensial aplikasi memiliki PutObject dan GetObject; tanpa DeleteObject
Antarmuka admin	Jika ADR-002 (Django) diambil, situs admin dibatasi hanya pada model data referensi dan tidak pernah memaparkan model case, alert, evidence, keputusan atau audit
Konfigurasi	Konfigurasi yang relevan terhadap risiko tidak dapat diubah oleh role Administrator; hal tersebut diarahkan ke maker-checker (FR-1106)

12.4 Perlindungan Data dan Masking

Kontrol	Desain
Kebijakan tunggal	Satu konfigurasi <code>sensitive_field_policy</code> mencantumkan field, fungsi masking-nya dan role yang berhak melihatnya tanpa masking. Dikonsumsi oleh serialisasi API, ekspor, redaksi log dan perakitan paket AI (menyelesaikan CF-06)
Ter-masking secara default	<code>national_id_reference</code> (disimpan sebagai hash ber-salt; hanya token tampilan 4 digit terakhir yang pernah dirender), nomor account lengkap (4 terakhir), nomor telepon lengkap (kode negara + 3 terakhir), email lengkap (karakter pertama + domain), alamat lengkap (kota + provinsi)
Pembukaan masking	Tindakan eksplisit dan diaudit yang tersedia bagi Investigator, Senior Investigator dan MLRO (FR-709)
Enkripsi saat transit	TLS 1.2+ di gateway; lalu lintas internal pada jaringan Docker privat
Enkripsi saat tersimpan	Enkripsi seluruh disk jika host mendukungnya; enkripsi sisi server MinIO diaktifkan; enkripsi kolom pada tingkat database tidak digunakan pada MVP (trade-off terdokumentasi: hal itu akan menggagalkan indexing yang dibutuhkan oleh query deteksi)

Kontrol	Desain
Hashing	<code>national_id_reference</code> di-hash dengan salt per deployment yang disimpan dalam secret, sehingga ID sintetis yang sama teresolusi secara konsisten untuk entity resolution tanpa menyimpan nilainya

12.5 Validasi Input dan Unggahan Aman

Kontrol	Desain
Validasi schema	Model Pydantic pada setiap body request; field yang tidak dikenal ditolak
Parameter query	Bernama, bertipe dan terenumerasi; tidak menerima bahasa query bentuk bebas
SQL	Hanya binding parameter; template rule menerima parameter bertipe, tidak pernah string yang diinterpolasi
Allow-list unggahan	<code>application/pdf</code> , <code>image/png</code> , <code>image/jpeg</code> , <code>text/csv</code> , <code>text/plain</code> , dan tipe MIME DOCX/XLSX
Pemeriksaan tanda tangan	Verifikasi magic-byte terhadap tipe MIME yang dideklarasikan; ketidakcocokan ditolak dan tidak disimpan
Batas ukuran	20 MB per file, 200 MB per case (dapat dikonfigurasi)
Isolasi penyimpanan	Objek disimpan di MinIO dengan key content-addressed dan disajikan dengan <code>Content-Disposition: attachment</code> dan <code>X-Content-Type-Options: nosniff</code> ; tidak pernah disajikan dari origin aplikasi sebagai konten aktif
Keamanan teks	Catatan case, justifikasi dan suntingan narrative disimpan sebagai teks biasa; rendering melakukan escaping secara default

12.6 Logging yang Aman

Kontrol	Desain
Format	JSON terstruktur, satu event per baris, dengan <code>correlation_id</code> , <code>actor_id</code> , <code>route</code> , <code>status</code> dan latensi
Redaksi	Formatter terpusat menerapkan <code>sensitive_field_policy</code> ; body route autentikasi tidak pernah di-log
Pemisahan	Log aplikasi bersifat operasional; audit trail adalah catatan resmi dan berada di dalam database

Kontrol	Desain
Retensi	Log dirotasi pada 100 MB, 10 file dipertahankan; audit event tidak pernah dirotasi

12.7 Manajemen Secret

Kontrol	Desain
Sumber	Variabel lingkungan yang dimuat dari <code>.env</code> , dikecualikan dari version control, <code>chmod 600</code> ; <code>.env.example</code> di-commit dengan nilai placeholder
Cakupan	Password database, kredensial MinIO, kunci penandatanganan JWT, salt hashing ID, kunci penyedia AI
Rotasi	Prosedur terdokumentasi; rotasi kunci JWT didukung melalui key ID pada header token
Dilarang	Secret di dalam kode, di dalam migration, di dalam seed data, di dalam log, di dalam pesan error, di dalam database, atau di dalam file ter-commit mana pun
Penegakan	<code>gitleaks</code> (atau yang setara) di CI memblokir build ketika sebuah secret terdeteksi

12.8 Backup dan Pemulihan

Aspek	Desain
Cakupan	Dump logis PostgreSQL; mirror bucket MinIO; definisi konfigurasi dan seed. Secret tidak pernah disertakan dalam backup data (menyelesaikan CF-08)
Jadwal	Setiap malam pukul 02:00 Asia/Jakarta; 7 harian + 4 mingguan dipertahankan
Integritas	Setiap backup mencatat checksum dan ukurannya; backup yang gagal muncul pada tampilan operasi
Restore	Runbook terdokumentasi; restore penuh ke lingkungan bersih dijalankan dan dicatat sebelum Minggu 15 (NFR-09, FR-1109)
RPO/RTO (kelas demo)	RPO 24 jam; RTO 4 jam. Dinyatakan secara eksplisit sebagai kelas demonstrasi, bukan komitmen produksi

12.9 Kontrol Jaringan dan Egress

Kontrol	Desain
Port yang dipublikasikan	Hanya gateway (443, dan 80 yang mengarahkan ulang)
Jaringan internal	fcip-app (layanan aplikasi) dan fcip-data (PostgreSQL, Redis, MinIO); jaringan data tidak memiliki egress
Allow-list egress	Hanya host penyedia AI, hanya dari api-investigation, dan dapat dinonaktifkan melalui konfigurasi
Absen secara konstruksi	Tanpa klien SMTP, tanpa klien HTTP eksternal selain adapter penyedia AI, tanpa klien SFTP/FTP, tanpa SDK cloud. Inilah yang membuat NG-02 bersifat struktural dan bukan prosedural
Verifikasi	T-SEC-EGRESS-01 menegaskan bahwa request ke host eksternal sembarang dari api-detection gagal, dan bahwa inventaris dependensi tidak memuat pustaka surel atau transfer

12.10 Higiene Dependensi dan Rantai Pasok

Kontrol	Desain
Penguncian	requirements.txt beserta hash-nya; package-lock.json di-commit
Pemindaian	pip-audit dan npm audit --audit-level=high di CI; temuan berseveritas tinggi menggagalkan build
Base image	Dikunci berdasarkan digest, bukan berdasarkan tag yang mengambang
Review	Penambahan dependensi memerlukan catatan pada pull request yang menjelaskan alasan kebutuhannya

13

13. Desain Narrative AI

POIN UTAMA

- Model menerima paket yang disusun hanya dari kueri berlingkup case, disimpan apa adanya, dan digunakan kembali saat review alih-alih dibangkitkan ulang.
- Sebuah grounding checker mengekstrak setiap entity, jumlah, tanggal, dan referensi dari draft lalu membandingkannya dengan paket tersebut. Apa pun yang tidak cocok memblokir persetujuan sampai seorang manusia menyelesaikannya.
- Evidence yang hilang menghasilkan daftar gap terstruktur dan tidak menghasilkan narrative sama sekali. Penolakan adalah hasil yang dirancang, bukan error.
- Ketika penyedia tidak tersedia, draft template deterministik dihasilkan dan diberi label jelas sebagai demikian. Ia tidak pernah disajikan sebagai narrative AI.

13.1 Paket Input (grounded, mencakupan case)

Dirakit oleh C-20 hanya dari query mencakupan case. Setiap elemen membawa sebuah `source_ref` berbentuk `{object_type, object_id}`.

```
{
  "package_version": 1,
  "case": {"source_ref": {"type": "CASE", "id": "CAS-000318"}, "title": "...", "type": "AML_REVIEW", "state":
"PENDING_DECISION", "created_at": "..."},
  "subjects": [
    {"source_ref": {"type": "ENTITY", "id": "ENT-7K2M9QX4B1CD"},
      "entity_type": "INDIVIDUAL", "display_name": "Sari W*****",
      "resolution": {"confidence": 0.93, "mode": "MANUAL", "source_record_count": 2},
      "risk": {"band": "MEDIUM", "score": 61, "as_at": "2026-04-01", "model_version": "risk_individual_v2",
        "top_factors": [{"code": "COUNTERPARTY_RISK_EXPOSURE", "contribution": 14}, {"code": "VELOCITY_BAND",
"contribution": 11}]}},
    ],
    "alerts": [
      {"source_ref": {"type": "ALERT", "id": "ALR-20260412-0001A7"},
        "rule": {"id": "RUL-0007", "version": 3, "pattern_code": "P02_STRUCTURING", "reason_code": "RC-STRUCT-01",
          "description": "Observes multiple transactions clustered below the reporting threshold..."},
        "window": {"start": "2026-04-05", "end": "2026-04-12"},
        "factors": [{"code": "TXN_COUNT_IN_BAND", "observed": "5", "threshold": "3"},
          {"code": "AGGREGATE_AMOUNT", "observed": "2245000000.00", "threshold": "500000000.00"}],
        "transaction_summary": {"count": 5, "total": {"amount": "2245000000.00", "currency": "IDR"},
          "date_range": ["2026-04-06", "2026-04-11"], "distinct_counterparties": 1}},
    ],
    "screening": [
      {"source_ref": {"type": "SCREENING_RESULT", "id": "SCR-20260405-000117"},
        "state": "DISMISSED_NO_MATCH", "list_type": "PEP_SYNTHETIC", "list_version": "v4",
        "combined_score": 0.887, "discriminating_attribute": "date_of_birth",
        "rationale": "Dates of birth differ by 14 years."}
    ],
    "signals": {"anomaly_score": 0.71, "graph": [{"code": "SHARED_DEVICE_ENTITY_COUNT", "value": 3}],
      "caption": "Relationships are investigation leads, not proof of wrongdoing."},
    "evidence": [
      {"source_ref": {"type": "EVIDENCE", "id": "EVD-000912"}, "evidence_type": "SYSTEM_CAPTURE", "view_type": "TIMELINE",
        "description": "Outgoing transfers above IDR 300m, 1-30 April, showing five clustered payments to one counterparty."}
    ],
    "investigator_findings": {"source_ref": {"type": "CASE_NOTE", "id": "NOT-004411"}, "text": "..."},
    "data_quality": {"banner_active": true, "detail": "12% of this entity's transactions have a missing counterparty
identifier."},
    "constraints": {
      "no_facts_beyond_this_package": true,
      "screening_vocabulary": ["POTENTIAL_MATCH", "POSSIBLE_MATCH", "CONFIRMED_MATCH", "DISMISSED_NO_MATCH"],
      "prohibited_conclusions": ["criminality", "guilt", "confirmed money laundering", "confirmed fraud"],
      "output_sections": ["Subject", "What was observed", "Why it was alerted", "What was checked",
        "Evidence relied upon", "Gaps and limitations", "Recommended next step for human consideration"]
    }
  }
}
```

Aturan perakitan: di-masking sesuai `sensitive_field_policy`; tanpa national ID tanpa masking maupun nomor account lengkap (AI-G11); batas ukuran dengan seleksi deterministik (seluruh alert dan hasil screening, kemudian

N ringkasan transaksi terbaru per alert) beserta daftar omitted yang eksplisit; disimpan verbatim bersama request dan digunakan kembali pada saat review alih-alih dibangkitkan ulang (AI-G14).

13.2 Konstruksi Prompt

Elemen	Isi
Instruksi sistem	Peran: menyusun draft narrative investigasi internal untuk review manusia. Aturan: gunakan hanya paket yang disediakan; kutip sebuah <code>source_ref</code> untuk setiap pernyataan faktual; jangan pernah menyatakan kriminalitas atau suatu kesimpulan; gunakan hanya keempat kata <code>state screening</code> ; bagian “Gaps and limitations” bersifat wajib dan tidak boleh kosong; jika suatu bagian tidak dapat didukung, nyatakan hal itu alih-alih menyimpulkan.
Konten pengguna	JSON paket tersebut
Kontrak output	JSON dengan <code>sections[{name, paragraphs[{text, citations[source_ref]}]}]</code> — output terstruktur membuat pemeriksaan sitasi bersifat mekanis alih-alih menjadi latihan parsing teks
Parameter	Temperature rendah (≤ 0.2), seed tetap jika penyedia mendukungnya, max token yang dibatasi; semuanya disimpan bersama request

13.3 Pemeriksaan Grounding (C-21)

Langkah	Desain
1. Indeks paket	Bangun lookup atas setiap ID entity dan display name, nominal (dinormalisasi ke desimal kanonik dan ke bentuk kata), tanggal (berbagai format), referensi account/transaksi/counterparty, nama rule, kode pattern dan state screening yang ada di dalam paket
2. Ekstraksi dari narrative	Entity bernama, nominal uang, tanggal, identifier dan nama counterparty, per paragraf
3. Bandingkan	Setiap item yang diekstraksi harus ada di dalam indeks, atau tercakup oleh daftar parafrase yang diizinkan (mis. “lima transfer” ketika paket menyatakan <code>count: 5</code>)
4. Pemeriksaan sitasi	Setiap paragraf yang memuat pernyataan faktual harus membawa ≥ 1 <code>source_ref</code> yang teresolusi ke sebuah elemen paket

Langkah	Desain
5. Pemeriksaan kosakata	Tanpa istilah kesimpulan yang dilarang; referensi screening hanya menggunakan keempat kata state
6. Flag	Kegagalan menjadi <code>narrative_flag(flag_id, narrative_id, paragraph_index, extracted_value, flag_type, state)</code>
7. Blokir	Endpoint persetujuan menolak selama masih ada flag yang OPEN (AI-G08)
8. Selesaikan	Manusia menyelesaikan setiap flag sebagai <code>ACCEPTED_PARAPHRASE</code> atau dengan menyunting teksnya; resolusi dan penyelesaiannya disimpan

Jenis flag: `UNSUPPORTED_ENTITY`, `UNSUPPORTED_AMOUNT`, `UNSUPPORTED_DATE`, `UNSUPPORTED_REFERENCE`, `MISSING_CITATION`, `PROHIBITED_CONCLUSION`, `NON_APPROVED_VOCABULARY`.

13.4 Perilaku Ketika Evidence Tidak Lengkap

Eksibit 12 — AI narrative: penolakan adalah hasil yang dirancang, dan persetujuan diblokir selama masih ada flag yang terbuka

```
graph TB
    R["Narrative requested"] --> C["Required inputs present?<br/>≥1 linked alert AND ≥1 evidence item"]
    C -->|No| G["Return structured gap list<br/>NO narrative produced<br/>Log AI_REQUEST_REFUSED"]
    C -->|Yes| P["Assemble package<br/>store verbatim"]
    P --> M["Provider available?"]
    M -->|No| T["TemplateProvider<br/>deterministic, labelled<br/>TEMPLATE_DRAFT"]
    M -->|Yes| L["LLM provider<br/>structured output"]
    L --> GC["Grounding check"]
    T --> GC
    GC --> F["Flags raised?"]
    F -->|Yes| RV["UNDER_HUMAN_REVIEW<br/>approval blocked<br/>until flags resolved"]
    F -->|No| RV2["UNDER_HUMAN_REVIEW<br/>approval available"]
    RV --> A["Human approval<br/>approver ≠ requester where<br/>requester is the case maker"]
    RV2 --> A
    A --> OK["APPROVED_INTO_CASE /<br/>EDITED_AND_APPROVED"]
    A --> NO["REJECTED_DISCARDED<br/>retained in AI usage log"]

    style G fill:#f8cecc
    style T fill:#fff2cc
```

Jalur penolakan mengembalikan, sebagai contoh:

```
{ "outcome": "REFUSED", "reason": "INSUFFICIENT_INPUTS",
  "gaps": [
    { "requirement": "EVIDENCE_ITEM", "message": "No evidence has been attached to this case.", "observed": 0, "required": 1 },
    { "requirement": "SCREENING_RESOLVED", "message": "One screening potential match on the subject is unresolved.",
      "unresolved": [ "SCR-20260405-000117" ] }
  ],
  "narrative": null }
```

13.5 AI Usage Log

`gov.ai_usage_log(usage_id, correlation_id, case_id, narrative_id, requested_by, requested_at, provider, model_id, model_version, parameters JSONB, package_hash, package_ref, prompt_text, response_text, latency_ms, outcome, fallback_used, fallback_reason, flags_raised, flags_resolved, reviewer_id, final_state)` — hanya dapat ditambah (append-only), dapat dicari berdasarkan case, user, versi model dan tanggal, dapat diekspor oleh Auditor dan MLRO. Kegagalan penulisan penyimpanan berarti narrative **tidak** ditampilkan: visibilitas tanpa record tidak diizinkan (FR-905 E1).

13.6 Template Fallback

Deterministik, tanpa prosa yang dihasilkan. Setiap bagian disusun dari field case dengan teks penghubung yang tetap; jika sebuah field tidak ada, template menuliskan baris “tidak dicatat” secara eksplisit alih-alih menghilangkan poin tersebut. Diberi label `TEMPLATE_DRAFT – NOT AI-GENERATED` di UI, dalam ekspor dan dalam log. Template mengikuti jalur review dan persetujuan yang identik, sehingga permukaan kontrolnya sama apa pun provider yang menghasilkan draft tersebut.

14

14. Observability dan Audit

POIN UTAMA

- Log bersifat operasional; audit trail adalah catatan resmi dan berada di dalam database, ditulis di dalam transaksi bisnis.
- Jika penulisan audit gagal, perubahan bisnis di-rollback. Kelengkapan dijamin oleh transaksi, bukan oleh disiplin.
- Tindakan yang ditolak diaudit sebelum respons error dikembalikan, sehingga percobaan menyetujui pekerjaan sendiri meninggalkan jejak, berhasil atau tidak.

14.1 Logging Terstruktur

Setiap baris log adalah objek JSON dengan envelope tetap:

```
{
  "ts": "2026-04-12T04:11:07.312Z",
  "level": "INFO",
  "service": "api-investigation",
  "correlation_id": "3f1c9a52-...",
  "actor_id": "USR-0142",
  "actor_role": "ROLE_TRIAGE",
  "route": "POST /api/v1/investigation/alerts/{id}/disposition",
  "object_type": "ALERT",
  "object_id": "ALR-20260412-0001A7",
  "status": 200,
  "latency_ms": 41,
  "event": "alert.disposed",
  "message": "Alert dispositioned"
}
```

Aturan	Rincian
Correlation	X-Correlation-Id dari gateway dilampirkan pada setiap baris, termasuk job worker (dipropagasikan melalui payload job)
Redaksi	Formatter terpusat menerapkan <code>sensitive_field_policy</code> ; body autentikasi tidak pernah dicatat dalam log
Level	DEBUG hanya untuk lokal; INFO untuk event bisnis; WARN untuk perilaku terdegradasi (graph basi, fallback provider); ERROR untuk kegagalan
Pemisahan	Log bersifat operasional. Audit trail adalah catatan resmi dan berada di dalam database (§14.2)

14.2 Desain Audit

Properti	Desain
Konten	Aktor, role, aksi, tipe objek dan ID, nilai sebelum, nilai sesudah, alasan, timestamp UTC, sesi, IP sumber, correlation ID, outcome (SUCCESS/DENIED) — himpunan “siapa / apa / kapan / mengapa / sebelum-sesudah / korelasi” yang diwajibkan oleh FRD
Transaksionalitas	Ditulis oleh C-27 di dalam transaksi bisnis; kegagalan penulisan audit me-rollback perubahan bisnis (ADR-004, CF-02)

Properti	Desain
Imutabilitas	Trigger BEFORE UPDATE OR DELETE memunculkan AUDIT_IMMUTABLE; role audit hanya memiliki INSERT dan SELECT
Coverage	Setiap transisi state dalam FRD §5, setiap persetujuan dan penolakan, setiap override, setiap ekspor, setiap perubahan konfigurasi, setiap request AI, setiap unmask, setiap pembacaan subject-access, dan setiap aksi yang ditolak
Aksi yang ditolak	Kegagalan otorisasi dan pelanggaran pemisahan tugas (segregation of duties) diaudit dengan outcome = DENIED sebelum respons error dikembalikan
Pencarian	Berdasarkan aktor, aksi, tipe/ID objek, correlation ID dan rentang tanggal; membaca dan mengeksport audit trail itu sendiri juga diaudit
Verifikasi	T-AUD-01 menelusuri setiap transisi dalam FRD §5 dan memastikan terdapat audit event yang sesuai (SM-09); T-AUD-05 memastikan UPDATE dan DELETE gagal

14.3 Metrik

Keluarga metrik	Contoh
Ingestion	Durasi batch, record per detik, rate quarantine, rate supresi, status rekonsiliasi
Detection	Durasi run, waktu evaluasi per rule, alert yang dibuat, alert yang disupresi, rule yang gagal atau timeout
Screening	Pihak yang di-screening, potential match yang dibuat, jumlah yang not-screenable
Graph	Durasi refresh, jumlah node dan edge, usia refresh
API	Rate request, latensi p50/p95 dan error rate per route
Queue	Kedalaman, usia job tertua, jumlah job yang gagal
Bisnis	Alert terbuka berdasarkan state dan prioritas, pelanggaran SLA, case berdasarkan state, kedalaman antrean persetujuan
AI	Request, penolakan, fallback, flag yang dimunculkan, flag yang diselesaikan, latensi median

Diekspos di `/ops/metrics` dalam format teks Prometheus; Grafana bersifat opsional dan, ketika tidak tersedia, layar operasi menampilkan angka yang sama.

14.4 Alert Demonstrasi (operasional, bukan alert financial crime)

Kondisi	Severity	Tempat kemunculannya
Batch ingestion gagal	High	Tampilan operasi + notifikasi Data Ops
Ketidaksesuaian rekonsiliasi	High	Tampilan operasi
Detection run <code>FAILED</code> atau <code>COMPLETED_WITH_ERRORS</code>	High / Medium	Tampilan operasi
Refresh graph lebih lama dari 24 jam	Medium	Banner staleness pada setiap permukaan graph
Kedalaman queue di atas threshold atau job lebih lama dari 30 menit	Medium	Tampilan operasi
Provider AI tidak tersedia	Low	Log peringatan + label <code>TEMPLATE_DRAFT</code> pada draft yang terdampak
Backup gagal	High	Tampilan operasi
Komponen belum pernah dijalankan	Informational	Tampilan operasi menampilkan “never run”, tidak pernah “healthy” (FR-1110)

14.5 Health dan Readiness

`/ops/health` mengembalikan liveness proses. `/ops/ready` memeriksa konektivitas database, konektivitas Redis, keterjangkauan MinIO dan status migration yang tertunda; layanan yang tidak ready tidak dirutekan oleh gateway.

15

15. Strategi Pengujian

POIN UTAMA

- Setiap FR dipetakan ke minimal satu test, dan sebuah job CI menggagalkan build jika kebutuhan wajib tidak memiliki satu pun.
- Kebutuhan guardrail diuji secara negatif: test menegaskan bahwa platform menolak.
- Test deteksi dijalankan terhadap keluaran generator berlabel, sehingga menempuh jalur data yang sama dengan demonstrasi, bukan fixture buatan tangan.

15.1 Prinsip

1. Setiap FR dipetakan ke ≥ 1 test ID; sebuah kebutuhan tanpa pengujian belum selesai (SM-11).
2. Kebutuhan guardrail diuji secara **negatif** — pengujian memastikan platform menolak.
3. Pengujian detection menggunakan output generator berlabel, bukan baris buatan tangan sekali pakai, sehingga pengujian menjalankan jalur data yang sama dengan demonstrasi.
4. Pengujian dijalankan pada setiap push; suite lengkap ditambah performa dijalankan setiap malam.

15.2 Level Pengujian dan Target Coverage

Level	Alat	Ruang lingkup	Target
Unit	pytest	Rule validasi, scoring ER, komputasi faktor risiko, feature builder, dedupe key, formula prioritas, normalisasi screening, ekstraksi grounding	$\geq 80\%$ line coverage pada detection/, risk/, screening/, iam/, audit/
Komponen/API	pytest + httpx	Setiap endpoint: happy path, kegagalan validasi, kegagalan otorisasi, kegagalan state machine	100% endpoint
Contract	schemathesis + fixture bersama	Kontrak Integrasi §17, dijalankan oleh masing-masing group terhadap fixture group lainnya	100% antarmuka A↔B
Integrasi	pytest + docker compose	Ingestion → ER → feature → detection → alert → outcome feed → metrik	Seluruh tahap pipeline
End-to-end	Playwright	Skenario UAT dalam FRD §14.4	15/15 skenario

Level	Alat	Ruang lingkup	Target
RBAC	pengujian matriks yang digenerate	9 role × setiap endpoint × state objek representatif	Nol izin yang tidak diharapkan
Maker-checker	pytest	Setiap workflow dalam FRD §10.3, termasuk user multi-role	Nol kemungkinan persetujuan diri sendiri
Reproduktibilitas	pytest	Detection run ganda; generator run ganda	Hasil identik byte demi byte
Faktualitas	pytest	FT-01...FT-08	Nol fakta tanpa dukungan yang lolos persetujuan
Kualitas data	pytest	Setiap tipe defect yang diinjeksikan dari §11.4	Setiap defect ditangani sesuai spesifikasi
Keamanan	pytest + scanner CI	T-01...T-18 dari §12.1	Seluruh kontrol terverifikasi
Performa	locust / pytest-benchmark	NFR-01...NFR-05	Seluruh target terpenuhi pada host referensi
UAT	Manual, terskrip	FRD §14.4	Persetujuan mentor dan dosen pembimbing

15.3 Desain Pengujian Detection

Untuk setiap pattern Pnn:

Pengujian	Asersi
T-DET-Pnn-01 positif	Setiap label INJECTED_POSITIVE untuk pattern tersebut menghasilkan alert dengan reason_code yang diharapkan
T-DET-Pnn-02 negatif	Tidak ada kemiripan EDGE_CASE yang menghasilkan alert pada parameter default yang disetujui, atau, jika secara sah ada, kemiripan tersebut tercantum dalam himpunan expected-false-positive yang terdokumentasi
T-DET-Pnn-03 batas	Kasus tepat pada threshold berperilaku sesuai dokumentasi, dalam arah yang terdokumentasi
T-DET-Pnn-04 penjelasan	Alert membawa himpunan faktor lengkap beserta nilai teramati dan nilai threshold serta ≥ 1 transaksi pemicu

Pengujian	Aseri
T-DET-Pnn-05 kecukupan	Dengan riwayat yang tidak memadai, cabang relatif tidak dievaluasi dan PARTIAL_WINDOW dicatat
T-DET-CONTROL-01	No! alert di seluruh control cohort CONTROL_CLEAN (SM-03)
T-DET-RECALL-01	Recall $\geq 90\%$ per pattern yang diimplementasikan terhadap label INJECTED_POSITIVE (SM-05)
T-DET-REPRO-01	Dua run atas data yang dibekukan menghasilkan dedupe key, faktor dan himpunan transaksi yang identik (SM-01)
T-DET-DEDUPE-01...05	Supresi menaikkan hitungan alih-alih menduplikasi; supresi tidak pernah mengubah state lifecycle

15.4 Pengujian Contract

Masing-masing group menerbitkan satu fixture pack; masing-masing group menjalankan pack milik group lain terhadap implementasinya sendiri.

Fixture pack	Isi	Dijalankan oleh
fixtures/alerts.json	12 alert, satu per pattern, dengan payload penjelasan lengkap termasuk edge case (partial window, evaluasi ulang yang terlambat, kemunculan yang disupresi, DEDUPE_UNAVAILABLE)	B, terhadap schema A
fixtures/outcomes.json	20 record outcome yang mencakup setiap disposition dan tipe keputusan, termasuk baris outcome yang tidak diketahui	A, terhadap feed B
fixtures/screening.json	8 hasil di keempat state, termasuk flag nama berfrekuensi tinggi dan pihak yang not-screenable	Keduanya
fixtures/entities.json	2 entity yang di-merge dengan evidence resolusi, 1 yang tidak di-merge dengan lineage, 1 risiko INSUFFICIENT_DATA	B, terhadap A
fixtures/graph.json	Sebuah traversal yang dipotong, sebuah edge LOW_SPECIFICITY, sebuah versi graph yang basi	B, terhadap A

Fixture pack	Isi	Dijalankan oleh
fixtures/audit.json	Satu rantai korelasi penuh dari batch hingga laporan yang disetujui	Keduanya

Kegagalan contract test memblokir gate integrasi (§17.4).

15.5 Matriks Pengujian RBAC dan Maker-Checker

Digenerate dari matriks FRD §4.2, sehingga pengujian dan spesifikasi tidak dapat menyimpang:

Dimensi	Nilai
Role	9
User multi-role	4 kombinasi yang bertentangan dari FRD §10.4
Endpoint	Setiap route
State objek	State representatif per tipe objek
Asersi	Ekspektasi allow/deny; pada deny, kode error yang benar dan sebuah audit event DENIED; pada route maker-checker, SEGREGATION_OF_DUTIES_VIOLATION untuk maker terlepas dari kombinasi role

T-MC-07 adalah pengujian utama untuk SM-08: seorang user yang memegang `ROLE_INVESTIGATOR` sekaligus `ROLE_SENIOR_INVESTIGATOR` mengirimkan sebuah keputusan dan ditolak untuk menyetujuinya.

15.6 Pengujian Performa Demo

Pengujian	Target	Metode
T-PERF-01	Alert queue, detail alert, detail case, Entity 360 < 3 s pada 20 user bersamaan	locust terhadap profil full
T-PERF-02	Timeline enam bulan < 5 s	Request yang diukur waktunya
T-PERF-03	Graph kedalaman 3, cap 300 < 5 s	Request yang diukur waktunya
T-PERF-04	Detection run penuh atas 420k transaksi < 30 min	Batch yang diukur waktunya
T-PERF-05	Ingestion 100k record < 10 min	Batch yang diukur waktunya

15.7 Ketertelusuran

Build memelihara `traceability.csv` dengan kolom `objective`, `fr_id`, `test_ids`, `owner`, `status`, yang digenerate dari marker pengujian (`@pytest.mark.fr("FR-604")`) sehingga tidak dapat menjadi usang. Sebuah job CI menggagalkan build jika ada FR bertanda `M` yang tidak memiliki pengujian terkait.

16

16. CI/CD, Migration, Konfigurasi dan Rollback

POIN UTAMA

- Enam job guardrail dapat memblokir merge, termasuk pemindaian secret, pola data nyata, pustaka transfer keluar, otorisasi route yang tidak dideklarasikan, dan kosakata yang bernada menuduh.
- Constraint guardrail hidup di dalam migration, sehingga lingkungan baru aman sejak dibangun, bukan setelah langkah setup yang terlupakan seseorang.
- Rollback tidak pernah menghapus alert, case, evidence, keputusan, atau audit event. Pemulihan selalu maju ke depan, melalui versi baru atau record baru.

16.1 Branching dan Review

Aturan	Rincian
Branch	<code>main</code> (selalu dapat di-deploy), feature branch berumur pendek <code>feat/<group>-<ticket></code>
Pull request	Wajib; minimal satu reviewer dari group lain untuk apa pun yang menyentuh kontrak §17
Commit	Conventional commits; setiap commit merujuk pada sebuah FR ID
Proteksi	<code>main</code> memerlukan pipeline hijau dan tidak ada komentar review yang belum terselesaikan

16.2 Pipeline

Eksibit 13 — CI pipeline: enam job guardrail dapat memblokir sebuah merge

```
graph LR
  A["Push / PR"] --> B["Lint & format<br>ruff, black, eslint, prettier"]
  B --> C["Type check<br>mypy, tsc"]
  C --> D["Secret scan<br>gitleaks"]
  D --> E["PII / real-data scan<br>custom rules (NFR-15)"]
  E --> F["Unit tests<br>+ coverage gate"]
  F --> G["Build images"]
  G --> H["Migrations on a clean DB<br>+ seed"]
  H --> I["API & contract tests"]
  I --> J["RBAC & maker-checker matrix"]
  J --> K["Integration pipeline test"]
  K --> L["E2E (Playwright)"]
  L --> M["Traceability check<br>every M-priority FR has a test"]
  M --> N["Publish images<br>tag = commit SHA"]
  N --> O["Deploy to integration"]
  style D fill:#f8cecc
  style E fill:#f8cecc
  style M fill:#d5e8d4
```

Setiap malam juga dijalankan: generasi profil full, reproduktibilitas detection, pengujian recall dan control cohort, pengujian performa, dan pemindaian dependensi.

16.3 Job Guardrail (memblokir)

Job	Menggagalkan build ketika
secret-scan	Ada string berbentuk kredensial yang di-commit
pii-scan	Ada file yang cocok dengan pola identifier nyata di luar rentang sintetis yang dideklarasikan generator, atau sebuah file data tidak memiliki deklarasi sintetis
egress-inventory	Inventaris dependensi memuat pustaka mail, FTP/SFTP atau cloud-transfer (NG-02)
route-authorisation	Ada route yang tidak memiliki deklarasi otorisasi
traceability	Ada FR berprioritas m yang tidak memiliki pengujian
language-scan	Teks UI, enumerasi API, template laporan atau template narrative memuat "match", "hit", "fraudster", "launderer" tanpa kualifikasi (NFR-16)

16.4 Migration dan Data Seed

Aspek	Desain
Alat	Alembic, hanya maju, satu migration per pull request
Penamaan	<code><timestamp>_<fr_id>_<description>.py</code>
Rollback	Setiap migration menyertakan <code>downgrade()</code> yang telah diuji; perubahan destruktif memerlukan dua langkah yang mempertahankan data (add → backfill → switch → drop pada rilis berikutnya)
Constraint	Constraint guardrail (trigger imutabilitas audit, checker_id <> maker_id, deferred constraint faktor alert, pemeriksaan state screening, pemberian role) berada di dalam migration, tidak pernah di kode setup aplikasi, sehingga lingkungan baru aman secara konstruksi
Lapisan seed	(1) data referensi (negara, channel, band MCC, kode validasi, kategori reason, kalender hari libur, target SLA); (2) role dan user demo; (3) definisi rule, risk, anomaly dan screening pada versi 1; (4) dataset yang digenerate berdasarkan profil
Idempotency	Seed dapat dijalankan ulang; setiap lapisan dijaga oleh penanda versi

16.5 Manajemen Konfigurasi

Kelas	Tempat penyimpanan	Yang mengubah	Berlaku
Deployment (port, host, ukuran pool)	Variabel environment	Administrator, saat deploy	Saat restart
Secret	.env, tidak pernah di-commit	Administrator	Saat restart
Data referensi	Database, berversi	Administrator	Segera, hanya maju
Operasional (target SLA, rule queue, cap, jam kerja)	Database, berversi	Administrator	Segera, hanya maju
Relevan terhadap risiko (threshold, bobot, parameter screening, daftar geografi)	Database, berversi	Analyst mengusulkan, MLRO menyetujui	Hanya maju; objek historis mempertahankan versinya

Setiap objek bisnis mencatat versi konfigurasi saat objek tersebut dibuat, sehingga tidak ada yang ditafsirkan ulang secara retroaktif (FR-1106).

16.6 Versioning dan Rilis

Artefak	Skema
Aplikasi	Semantik MAJOR.MINOR.PATCH; image diberi tag dengan commit SHA dan tag rilis
API	Versi path v1; hanya penambahan di dalam satu versi
Kontrak integrasi	contract_version bilangan bulat, dinaikkan hanya melalui kesepakatan bersama (§17)
Definisi rule / model / screening	Versi monotonik independen dengan definition_hash
Generator	Versi dicatat dalam setiap manifest batch
Schema database	Revisi Alembic dicatat dan diekspos pada /ops/ready

16.7 Rollback

Skenario	Prosedur
Rilis aplikasi yang buruk	Deploy ulang tag image sebelumnya; tidak ada perubahan schema yang terlibat karena migration dipisahkan dari feature toggle
Migration yang buruk	Jalankan downgrade() yang telah diuji; jika destruktif terhadap data, pulihkan dari backup malam hari dan jalankan ulang ingestion (idempoten, sehingga tidak ada duplikat)

Skenario	Prosedur
Aktivasi rule yang buruk	MLRO menangguhkan rule tersebut (FR-305); alert yang sudah dihasilkan tetap disimpan dan tetap dapat dikerjakan — tidak pernah dihapus
Versi model risiko yang buruk	Setujui pengembalian ke definisi sebelumnya sebagai sebuah versi baru; penilaian historis tidak tersentuh
Perubahan konfigurasi yang buruk	Kembalikan ke versi konfigurasi sebelumnya; objek mempertahankan versi saat objek tersebut dibuat
Batch hasil ingestion yang rusak	Proses ulang dengan batch ID baru dan pratinjau dampak (FR-107); alert dan case sebelumnya dipertahankan dan diberi tanda

Aturan yang mengatur semua ini: rollback tidak pernah menghapus alert, case, evidence item, keputusan atau audit event. Pemulihan selalu bergerak maju, melalui versi baru atau record baru.

17

17. Kontrak Integrasi yang Harus Disetujui pada Minggu 4

POIN UTAMA

- Inilah gate Minggu 4 yang bersifat wajib. Identifier, state, interface, event, autentikasi, error, dan fixture dibekukan di sini, dengan checklist tanda tangan tiga belas butir.
- Setiap group menjalankan paket fixture group lain di dalam pipeline-nya sendiri. Kegagalan kontrak memblokir gate, bukan muncul saat integrasi.
- Perubahan yang merusak menaikkan versi kontrak dan memerlukan kedua group lead beserta mentor. Tidak ada apa pun tentang batas ini yang berubah secara informal.

Bagian ini bersifat wajib dan harus ditandatangani oleh kedua lead group dan mentor pada GATE 1 (Minggu 4). Bagian ini berversi; `contract_version = 1` adalah nilai yang sedang ditinjau.

17.1 Identifier Bersama

Item	Nilai	Pemilik	Dibekukan?
Prefiks	ENT-, ACC-, TXN-, MER-, DEV-, RUL-, ALR-, SCR-, CAS-, EVD-, DEC-, RPT-, BAT-, RUN-, NAR-	Bersama	☐
Format	Prefiks + alfanumerik buram; consumer tidak boleh mengurai makna dari sebuah ID	Bersama	☐
Penggunaan ulang	Tidak pernah	Bersama	☐
<code>correlation_id</code>	UUIDv4, wajib pada setiap request, job dan event	Bersama	☐
Penerbit	A menerbitkan ENT/ACC/TXN/MER/DEV/RUL /ALR/SCR/BAT/RUN; B menerbitkan CAS/EVD/DEC/RPT/NAR	Bersama	☐

17.2 State Bersama

Kosakata	Nilai	Pemilik	Dibekukan?
Lifecycle alert	NEW, ASSIGNED, IN_REVIEW, ESCALATED, LINKED_TO_CASE, CLOSED_FALSE_POSITIVE, CLOSED_NO_ACTION, MERGED_DUPLICATE, CLOSED_WITH_CASE, REOPENED	Bersama	☐

Kosakata	Nilai	Pemilik	Dibekukan?
Lifecycle case	OPEN, IN_INVESTIGATION, PENDING_DECISION, PENDING_APPROVAL, RETURNED_FOR_REWORK, APPROVED_CLOSED, REOPENED	B	☐
Screening	POTENTIAL_MATCH, UNDER_REVIEW, POSSIBLE_MATCH, CONFIRMED_MATCH, DISMISSED_NO_MATCH, RESCREEN_REQUIRED	Bersama	☐
Tipe keputusan	NO_FURTHER_ACTION, MONITOR, INTERNAL_ESCALATION, DRAFT_REPORT_RECOMMENDED, MERGED_INTO_CASE	B	☐
State laporan	DRAFT_STARTED, DRAFT_COMPLETE, PENDING_MLRO_APPROVAL, APPROVED_INTERNAL, RETURNED — tidak ada state transmisi	B	☐
State rule	DRAFT, IN_SIMULATION, PENDING_APPROVAL, ACTIVE, SUSPENDED, RETIRED, REJECTED	A	☐
Role	Sembilan nilai ROLE_*	Bersama	☐
Kode pattern	P01_... sampai P12_...	A	☐
Kategori reason disposition	Sepuluh nilai dalam §8.2	Bersama	☐

17.3 Antarmuka Bersama

Eksibit 14 — Sebelas antarmuka yang harus dibekukan dan ditandatangani pada gate Minggu 4

#	Antarmuka	Arah	Pemilik	Consumer	Dibekukan?
I-01	Read model alert (GET /detection/alerts/{id}) — himpunan field lengkap sesuai FRD §13.3	A → B	A	B	☐
I-02	Penulisan lifecycle alert (assign,	B → data A	Bersama	A	☐

#	Antarmuka	Arah	Pemilik	Consumer	Dibekukan?
	review, dispose, escalate, reopen, override prioritas) — grant DB level kolom + service				
I-03	Profil entity / blok Entity 360	A → B	A	B	☐
I-04	Timeline (transaksi + penanda event, dengan filter yang digemakan)	A → B	A	B	☐
I-05	Traversal graph (node, edge, cap, flag pemotongan , versi graph, caption)	A → B	A	B	☐
I-06	Sinyal (anomaly + graph, dengan parameter dan caption)	A → B	A	B	☐
I-07	Penilaian risiko (terkini + riwayat + faktor + versi model)	A → B	A	B	☐
I-08	Pembacaan hasil screening	A → B	A	B	☐
I-09	Penulisan review dan konfirmasi screening	B → A	Bersama	A	☐
I-10	Outcome feed (post /detection/out comes)	B → A	B	A	☐

#	Antarmuka	Arah	Pemilik	Consumer	Dibekukan?
I-11	Pembacaan rule version (detail tidak dapat diubah untuk setiap alert, termasuk rule yang telah di-retire)	A → B	A	B	☐

17.4 Event Bersama

Event	Producer	Consumer	schema_version	Dibekukan?
INGESTION_BATCH_COMPLETED	A	B	1	☐
DETECTION_RUN_COMPLETED	A	B	1	☐
ALERT_CREATED	A	B	1	☐
ALERT_SUPPRESSED_AS_DUPLICATE	A	B	1	☐
POTENTIAL_MATCH_CREATED	A	B	1	☐
RISK_BAND_CHANGED	A	B	1	☐
GRAPH_REFRESHED	A	B	1	☐
ALERT_DISPOSED	B	A	1	☐
ALERT_ESCALATED	B	A	1	☐
CASE_CREATED	B	A	1	☐
CASE_DECIDED	B	A	1	☐
SCREENING_STATE_CHANGED	B	A	1	☐
REPORT_APPROVED_INTERNAL	B	A	1	☐

Envelope: event_id, event_type, occurred_at, producer, correlation_id, schema_version, payload. Consumer bersifat idempoten terhadap event_id dan mentoleransi field yang tidak dikenal.

17.5 Autentikasi Antar Layanan

Item	Nilai	Dibekukan?
Panggilan user	Bearer JWT yang diterbitkan oleh api-iam, divalidasi secara independen oleh setiap layanan terhadap kunci publik bersama	☐

Item	Nilai	Dibekukan?
Antar layanan	Satu service principal khusus per layanan dengan role mencakup terbatas (SERVICE_GROUP_B dapat memanggil POST /detection/outcomes dan endpoint baca A→B, dan tidak lebih dari itu)	☐
Correlation	X-Correlation-Id dipropagasikan pada setiap panggilan internal; panggilan tanpa header tersebut ditolak di lingkungan non-development	☐
Jam	Seluruh layanan menggunakan UTC; selisih di atas 60 detik menggagalkan readiness	☐

17.6 Error Bersama

Kode	HTTP	Dibekukan?
VALIDATION_FAILED	400	☐
UNAUTHENTICATED	401	☐
AUTHORIZATION_DENIED	403	☐
SEGREGATION_OF_DUTIES_VIOLATION	403	☐
NOT_FOUND	404	☐
CONFLICT	409	☐
INVALID_TRANSITION	409	☐
GUARD_NOT_MET	409	☐
IMMUTABLE_OBJECT	409	☐
RATE_OR_SIZE_LIMIT	413	☐
BUSINESS_RULE_VIOLATION	422	☐
TOO_MANY_REQUESTS	429	☐
DEPENDENCY_UNAVAILABLE	503	☐

Envelope: {error:{code, message, field, details, audit_event_id, correlation_id}}. AUTHORIZATION_DENIED — bukan NOT_FOUND — dikembalikan untuk objek yang tidak boleh dilihat oleh pemanggil.

17.7 Fixture Pengujian Bersama

Fixture	Pemilik	Isi	Dibekukan?
fixtures/alerts.json	A	12 alert (satu per pattern) + 4 edge case	☐
fixtures/outcomes.json	B	20 record outcome yang mencakup seluruh disposition dan tipe keputusan	☐
fixtures/screening.json	A	8 hasil di keempat state	☐
fixtures/entities.json	A	Entity yang di-merge, yang tidak di-merge dan INSUFFICIENT_DATA	☐
fixtures/graph.json	A	Traversal yang dipotong, edge dengan spesifisitas rendah, versi yang basi	☐
fixtures/audit.json	Bersama	Satu rantai korelasi lengkap	☐
Job contract test	Bersama	CI masing-masing group menjalankan fixture group lain; kegagalan memblokir gate	☐

17.8 Checklist Persetujuan — Minggu 4

#	Item	Lead A	Lead B	Mentor
1	Skema identifier dan penerbit (§17.1) disepakati	☐	☐	☐
2	Seluruh kosakata state (§17.2) disepakati dan lengkap	☐	☐	☐
3	Himpunan field read model alert (I-01) cukup lengkap untuk triage tanpa panggilan tambahan	☐	☐	☐

#	Item	Lead A	Lead B	Mentor
4	Batas penulisan lifecycle alert (I-02) disepakati, termasuk kepemilikan level kolom	☐	☐	☐
5	Field outcome feed (I-10) memadai untuk metrik performa rule	☐	☐	☐
6	Antarmuka screening (I-08, I-09) menegakkan aturan konfirmasi dua orang	☐	☐	☐
7	Antarmuka graph (I-05) membawa cap, flag pemotongan, versi dan caption	☐	☐	☐
8	Katalog event (§17.4) dan envelope disepakati	☐	☐	☐
9	Autentikasi layanan dan propagasi correlation (§17.5) disepakati	☐	☐	☐
10	Kode error dan envelope (§17.6) disepakati	☐	☐	☐
11	Fixture (§17.7) tersedia dan kedua CI pipeline menjalankan pack group lain	☐	☐	☐
12	Schema audit event (§8.8)	☐	☐	☐

#	Item	Lead A	Lead B	Mentor
	disepakati sebagai catatan resmi bersama			
13	Proses perubahan disepakati: setiap breaking change menaikkan contract_version dan memerlukan kedua lead ditambah mentor	☐	☐	☐

Tanda tangan: Lead Group A _____ Lead Group B _____ Mentor V-TEKI _____ Tanggal _____
contract_version yang disetujui: _____

18

18. Milestone, Risiko, Keterbatasan dan Lampiran

POIN UTAMA

- Enam belas minggu, enam gate, dan Definition of Done yang mencakup audit event serta deklarasi otorisasi — bukan hanya fiturnya.
- Delapan risiko teknis dan tujuh trade-off yang disengaja dinyatakan beserta apa yang dikorbankan masing-masing.
- Build Readiness Checklist adalah keluaran praktis dokumen ini: lima belas butir sebelum kode fitur dimulai, sepuluh butir sebelum demonstrasi akhir.

18.1 Milestone Teknis Enam Belas Minggu dan Definition of Done

Eksibit 15 — Enam belas minggu dan enam gate, dengan Definition of Done yang dinyatakan per milestone

Minggu	Milestone teknis	Definition of Done
1	Repository, stack Compose, kerangka CI, schema <i>v0</i>	<code>docker compose up</code> menghasilkan stack kosong yang berjalan; CI menjalankan lint dan satu pengujian
2	Generator <i>v0</i> (<i>tiny/small</i>); kamus data <i>v0</i> ; wireframe	Generator dijalankan dua kali dengan seed yang sama dan menghasilkan file yang identik
3	Ingestion + validasi + quarantine + log pemrosesan	UAT-01 lulus end to end pada profil <i>small</i>
4	Auth, kerangka RBAC, penulis audit, fixture contract	GATE 1 — §17 ditandatangani; setiap route memiliki deklarasi otorisasi; penulisan audit berada di dalam transaksi bisnis
5	Entity resolution; model risiko <i>v1</i>	Jalur ER otomatis/manual/konflik lulus; setiap assessment yang tersimpan memiliki faktor yang jumlahnya sama dengan risk score
6	Rules engine (definisi, versioning, simulasi); kerangka case	Sebuah rule version tidak dapat diedit setelah <i>ACTIVE</i> ; simulasi menghasilkan nol alert
7	Detection run, dedupe, prioritas; generator <i>v2</i> (<i>full</i> , berlabel)	GATE 2 — sebuah detection run nyata menempatkan alert yang dijelaskan ke dalam antrean Group B;

Minggu	Milestone teknis	Definition of Done
		pengujian reproduktibilitas hijau
8	Pattern P01–P06; Entity 360 dan timeline	Setiap pattern memiliki pengujian positif, negatif, batas, penjelasan dan kecukupan yang hijau
9	Pattern P07–P11; pembangunan graph, sinyal, traversal; keputusan maker-checker	DEP-08 — traversal terbatas < 5 s pada profil full; T-MC-07 hijau
10	Screening engine + UI review; layar investigasi graph	GATE 3 — rantai penuh ingestion → alert → case → keputusan dapat didemonstrasikan; pengujian SM-06 hijau
11	Maker-checker lifecycle rule; anomaly scoring; generasi narrative + grounding	FT-01...FT-08 disusun; sebuah pernyataan tanpa dukungan yang disisipkan berhasil tertangkap
12	Metrics engine; persetujuan narrative; draft report	GATE 4 — metrik rule dihitung dari outcome nyata Group B dengan coverage ditampilkan
13	Monitoring model; tata kelola threshold; dashboard; ekspor laporan	Matriks RBAC penuh hijau; watermark hadir pada setiap halaman yang diekspor
14	Performa, aksesibilitas, empty state, penanganan error	GATE 5 — feature freeze; NFR-01...NFR-05 terpenuhi pada host referensi
15	Penyelesaian pengujian, backup/restore, review keamanan dan keamanan data	Pengujian restore tercatat; secret-scan, pii-scan, egress-inventory, language-scan semuanya hijau
16	Dokumentasi, runbook, skrip demo, serah terima	GATE 6 — persetujuan UAT; walkthrough SM-12 selesai dalam kurang dari 20 menit

Definition of Done (setiap story): kode di-merge dengan review; pengujian unit dan API hijau; otorisasi dideklarasikan dan pengujian matriks diperbarui; audit event ditulis dan diverifikasi; jalur error mengembalikan envelope §8.9; empty state dan failure state dirancang; FR ID dirujuk dalam commit; dokumentasi diperbarui; traceability.csv digenerate ulang.

18.2 Kerangka Panduan Deployment

- Prasyarat** — sizing host, versi Docker dan Compose, port, sertifikat TLS (self-signed dapat diterima untuk demo).
- Dapatkan rilis** — clone pada tag rilis; verifikasi digest image.

3. **Konfigurasi** — salin `.env.example` ke `.env`; tetapkan nilai database, MinIO, JWT key, salt hashing ID dan AI provider opsional; tetapkan permission file.
4. **Jalankan data tier** — `docker compose up -d postgres redis minio`; tunggu hingga health.
5. **Migrasi dan seed** — `make migrate`, lalu `make seed-reference`, `make seed-users`, `make seed-definitions`.
6. **Generate data** — `make generate PROFILE=full SEED=<seed>`; verifikasi `generation_report.json` terhadap jumlah yang diharapkan.
7. **Ingest** — daftarkan dan jalankan batch yang dihasilkan; konfirmasi rekonsiliasi.
8. **Jalankan pipeline** — entity resolution, feature, screening, refresh graph, detection run; konfirmasi status run.
9. **Jalankan application tier** — `docker compose up -d`; verifikasi `/ops/ready` untuk setiap service.
10. **Verifikasi** — jalankan smoke checklist: login sebagai setiap role, buka satu alert, konfirmasi rantai audit dapat ditelusuri.
11. **Penjadwalan** — aktifkan backup malam dan job terjadwal.

18.3 Kerangka Runbook

Situasi	Tindakan pertama	Escalation
Batch FAILED	Baca stage dan kode kegagalan pada processing log	Jika struktural, perbaiki file dan daftarkan ulang; jika quality-abort, review quarantine
Ketidakcocokan rekonsiliasi	Bandingkan jumlah pada log dengan jumlah pada tabel untuk batch tersebut	Jangan lanjutkan detection sampai terselesaikan
Detection run gagal	Baca status per rule; identifikasi rule yang gagal	Suspend rule tersebut (MLRO) dan jalankan ulang; alert yang sudah ada tidak terpengaruh
Rule menghasilkan volume tak terkendali	MLRO melakukan suspend; Analyst mensimulasikan set parameter yang direvisi	Versi baru melalui maker-checker
Graph usang	Periksa job refresh dan error terakhirnya	Consumer sudah menampilkan banner keusangan; tidak ada data yang hilang
AI provider mati	Konfirmasi bahwa fallback menghasilkan <code>TEMPLATE_DRAFT</code>	Tidak diperlukan tindakan; catat outage tersebut
Queue menumpuk	Periksa health worker dan usia job tertua	Restart worker; job bersifat idempotent
Tekanan disk	Periksa volume MinIO dan PostgreSQL	Rotasi log; jangan pernah menghapus evidence atau data audit
Restore diperlukan	Ikuti runbook restore; replay ingestion setelah titik restore	Ingestion bersifat idempotent, sehingga replay tidak dapat menduplikasi
Dugaan insiden keamanan data (data non-sintetis)	Hentikan ingestion; isolasi batch tersebut; segera beri	Purge batch yang terdampak dan catat insiden tersebut

Situasi	Tindakan pertama	Escalation
	tahu pembimbing dan mentor	

18.4 Risiko, Trade-off dan Keterbatasan

Risiko teknis

ID	Risiko	Mitigasi
TR-01	Detection run melampaui target 30 menit pada volume penuh	Pra-komputasi feature; indeks; batch terpotong; timeout per rule; kurangi menjadi 300k transaksi jika diperlukan (TA-05)
TR-02	Penelusuran recursive-CTE menurun pada komponen yang padat	Batas keras kedalaman dan node; pengurutan deterministik; indeks pada kedua arah; COMPONENT_SIZE dilaporkan sebagai "> N"
TR-03	Dua service API yang berbagi satu database bergeser menjadi coupling implisit	Grant pada level kolom dan tabel; contract test; kepemilikan per schema
TR-04	Audit di dalam transaksi meningkatkan latensi penulisan	Insert audit bersifat sempit dan diindeks untuk pembacaan, bukan penulisan; diukur pada T-PERF-01
TR-05	AI provider tidak tersedia saat demonstrasi	TemplateProvider merupakan jalur first-class yang dikirimkan dan diuji dalam UAT
TR-06	Realisme generator tidak memadai sehingga rule tampak akurat secara trivial	Edge cohort disusun agar berdekatan secara perilaku dengan positif yang diinjeksikan (§11.2); mentor me-review katalog skenario pada Minggu 7
TR-07	Tim belum terbiasa dengan FastAPI/SQLAlchemy	Fallback ADR-002 diputuskan pada gate Minggu 4, tidak lebih lambat
TR-08	Kesalahan migration menyebabkan kehilangan data	Forward-only dengan downgrade yang teruji; backup malam; replay idempotent

Trade-off yang disengaja

Trade-off	Yang dipilih	Yang dilepaskan
Graph relasional vs graph database	Satu datastore, satu backup, satu batas transaksi	Analitik graph mendalam
Template rule SQL vs DSL pengguna	Reproduksibilitas, performa, tanpa permukaan injeksi	Logika baru yang ditulis Analyst tanpa developer
Model risiko terboboti yang transparan vs ML	Keterjelasan penuh	Kemungkinan peningkatan deteksi
Audit di dalam transaksi bisnis	Kelengkapan terjamin	Latensi penulisan sedikit lebih tinggi; audit tidak dapat dieksternalisasi
Database bersama antara kedua service	Tidak ada transaksi terdistribusi	Membutuhkan disiplin schema
Tanpa enkripsi level kolom	Query deteksi yang dapat diindeks	Perlindungan at-rest lebih lemah untuk field tertentu; dimitigasi dengan enkripsi disk dan masking
NFR kelas demonstrasi	Dapat diselesaikan dalam 16 minggu	Tanpa klaim HA, DR atau hardening

Keterbatasan (harus dinyatakan dalam presentasi akhir) — sepuluh keterbatasan L-01...L-10 pada FRD §14.5 berlaku tanpa perubahan, ditambah: TL-01 deployment single-node tanpa high availability; TL-02 tanpa MFA; TL-03 tanpa enkripsi level kolom; TL-04 tanpa partisi (langkah scaling pertama); TL-05 tanpa monitoring model drift, karena populasinya statis; TL-06 tanpa streaming ingestion; TL-07 graph dibangun ulang secara penuh, bukan secara inkremental.

18.5 Roadmap Produksi Masa Depan (indikatif, di luar lingkup)

Horizon	Pekerjaan
Hardening segera	MFA; secrets manager; enkripsi level kolom untuk identifier; WAF; penetration test; threat model formal
Skala	Partisi transaksi berdasarkan bulan bisnis; read replica untuk permukaan investigasi; pembaruan graph inkremental; broker untuk pengiriman event
Kematangan deteksi	Pengujian rule champion/challenger; rekomendasi threshold otomatis yang diajukan untuk persetujuan manusia ; scoring berbasis umpan balik; monitoring drift
Platform data	Integrasi sumber nyata dengan kontrak schema-registry; ingestion CDC; feature store; perkakas lineage
Operasi	High availability, disaster recovery, RPO/RTO formal, runbook on-call, SLO

Horizon	Pekerjaan
Tata kelola	Validasi model independen, siklus review rule berkala, resertifikasi akses formal, retensi dan purge dengan persetujuan ganda
Pelaporan	Penyelarasan dengan template regulasi yang berlaku, disiapkan untuk pelapor manusia — transmisi tetap berada di luar platform

18.6 Lampiran A — Kamus ERD (indeks)

Schema	Tabel
raw	landed_customer, landed_business_customer, landed_beneficial_owner, landed_account, landed_merchant, landed_device, landed_transaction, landed_watchlist, quarantine_item
core	party_source_record, entity, entity_source_record, entity_lineage, er_candidate, er_candidate_field_score, account, merchant, beneficial_owner, device, ip_address, phone, email, address, transaction, counterparty, fx_rate
detect	entity_feature, risk_model_version, risk_assessment, risk_factor, risk_band_override, anomaly_model_version, anomaly_score, anomaly_feature, graph_node, graph_edge, graph_signal, rule, rule_version, screening_config_version, watchlist_version, watchlist_record, screening_result, alert, alert_factor, alert_transaction, alert_relation
invest	case, case_subject, case_alert, case_note, case_relation, evidence, decision, decision_evidence, narrative, narrative_flag, regulatory_report, report_version, notification
gov	app_user, role, user_role, session, audit_event, ai_usage_log, configuration_version, configuration_value, sensitive_field_policy, geography_list_version, geography_list_entry
meta	ingestion_batch, ingestion_file, processing_log, dq_metric, detection_run, detection_run_rule, simulation_result, metric_snapshot, graph_version, domain_event, scenario_label

18.7 Lampiran B — Katalog API (indeks)

Group A: A1–A36 (§8.3). Group B: B1–B35 (§8.4). Bersama: S1–S9 (§8.5). Antarmuka A↔B: I-01...I-11 (§17.3). Event: 13 tipe (§17.4). Error: 13 kode (§17.6).

18.8 Lampiran C — Inventaris Rule dan Model

Artefak	ID	Versi saat pengiriman	Pattern / lingkup	Approver
Transaksi besar	RUL-0001	1	P01	MLRO
Structuring	RUL-0007	3	P02	MLRO
Pergerakan cepat	RUL-0012	1	P03	MLRO
Velocity tinggi	RUL-0018	2	P04	MLRO
Reaktivasi dormant	RUL-0023	1	P05	MLRO
Nominal bulat	RUL-0029	1	P06	MLRO
Lonjakan mendadak	RUL-0034	1	P07	MLRO
Geografi berisiko tinggi	RUL-0041	2	P08	MLRO
Device bersama	RUL-0047	1	P09	MLRO
Merchant tidak lazim	RUL-0052	1	P10	MLRO
Aliran funnel	RUL-0058	1	P11	MLRO
Screening watchlist	RUL-0063	1	P12 (via screening engine)	MLRO
Model risiko individu	risk_individual	v2	Scoring customer	MLRO
Model risiko merchant	risk_merchant	v1	Scoring merchant	MLRO
Model anomali	anomaly	v1	Sinyal pendukung	MLRO
Konfigurasi screening	screen	v1	Pencocokan nama	MLRO
Formula prioritas	priority	v1	Prioritisasi alert	MLRO
Feature set	features	v1	Agregat bersama	Analyst
Daftar geografi	geo_list	v2	P08 dan risiko	MLRO

18.9 Lampiran D — Checklist Kesiapan Build

Sebelum menulis kode feature (Minggu 4):

#	Item	✓
1	FRD dibekukan pada v1.0 dengan jawaban mentor untuk MQ-01...MQ-10	☐
2	Kontrak Integrasi §17 ditandatangani; contract_version = 1	☐
3	Repository, stack Compose dan pipeline CI berjalan dengan seluruh job guardrail	☐
4	Schema database dibuat dengan role, grant, trigger audit dan constraint guardrail di dalam migration	☐
5	Autentikasi dan fungsi authorize() tersedia; assertion saat startup untuk route yang tidak dideklarasikan aktif	☐
6	Audit writer tersedia bagi kedua group dan terbukti menulis di dalam transaksi bisnis	☐
7	Propagasi correlation ID berfungsi di gateway, kedua API dan job worker	☐
8	Generator vø deterministik; kamus data diterbitkan	☐
9	Fixture bersama diterbitkan; kedua pipeline CI menjalankan pack group lainnya	☐
10	.env.example di-commit; tidak ada secret di repository; secret-scan hijau	☐
11	pii-scan, egress-inventory dan language-scan hijau	☐
12	Error envelope dan daftar kode diimplementasikan dalam library bersama yang digunakan kedua service	☐
13	Marker test dan pembuatan traceability.csv berfungsi	☐

#	Item	✓
14	Keputusan stack ADR-001 atau ADR-002 dikonfirmasi	☐
15	Job backup dikonfigurasi; restore telah dicoba setidaknya satu kali	☐

Sebelum demonstrasi akhir (Minggu 15):

#	Item	✓
16	Seluruh dua belas pattern menyala pada positif berlabel; nol alert pada control cohort	☐
17	Uji reproduksibilitas hijau pada profil penuh	☐
18	Matriks RBAC dan uji maker-checker hijau, termasuk pengguna multi-role	☐
19	Rantai audit dapat ditelusuri melalui correlation ID dari batch hingga laporan yang disetujui	☐
20	Set faktualitas FT-01...FT-08 hijau	☐
21	Target performa NFR-01...NFR-05 terpenuhi pada host demonstrasi	☐
22	Watermark hadir pada setiap export; tidak ada jalur egress	☐
23	Restore diuji dan dicatat	☐
24	Ketertelusuran menunjukkan setiap FR berprioritas m memiliki test yang lulus	☐
25	Slide keterbatasan disiapkan, menyatakan bahwa seluruh metrik bersifat sintetis	☐

Akhir Dokumen Kebutuhan Teknis dan Desain Solusi. Dokumen ini berada di bawah FCIP-FRD v1.0; apabila keduanya berbeda, FRD yang berlaku dan konflik tersebut dicatat pada §1.5.